

# **A Trusted Authorisation Framework for Multi-Party Patient Consent in Healthcare Data Sharing**

Principal Supervisor: Professor Farookh Hussain

Co-Supervisor: Dr. Firas Al-Doghman

Presenter: Yasir Dhaifallah O Alyoubi

Student ID: 24724078

August 2026



# Pre-Submission Risk Review (generated — remove before submitting)

- ◆ [RED — يجب حله قبل التسليم] R1 (p. 6.8.12): re-verify every Sepolia Etherscan link (contract, mint tx, revoke tx, tokens) still resolves.
- ◆ [RED — يجب حله قبل التسليم] R2 (7.4, 7.5): RO4 Completed / RO5 Largely Completed upgrades the original staging - confirm with your supervisor and be ready to defend in the viva.
- ◆ [RED — يجب حله قبل التسليم] R3 (2.2.6): PRISMA numbers must match your real reference-manager export; fix prose AND Figure 2 together if they differ.
- ◆ [RED — يجب حله قبل التسليم] R4 (2.2.7): the quality-assessment procedure described must be one you actually performed.
- ◆ [RED — يجب حله قبل التسليم] R5 (2.2.4): the search claim (databases, dates) must be reproducible; keep the search logs.
- ◆ [RED — يجب حله قبل التسليم] R7 (References [21]): read Welzel et al. 2025 and confirm it supports its three citation sites.
- ◆ [GREEN — غير مهم] Y1 - FIXED: the cover and document title now read Authorisation, matching the body. Inform your supervisor of the spelling alignment.
- ◆ [GREEN — غير مهم] Y2 - FIXED: the procedure now sits in Section 6.5.2, directly before Algorithm 5 (renumbered 6.5.3); the former 6.4.3/6.4.4 are now 6.4.2/6.4.3.
- ◆ [GREEN — غير مهم] Y3 - FIXED: the composite predicate is renamed  $V_s(C, t, q)$  with a clarifying sentence separating it from the jurisdictional  $V^L(C)$ .
- ◆ [GREEN — غير مهم] Y4 - FIXED: the 7.6 status now reads Partially Completed (empirical validation complete; formal assurance outstanding).
- ◆ [GREEN — غير مهم] Y5 - FIXED: the duplicate Figure A in 6.5 is removed; the implemented state machine remains in Section 6.8.6 and Table 10 points there.
- ◆ [GREEN — غير مهم] Y6 - FIXED: all figures and tables are now in single numeric sequences - Figures 1-40 (former 2a/2b/2c are 3/4/5; the RO1 consent-object model is the new Figure 11; implementation screenshots are 17-40) and Tables 1-10; every in-text reference was remapped.
- ◆ [GREEN — غير مهم] G1 (References): [21]/[34] alphabetical-order break - harmless in numeric style.
- ◆ [GREEN — غير مهم] G2 (companion file): the short report uses the label Done where this report uses Completed for RO1-RO3.
- ◆ [GREEN — غير مهم] G3 (algorithms): grey line numbers are the original design of your listings.
- ◆ [GREEN — غير مهم] G4 (references): minor style variance ([27] keeps the TMIS abbreviation; [20] has no issue number).

## Contents

|                                              |    |
|----------------------------------------------|----|
| <b>1 Introduction</b>                        | 6  |
| 1.1 Research Context                         | 6  |
| 1.2 Problem Statement                        | 7  |
| 1.3 Research Motivation                      | 9  |
| <b>2 Systematic Literature Review</b>        | 13 |
| 2.1 Overview                                 | 13 |
| 2.2 Systematic Literature Review Methodology | 13 |
| 2.2.1 Review Design and Reporting Framework  | 14 |
| 2.2.2 Questions for Review                   | 14 |
| 2.2.3 Search Databases and Search Strategy   | 15 |

|                                                                        |           |
|------------------------------------------------------------------------|-----------|
| 2.2.4 Search Period and Search Execution.....                          | 16        |
| 2.2.5 Eligibility Criteria.....                                        | 16        |
| 2.2.6 Screening and Study Selection.....                               | 18        |
| 2.2.7 Data Extraction and Synthesis.....                               | 19        |
| 2.3 Review.....                                                        | 20        |
| 2.3.1 Healthcare Consent and Decentralised Data Governance.....        | 21        |
| 2.3.2 Blockchain-Based Consent and Data Governance.....                | 22        |
| 2.3.3 Decentralised Identity and Verifiable Credentials.....           | 23        |
| 2.3.4 Multi-Party Authorisation and Collaborative Consent.....         | 24        |
| 2.3.5 Policy-Based and Context-Aware Access Control.....               | 25        |
| 2.3.6 Trusted Computing, Secure Execution, and Security Assurance..... | 26        |
| 2.3.7 Comparative Analysis of Existing Approaches.....                 | 28        |
| 2.4 Synthesis and Research Gap.....                                    | 29        |
| <b>3 Research Gaps and Questions.....</b>                              | <b>32</b> |
| 3.1 Research Gap.....                                                  | 32        |
| 3.2 Main Research Question.....                                        | 33        |
| 3.3 Sub-Research Questions.....                                        | 34        |
| 3.3.1 SRQ1: Trust-Centric Consent Modelling.....                       | 34        |
| 3.3.2 SRQ2: Decentralised Identity and Authority Trust.....            | 35        |
| 3.3.3 SRQ3: Trustworthy Multi-Party Authorisation.....                 | 35        |
| 3.3.4 SRQ4: Policy- and Context-Aware Access Control.....              | 36        |
| 3.3.5 SRQ5: Temporal and Lifecycle Trust.....                          | 37        |
| 3.3.6 SRQ6: Formal Security Assurance and Empirical Validation.....    | 38        |
| 3.4 Research Questions as an Integrated Research Problem.....          | 39        |
| <b>4 Research Objectives.....</b>                                      | <b>42</b> |
| 4.1 RO1 - Trust-Centric Consent Model.....                             | 42        |
| 4.2 RO2 - Decentralised Identity and Authority Trust.....              | 42        |
| 4.3 RO3 - Trustworthy Multi-Party Authorisation.....                   | 42        |
| 4.4 RO4 - Policy- and Context-Aware Access Control.....                | 43        |
| 4.5 RO5 - Temporal and Lifecycle Trust.....                            | 43        |
| 4.6 RO6 - Formal Security Assurance and Empirical Validation.....      | 44        |
| 4.7 Relationship Between Research Questions and Objectives.....        | 45        |
| <b>5 Research Architecture: MVC.....</b>                               | <b>48</b> |
| 5.1 MVC Layered Architecture and Component Decomposition.....          | 48        |
| 5.1.1 MVC Component Decomposition.....                                 | 50        |
| 5.1.2 Trust Evaluation Across the MVC Layers.....                      | 52        |
| 5.1.3 Relationship Between MVC Layers and Research Questions.....      | 53        |
| 5.1.4 Architectural Boundary and Trust Assumptions.....                | 54        |
| 5.2 Trust-Oriented Consent Authorisation Workflow.....                 | 55        |
| 5.3 Model: Trust-Aware Consent and Authorisation Representation.....   | 58        |
| 5.4 View: Controlled Interaction Among Independent Participants.....   | 59        |
| 5.5 Controller: Trusted Multi-Party Authorisation Enforcement.....     | 60        |
| 5.6 Multi-Party Consent as Distributed Trust Establishment.....        | 61        |
| 5.7 Policy-Aware Consent Enforcement.....                              | 62        |
| 5.8 Authorisation Evidence and Auditability.....                       | 62        |
| 5.9 Architectural Security Properties.....                             | 63        |

|                                                                         |            |
|-------------------------------------------------------------------------|------------|
| 5.10 MVC Architecture and the Research Objectives.....                  | 64         |
| 5.11 Architectural Contribution and Scope.....                          | 64         |
| <b>6 Proposed Solution.....</b>                                         | <b>67</b>  |
| 6.1 Trust-Centric Consent Model for RO1.....                            | 67         |
| 6.1.1 RO1 Consent Creation Workflow.....                                | 67         |
| 6.1.2 Procedure for Trust-Aware Consent Creation.....                   | 69         |
| 6.1.3 Algorithm 1: Trust-Aware Consent Creation.....                    | 72         |
| 6.2 Decentralised Identity and Authority Trust for RO2.....             | 72         |
| 6.2.1 RO2 Identity and Authority Verification Workflow.....             | 72         |
| 6.2.2 Procedure for DID and VC Identity and Authority Verification..... | 73         |
| 6.2.3 Algorithm 2: DID and VC Identity and Authority Verification.....  | 76         |
| 6.3 Trustworthy Multi-Party Authorisation for RO3.....                  | 77         |
| 6.3.1 RO3 Multi-Party Authorisation Workflow.....                       | 77         |
| 6.3.2 Procedure for Threshold-Based Multi-Party Authorisation.....      | 78         |
| 6.3.3 Algorithm 3: Threshold-Based Multi-Party Authorisation.....       | 81         |
| 6.4 Policy- and Context-Aware Access Control for RO4.....               | 82         |
| 6.4.1 RO4 Policy-Aware Access Workflow.....                             | 83         |
| 6.4.2 Algorithm 4: Policy-Aware Access Decision.....                    | 84         |
| 6.4.3 Procedure for Policy-Aware Access Decision.....                   | 85         |
| 6.5 Temporal and Lifecycle Trust for RO5.....                           | 88         |
| 6.5.1 RO5 Temporal and Lifecycle Workflow.....                          | 89         |
| 6.5.2 Procedure for Temporal and Lifecycle Validation.....              | 89         |
| 6.5.3 Algorithm 5: Temporal and Lifecycle Validation.....               | 92         |
| 6.6 Formal Security Assurance and Empirical Validation for RO6.....     | 93         |
| 6.6.1 RO6 Assurance and Validation Workflow.....                        | 94         |
| 6.6.2 Procedure for Formal and Empirical Authorisation Validation.....  | 94         |
| 6.6.3 Algorithm 6: Formal and Empirical Authorisation Validation.....   | 99         |
| 6.7 Algorithms and the Research Objectives.....                         | 100        |
| 6.8 Implementation and Live Demonstration of the Proposed Solution..... | 102        |
| 6.8.1 The HALAH System.....                                             | 102        |
| 6.8.2 Create Smart Consent Contract: Patient Subsystem.....             | 106        |
| 6.8.3 Guardian Cryptographic Approval.....                              | 108        |
| 6.8.4 Secure Patient Data Access for the Doctor.....                    | 112        |
| 6.8.5 Negative Demonstration: Jurisdiction Violation.....               | 116        |
| 6.8.6 Consent Revocation.....                                           | 118        |
| 6.8.7 Blockchain Audit and Consent Lifecycle for the Auditor.....       | 121        |
| 6.8.8 Detailed Audit Records.....                                       | 124        |
| 6.8.9 Complete Audit Ledger and Independent Verification.....           | 124        |
| 6.8.10 Correspondence Between the Subsystems and the Framework.....     | 125        |
| 6.8.11 Overall System Demonstration.....                                | 126        |
| 6.8.12 Verification Links.....                                          | 127        |
| <b>7 Current Progress Status.....</b>                                   | <b>128</b> |
| 7.1 Progress of RO1: Trust-Centric Consent Model.....                   | 128        |
| 7.2 Progress of RO2: Decentralised Identity and Authority.....          | 128        |
| 7.3 Progress of RO3: Trustworthy Multi-Party Authorisation.....         | 129        |
| 7.4 Progress of RO4: Policy-Aware Access Control.....                   | 129        |
| 7.5 Progress of RO5: Temporal and Lifecycle Trust.....                  | 130        |

|                                                             |     |
|-------------------------------------------------------------|-----|
| 7.6 Progress of RO6: Security Assurance and Validation..... | 130 |
| <b>8 Publications Summary</b> .....                         | 132 |
| <b>9 Research Plan</b> .....                                | 133 |
| 9.1 Current Stage: Completed and Current Work.....          | 133 |
| 9.2 Next Stage: Planned Work.....                           | 133 |
| <b>References</b> .....                                     | 138 |

# 1 Introduction

## 1.1 Research Context

The rapid digitalisation of contemporary society has created an increasing demand for secure, interoperable, and trustworthy data sharing across organisational and institutional boundaries. Modern digital ecosystems frequently involve multiple independent stakeholders, including individuals, healthcare providers, service organisations, regulatory authorities, researchers, and third-party data processors, who may need to exchange information while maintaining privacy, accountability, and control over how that information is used [6, 19]. Although digital transformation creates significant opportunities for collaboration and service innovation, it also introduces a fundamental governance challenge: how can data access be authorised and trusted when the participating entities do not belong to a single administrative or institutional domain?

Healthcare represents a particularly important and challenging example of this broader problem. The increasing digitisation and decentralisation of healthcare information enables patients, healthcare professionals, guardians, researchers, healthcare organisations, and other authorised entities to participate in data-sharing processes [31, 14]. At the same time, healthcare data is highly sensitive, heterogeneous, and often subject to strict privacy, ethical, and governance requirements. Its exchange therefore raises complex questions concerning identity, authority, patient consent, privacy protection, accountability, and fine-grained access control [24, 22, 12].

Traditional access-control architectures are commonly based on centralised identity providers, institution-specific authentication systems, and relatively static permission-management mechanisms [28, 25, 11]. These approaches can provide effective access control within a well-defined organisational boundary, but they become increasingly difficult to apply when authorisation decisions involve multiple independent entities operating across decentralised or cross-organisational environments. In such settings, no single participant may possess sufficient authority to determine access independently, and trust cannot necessarily be assumed on the basis of membership in a common administrative domain.

This problem is particularly relevant in healthcare, where data-sharing decisions may require the coordinated participation of patients, guardians, healthcare professionals, institutional authorities, and other authorised stakeholders [21, 9]. Similar challenges also arise in enterprise, financial, and other cross-organisational data-sharing environments, where a decision may depend on the joint approval of customers, service providers, compliance entities, or regulatory authorities. These scenarios demonstrate that authorisation is increasingly a distributed governance problem rather than simply a process of authenticating a user and checking a static permission.

Several emerging technologies provide important building blocks for addressing these challenges. Blockchain-based mechanisms can provide tamper-resistant recording and distributed auditability, while decentralised identifiers can support the identification of participants without relying exclusively on a central identity provider. Verifiable credentials can provide cryptographically verifiable evidence concerning roles, attributes, qualifications, or authority, and cryptographic and policy-based access-control mechanisms can restrict access to authorised resources [2, 7, 3]. More broadly, blockchain-based approaches have demonstrated the potential to improve the integrity, transparency, and traceability of decentralised data-management processes [8, 1].

However, the availability of these technologies does not, by itself, establish trustworthy authorisation. Blockchain can preserve evidence that a consent event or transaction has occurred, but the existence of an immutable record does not necessarily demonstrate that the participating entities were legitimate, that they possessed the required authority, that all necessary parties participated in the decision, or that a subsequent data-access request remains consistent with the conditions originally authorised. Similarly, a decentralised identity may establish who an entity is, while a verifiable credential may provide evidence concerning the entity's role or attributes, but neither mechanism independently determines whether access to a particular patient's data should be granted.

The fundamental challenge is therefore not simply how to record consent in a decentralised system. Rather, it is how to coordinate identity verification, authority evaluation, collective decision-making, policy enforcement, and auditable evidence so that a data-access decision can be regarded as trustworthy. This requires a transition from viewing consent as a static record of permission towards understanding consent as an active and evaluable component of a broader authorisation process.

## **1.2 Problem Statement**

Existing consent-management and decentralised access-control approaches commonly represent authorisation through database records, access-control entries, smart contracts, or blockchain transactions. These mechanisms can improve record integrity, traceability, and auditability, but consent itself often remains a relatively passive artefact indicating that a permission or approval has been created. The relationship between the consent record, the identity of the participants, their authority to act, the required authorisation conditions, the applicable policy constraints, and the resulting access decision is frequently treated as a collection of separate technical concerns.

This creates a fundamental distinction between consent representation and trustworthy authorisation enforcement. A consent record can demonstrate that a decision has been created or recorded, but it does not

necessarily establish why that decision should be trusted when it is subsequently exercised. Immutability protects the integrity of recorded information, but immutability alone does not verify the legitimacy of the entities that participated in the decision. Likewise, successful authentication establishes that an entity has been identified, but authentication does not automatically establish that the entity possesses the authority to access a particular patient's information.

The problem becomes more complex when healthcare data sharing requires the coordinated authorisation of multiple independent participants. A patient may initiate consent, while guardians, healthcare professionals, or institutional authorities may also need to participate in the authorisation process. In such circumstances, a valid access decision should not necessarily be generated by a single participant acting independently. Instead, the authorisation process may need to establish whether the required set of independently verified participants has satisfied a defined collective approval condition.

Even where identity and collective approval requirements have been satisfied, an access request may still be inappropriate if it exceeds the authorised purpose or data scope. For example, a healthcare professional may possess a valid identity and participate in a valid consent process while subsequently requesting information that was not included in the patient's original authorisation. Consequently, identity verification and multi-party approval alone are insufficient to guarantee trustworthy access. The requested operation must also be evaluated against the policy constraints associated with the consent.

The central problem addressed by this research is therefore the absence of an integrated trust-oriented mechanism that connects these different conditions within a coherent authorisation decision. Existing approaches provide important technological components, including decentralised identity, verifiable credentials, blockchain-based records, multi-party approval mechanisms, and policy-based access control [20, 15]. However, these mechanisms are often investigated independently or integrated primarily at the implementation level without providing a unified Trust Computing model explaining how their combined operation establishes a trustworthy authorisation outcome.

Accordingly, the problem is not primarily whether consent can be stored securely or whether a blockchain transaction can be made immutable. The more fundamental problem is whether a system can determine that a particular data-access request has been generated under sufficient and verifiable trust conditions. This requires a framework capable of evaluating the legitimacy and authority of participating entities, determining whether the required collective authorisation has been established, and verifying that the requested operation remains consistent with the policy constraints defined by the consent.

The proposed research therefore addresses trustworthy authorisation as a coordinated security problem. The objective is to move beyond a model in which consent is primarily represented as a static permission and towards a model in which consent functions as a security-bearing authorisation object whose associated trust conditions can be explicitly represented and evaluated.

### **1.3 Research Motivation**

The framework has been extended to incorporate temporal validity and lifecycle trust. In particular, validity periods and expiration are enforced at the point of evaluation and mirrored on-chain, revocation is executed as a verifiable blockchain transaction, and consent progresses through controlled state transitions. This is important because trust cannot be regarded as permanently established at the moment a consent is created.

Adversarial and negative testing has been undertaken using the HALAH prototype, encompassing per-dimension denial scenarios, signature-rejection tests, and zero-knowledge tamper and expiry tests, together with a live negative evaluation on the Sepolia network. Consequently, formal security analysis remains the subject of the next research stage.

The motivation of this research is to develop a Trust Computing perspective in which trustworthy healthcare data access emerges from the coordinated verification and enforcement of multiple security conditions. Under this perspective, trust is not treated as a property that is provided by blockchain, decentralised identity, or any other individual technology. Instead, trustworthy authorisation is understood as an emergent property of a decision process in which independently verifiable conditions must be satisfied.

This perspective requires a clear separation between several concepts that are often implicitly combined within conventional access-control systems. Identity concerns whether a participant can be reliably identified. Authority concerns whether that participant possesses the relevant role, capability, or permission to participate in a particular decision. Multi-party authorisation concerns whether all required independent participants have jointly established the authorisation condition. Policy compliance concerns whether the requested access is consistent with the authorised purpose and data scope. Together, these conditions provide the foundation for determining not only whether access has been requested, but whether the resulting authorisation decision has a sufficient basis to be trusted.

The proposed framework consequently conceptualises patient consent as more than a static permission or a historical blockchain record. Consent is instead treated as a structured and trust-aware authorisation object that connects the relevant participants, authority requirements, policy constraints, and evidence associated with an authorisation decision. This conceptualisation makes it possible to evaluate the relationship between the consent itself and a subsequent data-access request rather than

assuming that the existence of a recorded consent automatically justifies future access.

The current research concentrates on the foundational dimensions required to construct this trust-oriented authorisation model. The first focus is the development of a trust-centric consent representation capable of capturing the conditions associated with an authorisation decision. Building on this representation, the research investigates how decentralised identifiers and verifiable credentials can establish trustworthy participants while maintaining a clear conceptual separation between identity authentication and authorisation authority. The framework then extends individual trust to collective trust through a multi-party authorisation mechanism, ensuring that sensitive healthcare data access can require the coordinated approval of multiple independently verified participants. Finally, policy-aware access control is incorporated to ensure that a valid identity or sufficient set of approvals cannot be used to obtain information outside the purpose or data scope authorised by the patient.

These four dimensions collectively define the foundational scope of Multi-Party Patient Consent. Their significance lies in the fact that they address different but interdependent aspects of the same authorisation problem. A trustworthy consent model cannot operate effectively without reliable evidence concerning the identity and authority of its participants. Similarly, verified identities and collective approval do not guarantee trustworthy access unless the resulting request remains within the policy constraints associated with the consent. The Multi-Party Patient Consent research therefore investigates these mechanisms as coordinated conditions of a unified authorisation model rather than as independent security features.

A consent that was valid when initially approved may subsequently become invalid due to expiration, revocation, or a change in its authorised lifecycle state.

Formal analysis will be used to define the security properties expected from the proposed trust-oriented authorisation model and to reason about whether unauthorised entities or invalid authorisation conditions can produce an apparently valid access decision under defined assumptions. The distinction between the current contribution and the subsequent research is summarised in Table 1.

Table 1 summarises the research dimensions, distinguishing those realised in the implemented HALAH prototype from the formal security assurance that remains for the subsequent research.

This separation establishes a clear progression between the current and subsequent stages of the research. The current research is concerned primarily with establishing the conceptual and technical foundations through which trustworthy multi-party authorisation can be constructed.

The current research is concerned primarily with establishing the conceptual and technical foundations through which trustworthy multi-party authorisation can be constructed.

Ultimately, the research is motivated by the argument that trustworthy healthcare data sharing cannot be guaranteed by a single technological mechanism. Blockchain can provide tamper-resistant evidence, decentralised identity can establish participant identity, verifiable credentials can provide evidence of authority, and policy mechanisms can constrain access. However, the security value of these mechanisms depends on how they are coordinated within the authorisation process. The proposed research therefore seeks to provide a trust-oriented authorisation framework in which these independently verifiable conditions contribute collectively to a defensible and explainable decision about whether a particular healthcare data-access request should be permitted.

**Table 1:** Research Scope and Progression

| Stage   | Research Dimension                              | Purpose and Core Objective                                                                                                                                                                                                                 |
|---------|-------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Current | RO1: Trust-Centric Consent Modelling            | Develop a structured and evaluable representation of patient consent as a trust-aware authorisation object that explicitly connects identity, authority requirements, policy constraints, and authorisation evidence.                      |
| Current | RO2: Decentralised Identity and Authority Trust | Establish trustworthy participants using decentralised identifiers and verifiable credentials while explicitly separating identity authentication from authorisation authority.                                                            |
| Current | RO3: Trustworthy Multi-Party Authorisation      | Establish collective trust by requiring multiple independently verified participants to satisfy predefined authorisation conditions before sensitive healthcare data access can be granted.                                                |
| Current | RO4: Policy- and Context-Aware Authorisation    | Ensure that authorised access remains consistent with the purpose, policy, and healthcare data scope specified by the consent, preventing valid identities and approvals from being used to obtain data beyond the authorised constraints. |

| Stage                               | Research Dimension                                      | Purpose and Core Objective                                                                                                                                                                                                                    |
|-------------------------------------|---------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Current                             | RO5: Temporal and Lifecycle Trust                       | Extend the authorisation model with validity periods, expiration, revocation, and controlled consent-state transitions to support dynamic and lifecycle-aware trust evaluation.                                                               |
| Current (empirical) / Next (formal) | RO6: Formal Security Assurance and Empirical Validation | Formally define and analyse the security and authorisation properties of the proposed framework and empirically evaluate the complete HALAH implementation using representative healthcare data-sharing, negative, and adversarial scenarios. |

## **2 Systematic Literature Review**

### **2.1 Overview**

The systematic literature review examines the current state of research on trustworthy and decentralised data sharing, with particular attention to healthcare consent management, multi-party trust data governance, decentralised identity, verifiable credentials, multi-party authorisation, policy-based access control, and Trusted Computing. The objective of the review is not simply to identify technologies that can be applied to healthcare data sharing, but to examine how existing approaches address different conditions required for a trustworthy authorisation decision and where conceptual or architectural gaps remain.

The reviewed literature demonstrates that substantial progress has been made in individual areas. Healthcare research has emphasised the importance of patient autonomy, privacy, informed consent, and controlled data sharing [31, 14, 24, 22, 12]. Multi-party trust research has investigated immutable data governance, distributed auditability, and decentralised trust [2, 7, 3, 30, 26]. Research on decentralised identity and verifiable credentials has developed mechanisms for self-controlled identity representation, credential verification, selective disclosure, and privacy-preserving authentication [20, 33, 4, 16, 5, 27]. Access-control research has further investigated role-based, attribute-based, risk-aware, and usage-control approaches for protecting sensitive healthcare information [32, 11, 28, 25].

However, the literature also indicates that these mechanisms are commonly developed and evaluated as separate technological components. This fragmentation creates an important distinction between the availability of security mechanisms and the ability to construct a unified and trustworthy authorisation decision. The following sections analyse these research areas and identify the gap addressed by the proposed framework.

### **2.2 Systematic Literature Review Methodology**

The review corpus comprises the 33 studies identified through the search and screening process described in the remainder of this section. Thirty-two of the 33 included studies were published between 2022 and 2026; one earlier foundational study [31] was retained under the eligibility provision for necessary foundational contributions. The corpus concentrates on blockchain-based data governance, decentralised identity, verifiable credentials, healthcare access control, and consent management.

Within this corpus, references [1, 2, 3, 7, 9, 10, 11, 12, 13, 14, 21, 22, 24, 25, 28, 31, 32] address the healthcare data sharing, consent, and access-control dimensions of the review, while references [4, 5, 15, 16, 20, 27, 33] address the decentralised identifier, verifiable credential, and trust-

architecture dimensions; the remaining studies contribute to multi-party governance and security assurance.

### **2.2.1 Review Design and Reporting Framework**

A systematic literature review (SLR) was conducted to identify, classify, and critically evaluate existing research on multi-party healthcare data sharing, patient consent management, decentralised identity, privacy-preserving access control, and auditability. The review was designed to establish the conceptual and technical foundations of the research and thus of the proposed framework, as well as to identify the limitations of existing approaches that motivate the research questions of this study. In particular, the review considered not only the use of multi-party trust management for healthcare data management, but also the relationship between consent specification, identity verification, authorisation enforcement, privacy preservation, and auditable data access.

The review process was structured according to the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA) framework [34]. PRISMA was adopted to improve the transparency, reproducibility, and traceability of the literature identification and selection process. The review consisted of four principal stages including identification, screening, eligibility assessment, and inclusion. The reporting of these stages was complemented by a predefined search strategy, explicit inclusion and exclusion criteria, and a quality assessment procedure.

### **2.2.2 Questions for Review**

This systematic literature review is guided by the following questions:

1. What multi-party trust approaches have been proposed for healthcare data sharing and patient consent management?
2. How do existing approaches represent, verify, and enforce patient consent and data access permissions?
3. What mechanisms are used to support decentralised identity, verifiable credentials, and authentication in healthcare data ecosystems?
4. How do existing systems address privacy preservation, selective disclosure, interoperability, and auditability?
5. What limitations remain regarding the integration of consent management, identity verification, access control, and auditable healthcare data sharing?
6. How do existing systems manage the temporal validity and lifecycle of consent, including expiration, revocation, and state transitions, after consent has been granted?

7. How are the security properties of existing consent and access-control systems evaluated, and to what extent is formal security analysis employed alongside empirical prototyping?

These questions were formulated to ensure that the review remained directly aligned with the technical objectives of the proposed system. The review therefore focused on the relationship between the individual security and privacy mechanisms rather than treating multi-party trust, identity, consent, and access control as isolated technologies.

### **2.2.3 Search Databases and Search Strategy**

The literature search was conducted using the following academic databases: 1) IEEE Xplore, 2) ACM Digital Library, 3) ScienceDirect, 4) SpringerLink, 5) PubMed, 6) Scopus, and 7) Web of Science.

These databases were selected because they provide complementary coverage of computer science, cybersecurity, healthcare informatics, distributed systems, and information management research. IEEE Xplore and ACM Digital Library were used to identify studies on multi-party trust architectures, cryptographic mechanisms, decentralised identity, and access control. ScienceDirect and SpringerLink were used to identify research on healthcare information systems, privacy, interoperability, and data governance. PubMed was included to capture healthcare-oriented studies concerning patient consent, health information exchange, and clinical data sharing. Scopus and Web of Science were used to improve the coverage of multidisciplinary studies and to support the identification of relevant review articles.

The search was conducted using combinations of keywords related to the principal concepts of the review. The search strings were constructed using Boolean operators and were adapted to the syntax requirements of each database. The principal search concepts were multi-party trust, blockchain and distributed-ledger technology, healthcare data, patient consent, decentralised identity, access control, privacy, and auditability. The general search string was defined as shown in Figure 1.

The supporting-requirements block of the search string additionally captured trusted-execution terminology (trusted computing, trusted execution environment, attestation), which yielded the secure-execution studies reviewed in Section 2.3.6.

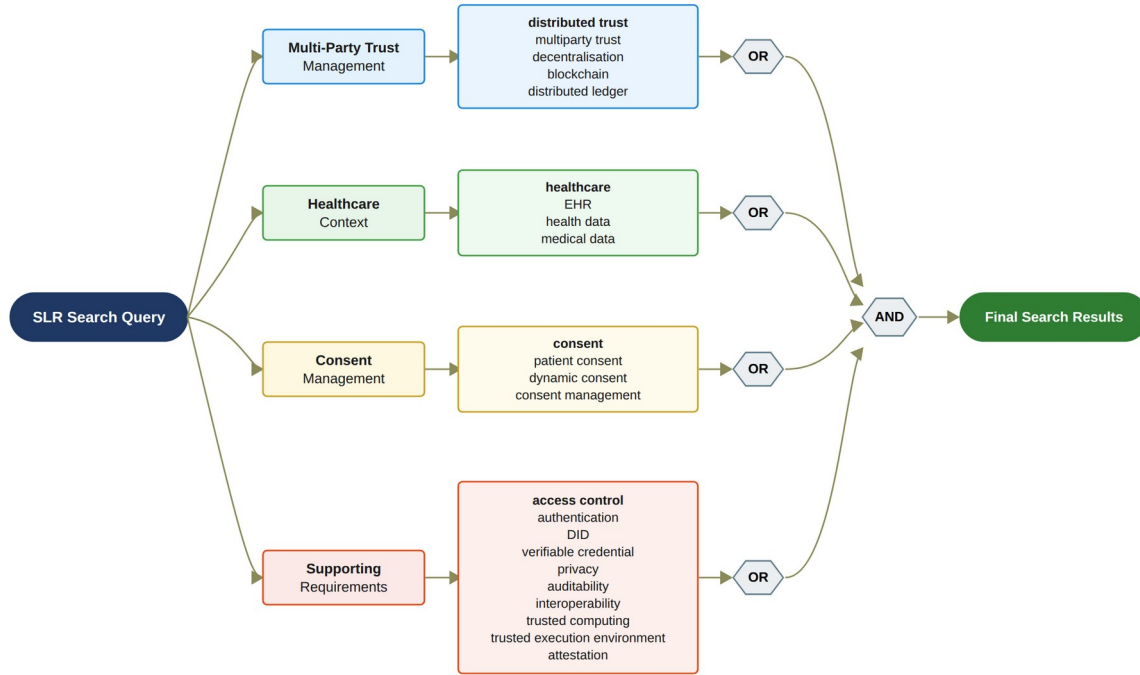


Figure 1: SLR Search String Definition

*[Figure 1: SLR Search String Definition (updated: blockchain and distributed-ledger terminology added to the Multi-Party Trust block, and trusted computing, trusted execution environment, and attestation added to the Supporting Requirements block, in line with Section 2.2.3)]*

## 2.2.4 Search Period and Search Execution

♦ [RED — يجب حله قبل التسليم] **R5: The search-execution claim (seven named databases, search performed in August 2026, window from January 2022) must correspond to a search you actually ran and can reproduce; keep the exported search logs ready for the examiner.**

The search was restricted to studies published between January 2022 and the search date, and was performed in August 2026. The search period was selected to capture the rapid development of multi-party trust healthcare data management, decentralised identity, and consent-aware access control while maintaining a sufficiently contemporary evidence base. Earlier foundational studies were retained when they provided critical contributions to the technical or conceptual development of the reviewed approaches.

The search results from all databases were exported into a reference management system. Duplicate records were identified using bibliographic metadata, including title, author, DOI, and publication year. Where duplicate records were identified, the most complete bibliographic record was retained for subsequent screening.

### **2.2.5 Eligibility Criteria**

The eligibility criteria were defined before the screening process to ensure consistency in the selection of studies. The criteria were designed to identify research that was directly relevant to the objectives of the SLR.

A study was included if it satisfied the following criteria:

1. The study was published as a peer-reviewed journal article, conference paper, or systematic review relevant to the research questions.
2. The study addressed healthcare data sharing, electronic health records, patient consent, healthcare access control, decentralised identity, privacy preservation, or a closely related topic.
3. The study proposed, implemented, evaluated, or critically reviewed a technical, architectural, conceptual, or governance-oriented approach relevant to the research questions.
4. The study provided sufficient methodological or conceptual information to support the extraction of relevant findings.
5. The full text was available for inspection.
6. The publication language was English.

Studies were excluded if they satisfied one or more of the following conditions:

1. The study was unrelated to healthcare data sharing, patient consent, identity management, access control, privacy, or auditability.
2. The study was a duplicate of another retrieved record.
3. The study was a short abstract, editorial, opinion article, thesis, book chapter, or non-peer-reviewed publication without sufficient methodological detail, unless it provided a necessary foundational contribution.
4. The study did not provide sufficient information to evaluate its contribution to the research questions.
5. The full text was unavailable.
6. The study focused exclusively on a technical problem that was outside the scope of healthcare data management and did not provide transferable insights relevant to the review.

The inclusion and exclusion criteria were applied consistently throughout the screening process. Where a study addressed multiple topics, its eligibility was determined according to the relevance of its contribution to the research questions rather than by the presence of a single keyword.

A small number of included studies address domains other than healthcare, such as cross-organisational livestock data sharing, archival record-keeping, smart agriculture, electric-vehicle charging, and smart-

city data governance [6, 8, 17, 27, 30]. These studies were retained under criterion 6 because they provide transferable insights on decentralised trust, verifiable credentials, and auditable data governance that bear directly on the review questions.

### 2.2.6 Screening and Study Selection

♦ [RED — يجب حله قبل التسليم] R3: The PRISMA chain (125 identified; 35 duplicates + 7 automated removals; 83 screened; 40 excluded; 43 sought; 3 not retrieved; 40 assessed; 7 excluded; 33 included) must match your reference-manager export exactly. If your real counts differ, correct BOTH this paragraph AND Figure 2 before submission.

The screening process consisted of three sequential stages: title and abstract screening, full-text eligibility assessment, and final inclusion.

During the first stage, the titles and abstracts of all retrieved records were examined to determine whether the studies were potentially relevant to the research questions. Records that were clearly unrelated to the review scope were excluded at this stage. During the second stage, the full texts of the remaining studies were assessed against the predefined inclusion and exclusion criteria. Particular attention was given to whether the studies addressed the relationship between consent, identity, authorisation, privacy, and healthcare data sharing.

During the final stage, the eligible studies were included in the qualitative synthesis. The reasons for exclusion at the full-text stage were recorded to improve the transparency of the review. The screening process was documented using the PRISMA flow diagram, which reports the number of records identified, duplicates removed, records screened, full texts assessed, studies excluded, and studies included in the final review.

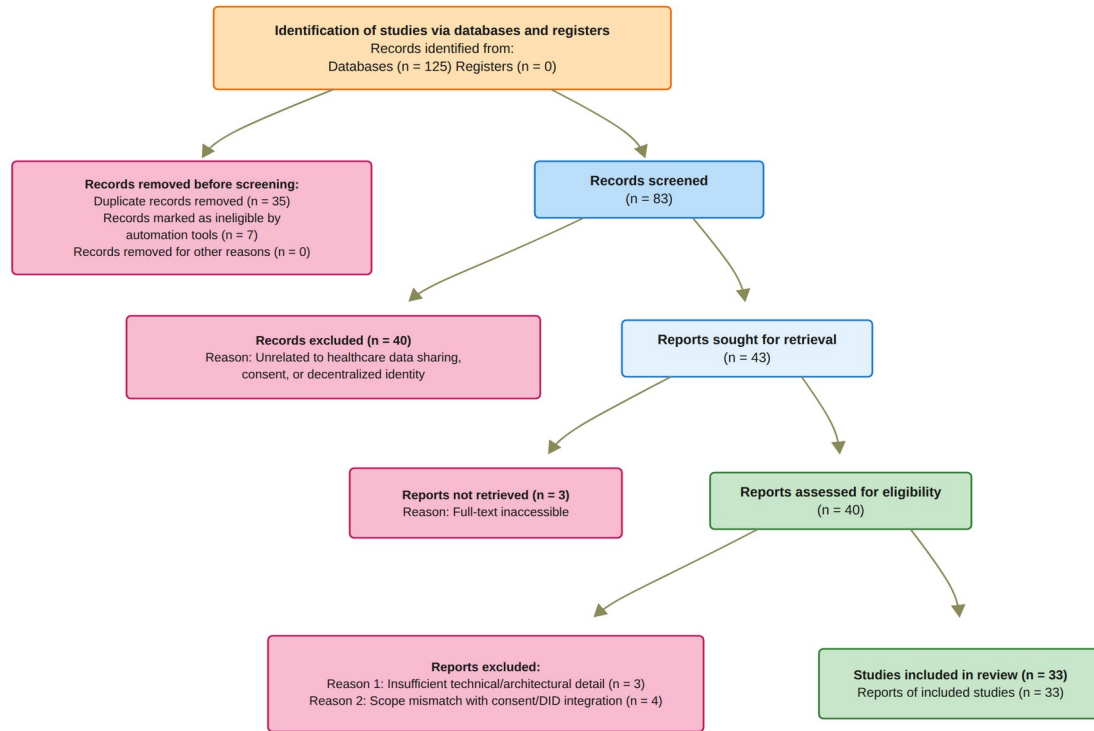


Figure 2: PRISMA Study Selection Summary

[Figure 2: PRISMA Study Selection Summary]

Figure 2 presents the PRISMA flow diagram for this review, which summarises the identification, screening, eligibility, and inclusion stages of the SLR. The final number of included studies was derived after completing the screening and eligibility assessment across the identified literature base.

Seven of the removed records were flagged as ineligible during automated pre-screening (non-English sources and non-peer-reviewed material) and were excluded before the manual title and abstract screening.

In numerical terms, the database searches returned 125 records. Before screening, 35 duplicate records and the seven records flagged during automated pre-screening were removed, leaving 83 records for title and abstract screening. Of these, 40 records were excluded as unrelated to the review scope and 43 reports were sought for retrieval; three full texts were inaccessible, so 40 reports were assessed for eligibility. Seven reports were excluded at this stage, three for insufficient technical or architectural detail and four for scope mismatch with the consent and decentralised-identity focus of the review, and 33 studies were included in the final qualitative synthesis, exactly as reported in Figure 2.

## 2.2.7 Data Extraction and Synthesis

♦ [RED — يجب حله قبل التسليم] R4: This paragraph now states that a four-criteria quality assessment was applied at the full-text stage. Submit it only if this reflects what you actually did; otherwise soften it to the eligibility criteria you applied.

The included studies were systematically analysed using a predefined data extraction framework. The extracted information included publication year, research objective, healthcare application domain, multi-party trust architecture, consent model, identity mechanism, access control mechanism, privacy-preserving technique, interoperability approach, evaluation method, and reported limitations.

The extracted data were organised into thematic categories corresponding to the research questions. These categories included consent specification and management, decentralised identity and credential verification, authorisation and access control, privacy preservation, interoperability, auditability, and system evaluation.

A qualitative synthesis was conducted to compare the approaches reported in the literature. The synthesis focused on identifying common architectural patterns, distinguishing technical and conceptual contributions, and examining the extent to which existing systems integrate consent management with identity verification and access control. Particular attention was given to whether the reviewed systems provided explicit enforcement of consent scope, verifiable authorisation, auditable access records, and mechanisms for preserving patient autonomy.

Each study assessed at the full-text stage was additionally evaluated against four predefined quality criteria: clarity of the research objective, adequacy of the methodological description, rigour of the reported evaluation or validation, and relevance of the evidence to the review questions. Studies that failed more than one criterion were excluded during the full-text assessment, so the quality assessment operated as part of the eligibility decision rather than as a separate scoring exercise.

The final review set was used to establish the state of the art in multi-party-trust healthcare data sharing and consent management. The findings were subsequently used to identify research gaps and to inform the design requirements of the proposed framework.

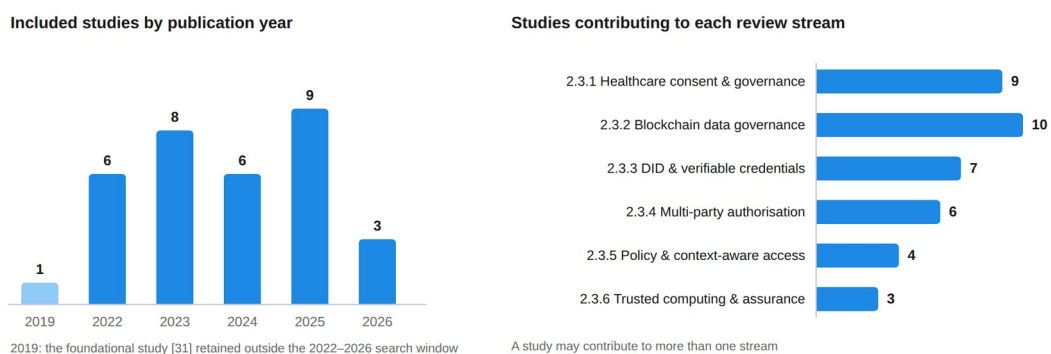


Figure 3: Profile of the 33 included studies: distribution by publication year and by review stream. The single 2019 study is the foundational source [31] retained outside the systematic search window; a study may contribute to more than one stream.

## 2.3 Review

The thematic sections that follow (Sections 2.3.1–2.3.6), together with the comparative analysis in Section 2.3.7, address the review questions as follows. Review question 1 is addressed principally in Sections 2.3.2 and 2.3.4; review question 2 in Sections 2.3.1 and 2.3.5; review question 3 in Section 2.3.3; review question 4 in Sections 2.3.2 and 2.3.5, with its selective-disclosure dimension addressed in Section 2.3.3; and review question 5 is synthesised in Sections 2.3.7 and 2.4, where it motivates the research gap. The lifecycle and evaluation questions 6 and 7 are addressed in Sections 2.3.1 and 2.3.6 respectively.

Consistent with the scope established in Section 2.1, the following subsections examine each research stream in turn: healthcare consent governance, blockchain-based data governance, decentralised identity and verifiable credentials, multi-party authorisation, policy-based and context-aware access control, and Trusted Computing. Each subsection evaluates how the reviewed approaches contribute to the conditions required for a trustworthy authorisation decision and identifies the limitations that motivate the proposed framework.

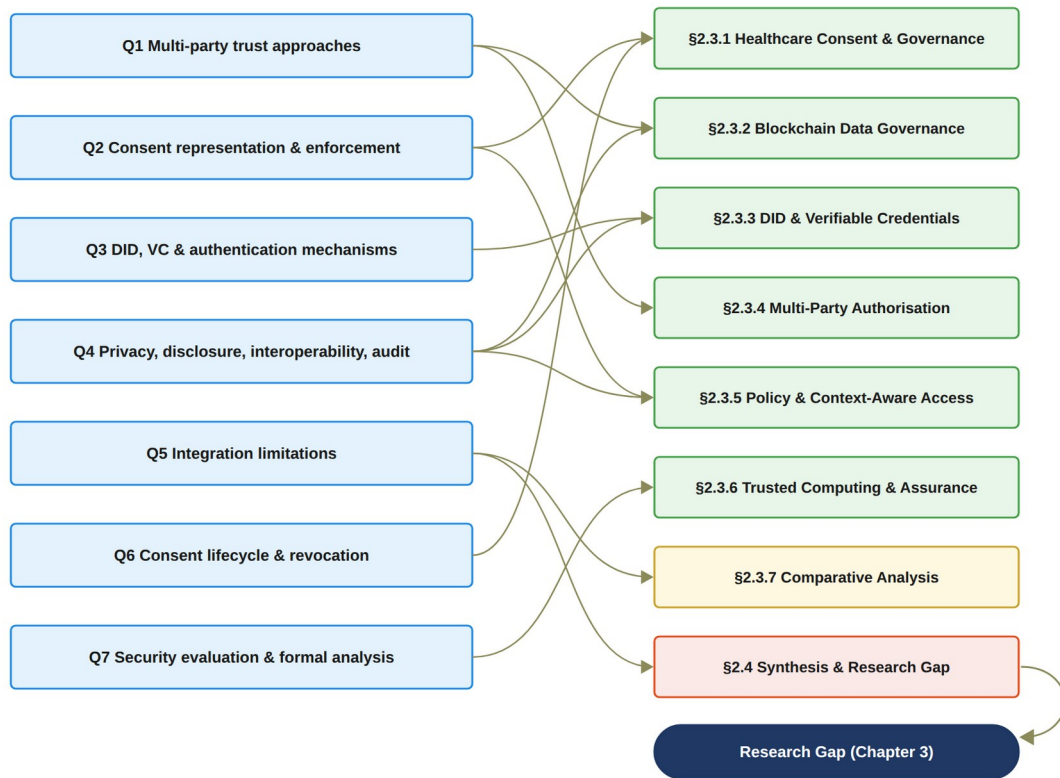


Figure 4: Correspondence between the seven review questions of Section 2.2.2 and the sections of the review in which they are addressed, ending in the research gap carried into Chapter 3.

### **2.3.1 Healthcare Consent and Decentralised Data Governance**

Healthcare data sharing is fundamentally different from conventional information exchange because the data involved are highly sensitive and because decisions regarding its use may affect patient privacy, autonomy, clinical care, research participation, and institutional accountability. Existing studies have therefore emphasised the importance of informed consent, patient control, privacy preservation, and transparent governance in healthcare information systems [31, 22, 14, 12].

The literature increasingly recognises that patients should not be regarded merely as passive data providers. Research on patient autonomy and data ownership has highlighted the importance of giving individuals greater control over how their health information is accessed, shared, and reused [24]. At the same time, privacy-preserving interoperability remains difficult because healthcare systems must balance individual autonomy with the operational requirements of clinical care, coordination, and legitimate secondary data use [21, 9]. These competing requirements make healthcare consent a governance problem rather than simply a binary access-control decision.

Traditional consent-management approaches frequently represent consent as a permission indicating whether a particular party is allowed to perform a specified operation [13, 10]. Dynamic consent research has attempted to provide greater flexibility by allowing consent preferences to evolve over time, while privacy-first approaches have explored decentralised controllers and privacy-preserving mechanisms for improving data-subject control [13]. Consent receipts and auditable consent records have also been proposed to improve transparency and accountability by providing evidence of how consent was obtained and exercised [10].

Despite these developments, a significant conceptual limitation remains. The existence of a consent record does not necessarily explain whether the conditions required for a subsequent access request are still satisfied. A consent may identify a data subject and a recipient, but trustworthy authorisation requires additional reasoning concerning the legitimacy of the participants, their authority to act, whether other independent parties must participate in the decision, and whether the requested operation remains within the purpose and data scope originally authorised.

Consequently, the literature establishes the importance of patient autonomy and consent governance, but it provides comparatively limited integration between consent representation and a comprehensive trust-oriented authorisation process. This distinction becomes particularly important in decentralised environments where the entities involved in healthcare data sharing may not belong to the same administrative or trust domain.

Within this stream, dynamic-consent research [13] and consent-receipt mechanisms [10] already recognise that a patient's permission changes over time; however, the reviewed systems provide limited support for treating expiration, revocation, and consent state transitions as first-class and independently verifiable authorisation conditions after consent has been granted. This limitation motivates the lifecycle dimension examined by review question 6.

### **2.3.2 Blockchain-Based Consent and Data Governance**

Blockchain technologies have been extensively investigated as mechanisms for improving integrity, transparency, traceability, and accountability in distributed data-sharing environments. In healthcare, blockchain-based architectures have been proposed for electronic health records, access control, auditability, interoperability, and consent management [1, 2, 7, 3]. More generally, blockchain has been studied as an infrastructure for trustworthy data sharing and decentralised decision-making across organisational boundaries [29, 30, 26].

A major contribution of blockchain is its ability to preserve tamper-resistant evidence of transactions and state changes. This characteristic is particularly valuable for sensitive documentation and data governance because it can strengthen auditability and provide evidence that recorded information has not been modified without detection [8]. Analytical research has also investigated how blockchain immutability contributes to tamper-resilient trust and integrity within distributed systems [18].

Blockchain-based healthcare systems therefore provide an important foundation for recording consent events, access decisions, and governance actions. Surveys of healthcare blockchain systems demonstrate the potential of distributed ledgers to improve transparency and decentralised accountability, while also identifying continuing challenges associated with privacy, scalability, interoperability, and access control [2, 7, 3, 28].

However, blockchain immutability should not be confused with trustworthy authorisation. A blockchain can provide strong evidence that a transaction has been recorded, but it does not independently determine whether the entity initiating the transaction possesses legitimate authority. Similarly, the integrity of a consent record does not guarantee that all required participants approved the decision or that a subsequent access request complies with the conditions associated with the consent.

This distinction is particularly important when participants have incomplete information about each other, operate across organisational boundaries, or possess asymmetric authority. Under such conditions, the problem is not simply how to record a decision, but how to determine whether the decision was generated under sufficient and verifiable trust conditions.

Accordingly, blockchain is best understood as an enabling infrastructure for evidence preservation, auditability, and decentralised coordination rather than as the sole source of trust. The proposed research therefore does not treat blockchain storage as the primary research contribution. Instead, blockchain-compatible mechanisms are considered as part of a broader architecture in which the validity of an authorisation decision depends on the coordinated evaluation of identity, authority, multi-party approval, and policy constraints.

### **2.3.3 Decentralised Identity and Verifiable Credentials**

Decentralised Identifiers (DIDs) and Verifiable Credentials (VCs) provide an alternative to conventional identity architectures based exclusively on centralised identity providers. DID-based systems enable entities to establish persistent and cryptographically verifiable identifiers, while VCs provide verifiable claims concerning roles, attributes, qualifications, or other properties associated with an entity [20, 33, 4, 16].

Recent research has extended decentralised identity beyond static identity representation. Dynamic DID mechanisms have investigated proactive approaches for identity management, while decentralised identity systems with multi-party verification have demonstrated the potential to strengthen the process through which identity claims are established or validated [33, 4]. Other studies have examined privacy-preserving authentication and selective disclosure, allowing participants to prove selected attributes without unnecessarily revealing additional information [27, 5].

These mechanisms are particularly relevant to healthcare and other sensitive data-sharing environments because they can reduce dependence on a single identity provider and provide stronger control over the disclosure of participant attributes. However, the literature also reveals an important conceptual distinction between identity and authority.

A valid decentralised identifier establishes that a participant can be cryptographically identified. A valid verifiable credential may establish that the participant possesses a particular role, qualification, or attribute. Nevertheless, neither identity verification nor credential possession automatically establishes that the participant should be granted access to a particular patient's information. An entity may be a legitimate healthcare professional, for example, while still lacking authority to access a specific data category for a particular purpose.

The proposed research therefore extends the role of DID and VC technologies from identity representation and credential verification towards their use as trusted inputs to a broader authorisation process. Under this approach,

*Identity ≠ Authorisation.*

(1)

Identity verification establishes who is participating in the decision, while authority verification determines whether that entity satisfies the requirements associated with a particular consent or access operation. The resulting distinction is important because it prevents successful authentication from being interpreted as automatic permission.

The literature provides increasingly sophisticated mechanisms for decentralised identity and credential validation. However, there remains a need to integrate these mechanisms with collective authorisation and policy evaluation so that verified identities and credentials contribute to, rather than replace, a comprehensive trust decision.

Recent reviews of blockchain-based identity management further consolidate this stream, surveying identity management, access control and trust mechanisms for connected environments and confirming the maturity of DID- and VC-based designs [15].

#### **2.3.4 Multi-Party Authorisation and Collaborative Consent**

A further limitation of conventional access-control models is their frequent reliance on a single authority responsible for granting or denying access. This assumption may be inappropriate in decentralised healthcare scenarios involving patients, guardians, healthcare professionals, institutional authorities, and other stakeholders with different responsibilities and authority levels [21, 9, 31].

More generally, multi-party data-sharing environments require mechanisms capable of supporting collaborative governance. Research on decentralised data trusts has explored platforms through which multiple parties can participate in data-sharing arrangements and governance processes [19]. Decentralised decision-making has also been investigated in combination with blockchain and large-scale data systems [29]. FutureDID further demonstrates that multi-party verification can be incorporated into decentralised identity processes [4].

Nevertheless, multi-party verification of identity should not be considered equivalent to multi-party authorisation of data access. The first concerns whether an identity claim can be trusted, whereas the second concerns whether a group of independent participants has collectively established a valid permission decision.

Existing literature provides useful foundations for collaborative governance and multi-party verification. However, comparatively less attention has been given to modelling multi-party approval as an explicit and independently verifiable security condition within a patient consent object. This represents an important area addressed by the proposed framework.

Beyond healthcare, decentralised trust mechanisms have also been applied to empower independent stakeholders in cross-organisational data

sharing, demonstrating that multi-party governance generalises across application domains [6].

Where the reviewed systems support multiple approvers, approval is typically implemented as a workflow or signature-collection step [19, 29] rather than represented as a verifiable threshold condition bound to the consent object itself. It is this representational absence, rather than the absence of multi-party mechanisms as such, that the proposed framework addresses.

### 2.3.5 Policy-Based and Context-Aware Access Control

Healthcare access-control research has developed a broad range of mechanisms for restricting access according to roles, attributes, risk conditions, contextual information, and usage constraints. Attribute-based encryption and decentralised key-management approaches, for example, provide mechanisms for protecting healthcare data through fine-grained cryptographic access policies [32]. Risk-aware and usage-control models have further investigated how access decisions can incorporate dynamic conditions and constraints beyond traditional role-based permissions [11].

Recent surveys demonstrate the continuing development of blockchain-based healthcare access control and healthcare IoT security, highlighting the importance of privacy preservation, interoperability, scalability, and dynamic access management [28, 25]. These approaches provide important mechanisms for determining whether an operation should be permitted under a particular set of access-control rules.

However, access control becomes more complex when policies must be connected directly to a decentralised consent process. A requester may possess a valid identity, valid credentials, and even the required multi-party approval while still requesting information outside the scope authorised by the patient. Therefore, the validity of the requester and the validity of the requested operation must be evaluated separately.

The proposed framework consequently treats policy compliance as an explicit authorisation condition. Let  $C$  represent the consent object and  $R$  represent a requested operation. Policy validity can be represented conceptually as

$$V_P(C, R) = \text{Policy}(C, R). \quad (2)$$

For example, if a consent authorises access to observations and medications,

$$S_C = \{\text{Observation}, \text{Medication}\}, \quad (3)$$

then a request for observations, medications, and procedures,

$$S_R = \{\text{Observation}, \text{Medication}, \text{Procedure}\}, \quad (4)$$

should be rejected because

$$S_R \not\subseteq S_C. \quad (5)$$

This illustrates a central argument of the proposed research: identity trust and approval trust are insufficient without contextual policy trust. The access decision must also be evaluated against the purpose and data-scope constraints explicitly associated with the consent.

Across the reviewed access-control approaches [32, 11, 28, 25], policy evaluation is bound primarily to the requester's roles, attributes, or risk context rather than to the purpose and data scope authorised by the patient's consent. It is this missing relationship between the evaluated policy and the consent object itself that the proposed framework formalises.

### **2.3.6 Trusted Computing, Secure Execution, and Security Assurance**

Trusted Computing provides an additional perspective on the protection and verification of security-critical processes. Trusted Execution Environments (TEEs), for example, provide hardware-supported isolation that can protect sensitive computation from compromised or untrusted operating environments [23]. Remote attestation mechanisms can further provide evidence concerning the integrity of the execution environment in which a security-sensitive process is performed [23].

Recent research has explored the integration of trusted execution and distributed trust mechanisms in different application domains. Trust-aware sensing and consensus mechanisms have demonstrated how TEE-supported sensing can contribute to resilient decision-making in conjunction with blockchain coordination [17]. These studies illustrate the potential of Trusted Computing to provide an additional assurance layer beyond conventional software-based access-control mechanisms.

Nevertheless, Trusted Computing does not by itself determine the correctness of an authorisation policy. A TEE can protect the execution of an authorisation decision, but the resulting decision remains dependent on the correctness of the identities, authority relationships, approval conditions, and policies supplied to that computation. Consequently, secure execution and trustworthy authorisation address complementary rather than identical problems.

The reviewed literature therefore suggests an important opportunity for integration. A trust-oriented authorisation framework can define the conditions under which access should be permitted, while Trusted Computing mechanisms can provide stronger assurance that the relevant security-sensitive evaluation is performed within an integrity-protected environment.

This research establishes the conceptual foundation for such integration and, moreover, demonstrates it through an implemented and empirically evaluated prototype. Future work can therefore investigate how trusted

execution and remote attestation can strengthen the enforcement and verification of decentralised consent decisions.

Beyond execution security, formal security reasoning is also necessary to distinguish prototype functionality from security assurance. A system may successfully execute valid authorisation scenarios without demonstrating that invalid identities, insufficient approvals, or policy violations cannot produce an unintended access decision.

The present prototype addresses this concern empirically through adversarial and negative testing across each verification dimension. Nevertheless, formal analysis remains necessary in order to demonstrate that these properties hold under defined assumptions.

Complementary work in this stream applies entropy-based measurement to quantify blockchain immutability and tamper-resilient trust, providing an analytical basis for treating the ledger itself as part of the trusted computing base [18].

Formal security analysis nevertheless remains rare across the reviewed corpus: security arguments are predominantly architectural or empirical, and only a minority of studies accompany their designs with formal reasoning about the stated security properties [17, 18]. This observation grounds review question 7 and motivates the formal-assurance direction of the research. While Trusted Computing mechanisms could further harden the execution of the proposed authorisation evaluation, hardware-supported execution is treated as an orthogonal assurance layer and lies outside the scope of the present research questions.

### **2.3.7 Comparative Analysis of Existing Approaches**

The reviewed literature demonstrates that existing approaches provide strong solutions for individual dimensions of trustworthy data sharing. Blockchain-based systems provide tamper-resistant recording and auditability [2, 7, 28]; DID and VC mechanisms provide decentralised identity and verifiable attributes [20, 4, 5]; policy-based and cryptographic access-control mechanisms provide fine-grained data protection [32, 11, 25]; collaborative governance mechanisms support distributed participation [19, 29, 6]; and Trusted Computing provides secure execution and attestation capabilities [23, 17].

However, these contributions address different layers of the security problem. No individual mechanism can independently establish that a healthcare data-access decision is trustworthy. A blockchain record does not establish participant authority, a valid DID does not establish access permission, multi-party participation does not guarantee policy compliance, and secure execution does not guarantee that the underlying authorisation policy is correct.

Table 2 summarises the principal focus and limitations of the major research streams and positions the proposed framework relative to the existing literature.

**Table 2:** Comparison of Existing Research Approaches and the Proposed Framework

| Research Stream                                   | Primary Contribution                                                                               | Main Limitation for Authorisation                                                                                                    | Representative References    |
|---------------------------------------------------|----------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|------------------------------|
| Healthcare consent and privacy governance         | Patient autonomy, informed consent, and controlled data sharing                                    | Consent is treated as permission rather than an evaluable authorisation object                                                       | [31, 22, 14, 24, 12, 13, 10] |
| Blockchain-based data governance                  | Tamper-resistant records, distributed auditability, and transparency                               | Immutable records do not establish participant legitimacy, authority, or policy compliance                                           | [1, 2, 7, 3, 30, 26, 8, 29]  |
| Decentralised identity and verifiable credentials | Self-controlled identity, verifiable attributes, and authentication                                | Identity and credential validity do not independently determine if access is authorised                                              | [20, 33, 4, 16, 27, 5]       |
| Multi-party and decentralised governance          | Collaborative participation and distributed verification or governance                             | Limited integration between collective approval thresholds, consent, and access decisions                                            | [19, 4, 21, 9]               |
| Policy-based and healthcare access control        | Fine-grained restriction based on attributes, risk, context, and constraints                       | Policy enforcement is separated from decentralised identity and multi-party consent                                                  | [32, 11, 28, 25]             |
| Trusted Computing and secure execution            | Hardware-supported isolation, execution integrity, and attestation                                 | Secure execution does not determine whether underlying authorisation conditions are sufficient                                       | [23, 17, 18]                 |
| Proposed Framework                                | Integrated evaluation of consent, identity, authority, multi-party approval, and policy compliance | Lifecycle trust and empirical validation realised in the implemented prototype; formal security assurance requires further extension | This research                |

The comparison indicates that the principal contribution of the proposed research is not the replacement of existing technologies. Rather, it lies in establishing an explicit conceptual relationship among them. Blockchain, DID, VCs, policy mechanisms, and potentially trusted execution are treated as complementary components that address different trust conditions within a common authorisation process.

## 2.4 Synthesis and Research Gap

The literature review identifies a consistent pattern of fragmentation across existing research. Blockchain-based approaches primarily address the integrity and traceability of recorded events [2, 7, 28]. Decentralised identity and verifiable credential systems address the identification and attribute verification of participating entities [20, 33, 4]. Multi-party governance mechanisms address distributed participation and collective decision-making [19, 29]. Policy-based access-control approaches determine whether requested operations comply with predefined constraints [32, 11, 25]. Trusted Computing technologies protect the execution of security-sensitive computation [23, 17].

These mechanisms provide important but incomplete answers when considered independently. The existence of a valid blockchain record does not guarantee that the authorisation decision was generated by legitimate and appropriately authorised participants. A verified identity does not imply permission to access a specific patient's information. A valid credential does not necessarily satisfy a multi-party approval requirement. Similarly, sufficient approvals do not guarantee that a subsequent request remains within the authorised purpose or healthcare data scope.

The central research gap therefore concerns the absence of a sufficiently integrated trust-oriented authorisation framework that explicitly models the relationship between these independently verifiable conditions. In particular, existing approaches provide limited treatment of patient consent as a security-bearing and policy-aware authorisation object whose validity depends on coordinated conditions concerning participant identity, authority, collective approval, and contextual policy compliance.

The reviewed literature also identifies persistent challenges of privacy preservation, scalability, and interoperability in blockchain-based healthcare systems [2, 7, 3, 28]; while these concerns inform the design constraints of the proposed framework, they are treated as engineering constraints rather than as the conceptual gap pursued by this research.

In the same way, the consent-lifecycle limitation identified in Section 2.3.1 and the scarcity of formal security analysis identified in Section 2.3.6 define the temporal-lifecycle and formal-assurance dimensions that the next stage of this research addresses.

The proposed research addresses this gap by developing a trusted multi-party consent governance framework in which consent is represented as an evaluable authorisation object rather than simply as a database entry, consent receipt, or blockchain transaction. Decentralised identifiers and verifiable credentials are used to establish trusted identity and authority inputs. Multi-party authorisation mechanisms determine whether the required independent participants have collectively satisfied the authorisation condition. Policy-aware access control evaluates whether a

requested operation remains within the authorised purpose and data scope.

The foundational authorisation decision investigated in the current stage of the research can therefore be represented as

where  $V_I(u)$  represents the validity of the identity and relevant authority evidence associated with participant  $u$ ,  $V_A(C)$  represents the satisfaction of the required multi-party authorisation condition for consent  $C$ , and  $V_P(C, R)$  represents compliance between the consent and the requested operation  $R$ .

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L$$

This is the rule enforced by the implemented Consent Engine: every access request is evaluated over the complete tuple, where  $V_T(C, t)$  additionally represents the temporal validity of the request instant and  $V_L(C)$  the jurisdictional constraint; the temporal and jurisdictional predicates are already operational rather than deferred to subsequent research.

This formulation represents the principal conceptual contribution of the current research stage. It shifts the focus from determining whether consent has merely been recorded towards determining whether a data-access decision has been generated under sufficient and independently verifiable trust conditions.

The current research therefore concentrates on establishing the foundational relationship between trust-centric consent modelling, decentralised identity and authority verification, multi-party authorisation, and policy-aware access control.

Accordingly, the literature suggests that the principal research opportunity is not the development of another isolated blockchain consent mechanism or identity-management system. Instead, the opportunity lies in constructing a coherent trust-oriented authorisation model in which the different security mechanisms contribute to a common and explainable authorisation decision. Trustworthy healthcare data sharing can then be evaluated not simply according to whether a consent record exists, but according to whether the combined identity, authority, collective authorisation, and policy conditions required for access have been satisfied.

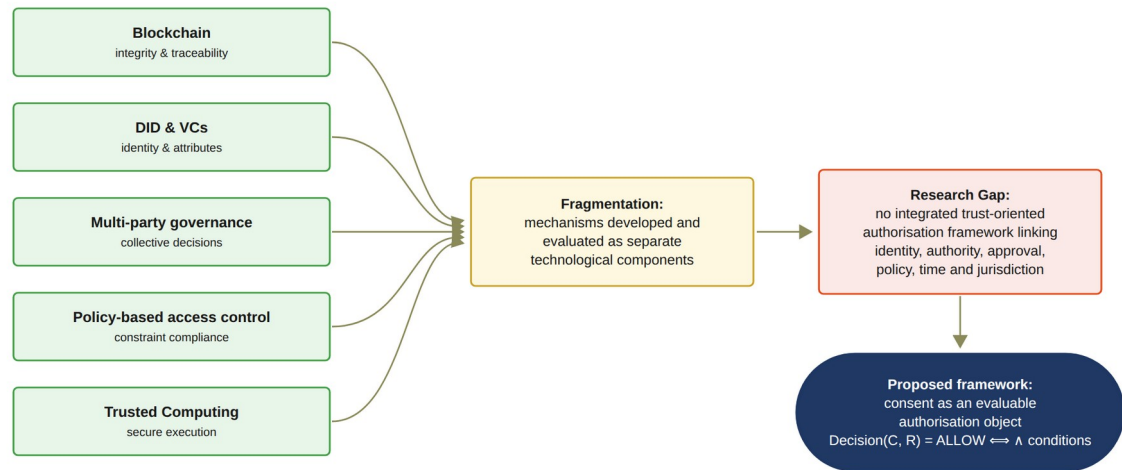


Figure 5: Synthesis of the review: the five research streams provide strong but fragmented mechanisms; their lack of integration constitutes the research gap, which the proposed framework addresses by treating consent as an evaluable authorisation object.

## 3 Research Gaps and Questions

### 3.1 Research Gap

The systematic literature review indicates that substantial research has been conducted on individual mechanisms for securing healthcare data sharing, including blockchain-based consent management, decentralised identity, verifiable credentials, cryptographic access control, policy-based authorisation, and multi-party approval. These approaches have demonstrated the value of decentralisation, tamper-resistant records, verifiable identity, fine-grained access control, and distributed decision-making in addressing different aspects of healthcare data security. However, the literature also reveals a significant conceptual and architectural fragmentation among these mechanisms. They are commonly investigated as independent technical solutions rather than as coordinated components of a unified trust-oriented authorisation model.

The central gap is therefore not the absence of technologies for recording consent, verifying identity, or restricting data access. Rather, it is the absence of a sufficiently integrated model explaining how these mechanisms collectively establish a trustworthy authorisation decision. In particular, existing consent-oriented approaches tend to treat consent primarily as a record of a patient's permission. Once the permission has been created and stored, subsequent access control may depend predominantly on the existence of the consent record and the successful authentication of the requester. Such a model establishes evidence that a consent decision occurred, but it does not necessarily establish that the requester possesses the required authority, that all required parties have independently approved the access, or that the requested operation is consistent with the purpose and data scope originally authorised by the patient.

This distinction is important because recording consent and enforcing trustworthy authorisation represent fundamentally different security problems. A blockchain may provide an immutable representation of a consent event, but immutability does not establish the legitimacy of the entities involved in that event. Similarly, a valid decentralised identity can establish who a participant is, but it does not necessarily establish what that participant is authorised to do. Multi-party approval can strengthen collective decision-making, but approval alone does not guarantee that the resulting access request conforms to the patient's authorised purpose or data scope. Consequently, trust cannot be attributed to any individual mechanism in isolation.

From a Trust Computing perspective, this leads to a more fundamental research problem. Trustworthy access should be understood as an outcome of the coordinated satisfaction of multiple independently verifiable conditions. The relevant conditions include the legitimacy of the participating identities, the authority associated with those identities, the

satisfaction of required collective approval conditions, and compliance between the requested operation and the policy defined by the consent. The research therefore conceptualises trust not as a static attribute possessed by a particular entity or technology, but as an emergent property of a verifiable authorisation process.

This perspective also introduces an important distinction between authentication, authorisation, and trustworthy access. Authentication determines whether an entity can be identified and verified. Authorisation determines whether the entity is permitted to perform a particular operation. Trustworthy access requires an additional consideration: whether the authorisation decision itself has been established through sufficient, verifiable, and policy-compliant conditions. The research consequently investigates how these layers can be connected within a single framework without reducing trust to any individual credential, transaction, or access-control rule.

The identified gap can therefore be stated as follows: existing healthcare consent and access-control research provides many of the necessary technological building blocks, but there remains a need for an integrated trust-oriented authorisation framework that treats patient consent as a security-bearing and evaluable authorisation object. Such a framework should be capable of representing the relevant trust conditions, verifying the participating entities and their authority, establishing collective authorisation where required, and enforcing the policy and data-scope constraints associated with the consent.

The research addresses this gap by developing a trust-oriented authorisation model in which consent is not simply evidence that permission was granted, but the basis for evaluating whether a particular access request should be trusted. The resulting research direction places Trust Computing at the centre of the investigation, while treating blockchain, decentralised identity, verifiable credentials, and policy mechanisms as enabling technologies supporting the broader trust model.

## **3.2 Main Research Question**

Temporal and lifecycle trust has been operationalised in the current prototype, and empirical validation has been partially completed through automated and live negative testing. Consequently, formal security assurance forms the subsequent research scope and will be developed further in CA3.

Based on the identified research gap, the overarching research question is formulated as follows:

*How can a trust-oriented computing framework establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints?*

The formulation of this question deliberately emphasises trust-oriented computing rather than any individual implementation technology. The terms establish and enforce represent two complementary aspects of the research problem. Establishment concerns how trustworthy participants, authority relationships, and collective consent decisions are created. Enforcement concerns how these established conditions are evaluated when a healthcare data-access request is made.

The main research question therefore encompasses both the conceptual and technical dimensions of the research. At the conceptual level, it investigates how trust should be represented and reasoned about within a multi-party consent environment. At the technical level, it investigates how these trust conditions can be operationalised through decentralised identities, verifiable credentials, multi-party authorisation, and policy-aware access control. The question consequently provides the basis for both the proposed framework and its subsequent implementation and evaluation.

For the current stage, the investigation is deliberately focused on the foundational conditions required to establish trustworthy authorisation. These conditions are represented through the first four of the six interconnected sub-research questions presented in Section 3.3, concerning consent modelling, identity and authority trust, multi-party authorisation, and policy-aware access control. The remaining two sub-questions, addressing temporal and lifecycle trust and formal security assurance, complete the six-question structure; the fifth is operationalised in the current prototype, and the formal component of the sixth is carried into the next stage of the research.

### **3.3 Sub-Research Questions**

The research objectives are operationalised through six corresponding sub-research questions. Each sub-research question addresses a distinct dimension of the proposed trust-oriented healthcare authorisation framework, while the six questions collectively establish a progression from consent modelling and participant trust to collective authorisation, policy enforcement, temporal and lifecycle control, and finally formal security assurance and empirical validation.

#### **3.3.1 SRQ1: Trust-Centric Consent Modelling**

The first sub-research question is:

*How can patient consent be modelled as a trust-aware authorisation object that explicitly represents identity, authority requirements, policy constraints, and authorisation evidence?*

The purpose of this question is to establish the conceptual foundation of the framework. Rather than representing consent as a simple association

between a patient, a requester, and a permission, the proposed model represents consent as a structured and evaluable authorisation object such that

$$C = (I, A, P, T, L, E) \quad (7)$$

where I represents the participating identities, A represents the authority and multi-party authorisation evidence, P represents the purpose and data-scope constraints, T represents the temporal validity window, L represents the jurisdictional constraint, and E represents the authorisation evidence, including the record of whether the consent remains active or has been revoked.

This formulation changes the role of consent from a passive record into an evaluable authorisation object. Its security significance is determined not merely by the existence of a consent record, but by whether the associated trust, authority, policy, and evidence conditions remain valid when an access request is evaluated.

SRQ1 therefore establishes the conceptual representation required by the subsequent identity, multi-party authorisation, policy, and security-assurance mechanisms.

### 3.3.2 SRQ2: Decentralised Identity and Authority Trust

The second sub-research question is:

*How can decentralised identities and verifiable credentials establish trustworthy participants while explicitly separating identity authentication from authorisation authority?*

A fundamental principle of the proposed framework is that identity and authorisation should not be treated as equivalent. A valid decentralised identifier establishes the identity of a participant, while a verifiable credential provides evidence concerning the participant's role or authority. Therefore, Identity  $\neq$  Authorisation. The identity and authority validity condition is represented as

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u). \quad (8)$$

This separation prevents successful authentication from being interpreted as automatic authorisation. For example, authenticating a healthcare professional identified by a DID does not by itself establish that the professional is authorised to access a particular patient's data. Identity and authority verification instead provide trusted inputs to the subsequent authorisation evaluation process.

SRQ2 therefore addresses how trustworthy participants can be established before their participation in collective authorisation decisions.

### 3.3.3 SRQ3: Trustworthy Multi-Party Authorisation

The third sub-research question is:

*How can multiple independently verified participants jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access?*

This question addresses the collaborative authorisation problem. Let  $A_v$  denote the set of independently verified authorisation participants and let  $N$  denote the required authorisation threshold. Multi-party authorisation is defined as

$$V_A(C) = \{ 1, |A_v| \geq N; 0, |A_v| < N. \} \quad (9)$$

Consequently,

$$|A_v| < N \Rightarrow \text{Decision}(C, R) = \text{DENY}. \quad (10)$$

Consequently, in the implemented framework  $N$  is instantiated as  $|G|$ , the number of designated guardians, so that activation requires the approval of every listed guardian; configurable k-of-n thresholds are identified as future work.

This formulation allows the framework to distinguish explicitly between sufficient and insufficient collective participation. It also reduces reliance on a single authorising participant where a predefined threshold of independent approvals is required.

More fundamentally, SRQ3 changes the interpretation of trust from an assumption concerning a single trusted entity to a property established through the joint satisfaction of independently verified authorisation requirements.

### 3.3.4 SRQ4: Policy- and Context-Aware Access Control

The fourth sub-research question is

*How can policy, purpose, and data-scope constraints be incorporated into authorisation decisions so that valid identities and sufficient approvals cannot be used to obtain unauthorised healthcare data?*

Multi-party approval alone does not guarantee that a data-access request is legitimate. A requester may possess a valid identity and the required approvals while requesting information beyond the authorised scope. The framework therefore introduces an explicit policy predicate

$$V_P(C, R) = \text{Policy}(C, R), \quad (11)$$

which evaluates whether the requested operation satisfies the purpose and data-scope constraints defined by the consent object.

For example, if a consent authorises access to

$$S_C = \text{Observation, Medication}, \quad (12)$$

while the request contains

$$S_R = \text{Observation, Medication, Procedure,} \quad (13)$$

the request must be rejected when

$$S_R \not\subseteq S_C. \quad (14)$$

Similarly, a request may be rejected when its declared purpose is inconsistent with the purpose specified in the consent.

Thus, trustworthy authorisation requires not only trusted participants and sufficient approvals, but also compliance between the requested operation and the authorisation policy.

SRQ4 therefore completes the foundational access-control mechanisms by connecting participant trust and collective authorisation with the actual operation being requested.

### 3.3.5 SRQ5: Temporal and Lifecycle Trust

The fifth sub-research question is

*How can temporal validity and consent lifecycle controls ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and is rejected after expiration, revocation, or an unauthorised state transition?*

Trustworthy authorisation is inherently dynamic. A consent that is valid at one point in time cannot necessarily be assumed to remain valid indefinitely. Let the validity interval of a consent object be  $[t_s, t_e]$ . Temporal validity is defined as

$$V_T(C, t) = (t_s \leq t \leq t_e). \quad (15)$$

Consequently,

$$t < t_s \vee t > t_e \Rightarrow \text{Decision}(C, R) = \text{DENY}. \quad (16)$$

Temporal validity must also be evaluated together with the lifecycle state of the consent. The lifecycle can be represented as

$$\text{Specification} \rightarrow \text{Verification} \rightarrow \text{Approval} \rightarrow \text{Active} \rightarrow \text{Expiration/Revocation}. \quad (17)$$

The lifecycle validity predicate  $V_S$  can therefore be represented as

$$V_S(C) = \text{ValidState}(C) \wedge \text{ValidTransition}(C). \quad (18)$$

An authorisation decision consequently requires both temporal and lifecycle validity. A consent that has expired, has been revoked, or has entered an invalid state must not be treated as an active authorisation even when its original identity, authority, and approval conditions were valid. In the implemented framework, the lifecycle validity predicate  $V_S$  is evaluated as part of the collective authorisation predicate  $V_A$ . This is important because only a consent in the ACTIVE state can satisfy the authorisation condition. Consequently, the symbol  $V_L$  is reserved for the jurisdictional predicate, which corresponds to the component L of the consent object.

SRQ5 therefore extends the foundational authorisation model into a dynamic consent environment in which trust is continuously evaluated according to both temporal conditions and lifecycle state.

### 3.3.6 SRQ6: Formal Security Assurance and Empirical Validation

The sixth sub-research question is

*How can the security properties of the proposed trust-oriented authorisation mechanism be formally defined and empirically evaluated to demonstrate that the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions?*

This question integrates the formal security analysis and empirical validation of the proposed framework. The purpose is not only to determine whether the prototype can execute valid consent workflows, but also to establish whether the implemented mechanism conforms to the security properties defined by the conceptual model.

The overall authorisation decision is defined as a conjunction of independently evaluated predicates

$$Decision(C, R) = \{ ALLOW, V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L; DENY, otherwise. \} \quad (19)$$

The corresponding security properties include identity correctness, which can be formulated as

$$u \in A_v \Rightarrow V_i(u) = I, \quad (20)$$

authorisation integrity

$$\neg (V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L) \Rightarrow Decision(C, R) = DENY, \quad (21)$$

threshold security, formulated as

$$|A_v| < N \Rightarrow Decision(C, R) = DENY, \quad (22)$$

and temporal safety, formulated as

$$t \notin [t_s, t_e] \Rightarrow Decision(C, R) = DENY. \quad (23)$$

Lifecycle safety additionally requires that unauthorised state transitions be rejected

$$IllegalTransition(C) \Rightarrow Reject. \quad (24)$$

The formal analysis provides a theoretical assurance layer that is independent of the empirical execution of the prototype. Experimental success alone cannot establish that unauthorised access is impossible under the stated model, while formal reasoning establishes security properties only under explicitly defined assumptions. Consequently, the two forms of evidence are complementary rather than interchangeable.

The empirical component evaluates whether the implemented HALAH framework realises these defined properties in representative

decentralised healthcare data-sharing scenarios. Synthetic demonstration records, containing no real patient data, are used to construct representative consent workflows. The evaluation considers both successful and unsuccessful authorisation scenarios, including valid identity and credential verification, invalid identity or credential submission, insufficient multi-party approval, valid threshold-based approval, unauthorised data-scope requests, purpose violations, expired consent, revoked consent, and invalid lifecycle transitions.

For a representative multi-party consent scenario, if two authorised participants are required, then it yields

$$|A_v| = 2 \Rightarrow V_A = 1, \quad (25)$$

whereas

$$|A_v| = 1 \Rightarrow V_A = 0. \quad (26)$$

The prototype evaluation therefore examines whether the implemented framework correctly transitions a consent from an unapproved state to an active authorisation state only when all required conditions are satisfied, and whether subsequent access requests are rejected when any required trust condition is violated.

Audit records are generated throughout the workflow to provide evidence of consent creation, participant verification, approval events, authorisation-state evaluation, data-access decisions, and relevant lifecycle transitions.

The empirical evaluation is therefore not primarily intended as a high-throughput performance benchmark. Instead, it assesses functional security correctness and consistency between the conceptual model, formal security properties, and implemented authorisation behaviour.

SRQ6 consequently represents the final assurance stage of the research programme by connecting formal security reasoning with implementation-level evidence. Together, these two forms of analysis provide evidence that the proposed framework is not only conceptually defined, but also capable of enforcing the intended trust-oriented authorisation properties in representative healthcare data-sharing scenarios.

### **3.4 Research Questions as an Integrated Research Problem**

The six sub-research questions are not independent technical questions; rather, they represent successive and interdependent trust conditions within a unified healthcare data authorisation problem. Collectively, they investigate how patient consent can be transformed from a static permission record into a trustworthy, evaluable, and enforceable authorisation mechanism.

SRQ1 establishes the conceptual object against which trust and authorisation can be evaluated by modelling patient consent as a structured authorisation object. SRQ2 establishes the trustworthiness of the participants by verifying their decentralised identities and authority evidence while explicitly separating identity from authorisation. SRQ3 then extends this participant-level trust into a collective decision by requiring independently verified participants to satisfy a predefined authorisation threshold. SRQ4 determines whether the resulting authorisation is applicable to the specific data-access request by evaluating purpose and data-scope constraints. SRQ5 further introduces the dynamic dimension of trust by determining whether the authorisation remains valid with respect to its temporal conditions and lifecycle state. Finally, SRQ6 establishes the assurance layer by formally defining the resulting security properties and empirically evaluating whether the implemented framework enforces them correctly.

The integrated authorisation condition can therefore be expressed as

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (27)$$

where  $V_I$  represents identity and authority validity,  $V_A$  represents collective authorisation validity,  $V_P$  represents policy and contextual compliance,  $V_T$  represents temporal validity, and  $V_L$  represents jurisdictional compliance, while lifecycle validity  $V_S$  is evaluated within  $V_A$ .

This formulation provides the central logical relationship among SRQ1–SRQ5. A valid authorisation decision requires the simultaneous satisfaction of all relevant trust conditions. Consequently, failure of any individual condition results in denial, such that

$$\neg (V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L) \Rightarrow Decision(C, R, t) = DENY. \quad (28)$$

The formulation also clarifies the role of SRQ6. Formal security assurance does not constitute another authorisation condition to be evaluated at runtime. Instead, it provides a means of specifying, analysing, and verifying the security properties of the integrated authorisation mechanism. Empirical validation subsequently examines whether the implemented system realises these properties under representative valid, invalid, and adversarial healthcare data-sharing scenarios. Thus, SRQ6 operates as an assurance layer over the mechanisms established by SRQ1–SRQ5 rather than as an additional access-control predicate.

The research questions form a progressive research architecture that begins with establishing a robust Consent Representation, which directly fosters Participant Trust. This trust then translates into a framework for Collective Authorisation, providing the necessary foundation for systemic Policy Enforcement. Consequently, this enables dynamic Temporal/Lifecycle Control over data and processes, culminating in comprehensive Security Assurance and Validation. By structuring the inquiries this way, the architecture links the user-facing interaction directly to the underlying authorisation checks.

The first four objectives are realised in full, while the fifth objective is realised operationally in the current prototype and the sixth objective is addressed empirically at this stage, with its formal component reserved for the next research programme.

This progression provides a coherent research pathway from the representation of consent to the enforcement and assurance of trustworthy data access. It also clarifies that decentralised identifiers, verifiable credentials, threshold authorisation, policy enforcement, and lifecycle controls are not independent blockchain or security features. Instead, they constitute complementary mechanisms within a single trust-oriented authorisation model.

Accordingly, the contribution of the research is not simply the implementation of a blockchain-based consent prototype. Rather, the research investigates how multiple trust conditions can be explicitly represented, independently evaluated, jointly enforced, formally reasoned about, and empirically validated within a decentralised healthcare data-sharing environment. The six research questions therefore collectively define the integrated research problem and provide a direct conceptual correspondence with the six research objectives.

## **4 Research Objectives**

The research objectives are derived from the research questions and translate the identified research gap into concrete research and development activities. The objectives are intentionally broader than individual implementation tasks. Each objective represents a research contribution that can be examined conceptually, technically, and, where appropriate, empirically. The complete research programme consists of six research objectives, corresponding to six research questions. The first four objectives establish the foundational trust-oriented authorisation mechanisms investigated during the current stage.

### **4.1 RO1 - Trust-Centric Consent Model**

The first research objective is to develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The model will incorporate identity information, authority requirements, policy constraints, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made.

RO1 directly addresses RQ1 and establishes the conceptual foundation for the remaining objectives. In particular, it defines the information that must be represented before consent can be interpreted as an authorisation decision rather than merely as a static approval record.

### **4.2 RO2 - Decentralised Identity and Authority Trust**

The second research objective is to develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority.

RO2 addresses RQ2 and provides the trust inputs required by the subsequent multi-party authorisation process. The objective is based on the principle that successful identity verification does not automatically imply permission to access healthcare data. Instead, identity and authority must be verified as distinct but related conditions of trustworthy authorisation.

### **4.3 RO3 - Trustworthy Multi-Party Authorisation**

The implemented mechanism defines the designated guardians at consent creation, verifies each EIP-712 approval through signature recovery, and requires a valid signature from every listed guardian. Consequently, the threshold equals  $|G|$ , an N-of-N condition demonstrated in the 2-of-2 configuration.

The third research objective is to develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants can jointly establish a trustworthy consent decision.

The objective is to prevent unilateral authorisation where collective approval is required and to provide an explicit mechanism for distinguishing sufficient from insufficient participation.

RO3 directly addresses RQ3 and extends the consent model from an individual permission statement to a collective authorisation decision.

#### **4.4 RO4 - Policy- and Context-Aware Access Control**

Accordingly, the implemented mechanism evaluates whether the requested purpose is consistent with the consent and rejects any request whose data scope is not a non-empty subset of the authorised EMR modules.

The fourth research objective is to develop a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent.

The objective is to ensure that a valid identity and sufficient multi-party approval cannot be used to obtain healthcare information outside the authorised scope.

RO4 directly addresses RQ4 and completes the foundational authorisation model investigated during the current stage. Together, RO1-RO4 establish the representation, verification, collective authorisation, and policy-enforcement mechanisms required for a trust-oriented healthcare data-sharing decision.

#### **4.5 RO5 - Temporal and Lifecycle Trust**

This objective has been substantially realised in the current implementation. In particular, the prototype enforces the temporal validity window at every access decision through the predicate VT, records notBefore and expiry on-chain within the consent token, implements end-to-end revocation including an on-chain revoke transaction, and manages the consent through an explicit lifecycle state machine. The remaining work therefore concerns hardening these controls rather than introducing them.

The fifth research objective is to extend the trust-oriented framework with temporal validity and consent lifecycle controls. The objective is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced.

RO5 addresses RQ5 and extends the foundational current stage authorisation model into a dynamic consent environment. Whereas current stage establishes whether an authorisation can be considered valid under

the defined identity, approval, and policy conditions, RO5 investigates whether that authorisation remains valid as time passes and as the consent state changes.

## **4.6 RO6 - Formal Security Assurance and Empirical Validation**

The empirical component has been partially delivered: 23 automated tests exercise per-dimension denial, signature rejection and proof tampering; a live out-of-jurisdiction request was refused on the deployed Sepolia contract; and an independent tool re-verified every recorded transaction against the chain. Consequently, the complete formal analysis, whether through proofs or model checking of the stated properties, remains the subject of the next stage research.

The sixth research objective is to formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios.

RO6 addresses RQ6 and combines formal security assurance with empirical validation of the proposed framework. The formal component will specify and analyse the security properties, consistency requirements, and soundness conditions of the trust-oriented authorisation mechanism. The empirical component will evaluate the implementation through representative consent workflows, negative and adversarial scenarios, and comprehensive testing of the HALAH prototype.

The empirical component has been executed against the demonstrated prototype. In particular, 23 automated tests cover per-dimension failures of the decision matrix, rejection of invalid EIP-712 signatures, and zero-knowledge tamper and expiry cases; the live demonstration includes a jurisdiction-based denial and a revocation followed by refusal; and an independent verification tool re-checks every ledger transaction against Sepolia receipts, reporting ALL CHECKS PASSED.

The objective is to establish not only that the prototype can execute valid consent workflows, but also that it behaves correctly when one or more trust conditions are violated. For example, the evaluation should examine whether access is denied when identity verification fails, when the required authorisation threshold is not satisfied, or when the requested purpose or data scope violates the consent policy.

RO6 therefore represents the transition from establishing the authorisation model to providing evidence for its security and practical effectiveness.

## 4.7 Relationship Between Research Questions and Objectives

The relationship between the six research questions and the six research objectives is summarised in Table 3 and Table 4.

The relationship between the six research questions and the six research objectives is

RO5 and RO6 constitute the principal research agenda for CA3. RO5 extends the authorisation model with temporal and lifecycle trust, while RO6 provides formal security assurance and comprehensive empirical validation. The distinction between the current stage and the next stage is therefore based on research scope and maturity rather than on a different set of research questions or objectives. Current stage establishes the foundational mechanisms and their conceptual relationships, whereas next stage investigates whether these mechanisms remain

The current stage delivers RO1–RO5 in operational form together with the empirical component of RO6, including negative and adversarial testing. Consequently, the principal remaining agenda for CA3 is the formal component of RO6, namely the formal specification and analysis of the security properties, together with the identified prototype hardening.

**Table 3:** Research Questions, Research Objectives, and Thesis Chapters for Current Stage

| RQ  | Research Objective                              | Research Focus and Scope                                                                                                                                                                                                              | Thesis    |
|-----|-------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| RQ1 | RO1: Trust-Centric Consent Model                | Develop a structured and evaluable consent representation that treats patient consent as a policy-bound authorisation object containing identity information, authority requirements, policy constraints, and authorisation evidence. | Chapter 3 |
| RQ2 | RO2: Decentralised Identity and Authority Trust | Establish trustworthy participants using DIDs and VCs while explicitly separating identity authentication from authorisation authority.                                                                                               | Chapter 3 |

| RQ  | Research Objective                         | Research Focus and Scope                                                                                                                                                                                  | Thesis    |
|-----|--------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| RQ3 | RO3: Trustworthy Multi-Party Authorisation | Establish collective authorisation through independently verified participants and threshold-based approval mechanisms, thereby preventing unilateral authorisation when collective approval is required. | Chapter 4 |

**Table 4:** Research Questions, Research Objectives, and Thesis Chapters for CA3

| RQ  | Research Objective                                      | Research Focus and Scope                                                                                                                                                                                   | Thesis    |
|-----|---------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| RQ4 | RO4: Policy- and Context-Aware Access Control           | Enforce purpose and healthcare data-scope constraints as explicit and evaluable conditions of access, ensuring that valid identities and sufficient approvals cannot be used outside the authorised scope. | Chapter 4 |
| RQ5 | RO5: Temporal and Lifecycle Trust                       | Temporal validity, expiration, revocation and controlled state transitions, enforced in the current prototype and anchored on-chain                                                                        | Chapter 5 |
| RQ6 | RO6: Formal Security Assurance and Empirical Validation | Formal analysis of the security properties (next stage), building upon the empirical negative and adversarial testing already performed with the HALAH prototype                                           | Chapter 5 |

reliable under dynamic lifecycle conditions and whether their security and practical effectiveness can be formally and empirically demonstrated. The overall research argument is that trustworthy patient consent should not be understood as a single technological artefact or as the outcome of a single access-control operation. Rather, it should be understood as a security decision emerging from a set of independently verifiable conditions. The contribution of the research is therefore to provide a coherent trust-oriented authorisation framework through which these conditions can be represented, evaluated, enforced, and ultimately validated in a decentralised healthcare data-sharing environment. For the

foundational current stage model, the authorisation decision is expressed as

$$Decision(C, R) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R), \quad (29)$$

$$Decision(C, R, t) = ALLOW \Leftrightarrow VI \wedge VA \wedge VP \wedge VT \wedge VL$$

This five-predicate conjunction constitutes the decision rule of the implemented Consent Engine and is applied consistently throughout this chapter; the earlier three-predicate formulation represents an initial design iteration that has since been superseded by the implementation.

where VI (u) represents the validity of the requesting participant's identity and authority evidence, VA (C) represents satisfaction of the required multi-party authorisation threshold, and VP (C, R) represents compliance between the access request and the consent policy. The next stage research will extend this decision model by incorporating temporal and lifecycle conditions

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C), \quad (30)$$

where VT (C, t) represents temporal validity and VL (C) represents the validity of the consent lifecycle state and its transitions. This extension provides a consistent connection between the foundational current stage objectives and the planned next research on dynamic trust, formal assurance, and comprehensive validation.

## 5 Research Architecture: MVC

The proposed research architecture adopts a Model-View-Controller (MVC) design to provide a structured implementation foundation for the trusted multi-party consent management framework. However, the MVC architecture is not used merely as a conventional software engineering pattern for separating data, interfaces, and application logic. Within the proposed framework, MVC is extended to support a more fundamental separation between the representation of consent, the interaction of independent stakeholders, and the enforcement of security-critical authorisation decisions. This separation is particularly important in decentralised healthcare data-sharing environments. A healthcare consent decision may involve patients, guardians, healthcare professionals, auditors, and other authorised entities, each of whom may possess different identities, authorities, responsibilities, and interests. Consequently, the system cannot rely on a single user authentication event or a static permission entry to determine whether access should be granted. Instead, the authorisation decision must emerge from the coordinated evaluation of independently verifiable security conditions. The proposed architecture therefore distinguishes three complementary responsibilities. The Model represents the security and governance state of the system, including identities, credentials, consent objects, authorisation requirements, policies, approval evidence, and healthcare data scopes. The View provides controlled interaction mechanisms through which independent participants can create, inspect, approve, or exercise consent-related operations. The Controller acts as the trusted decision coordination layer responsible for validating identity,

evaluating authority, aggregating multi-party approval evidence, enforcing policy constraints, and determining whether a requested healthcare data operation should be permitted. The architectural significance of this design is that the View cannot directly modify the authorisation outcome, while the existence of a Model object does not automatically imply that access is permitted. Instead, every sensitive access decision must pass through the Controller, which evaluates the relevant trust predicates associated with the consent and the access request. This provides a clear separation between what consent represents, how stakeholders interact with it, and how trust is enforced.

### 5.1 MVC Layered Architecture and Component Decomposition

The proposed HALAH framework adopts a layered Model-View-Controller (MVC) architecture to provide a clear separation between consent representation, stakeholder interaction, and security-critical authorisation enforcement. The purpose of this architectural decomposition is not simply to follow a conventional software engineering pattern, but to establish explicit boundaries between the information that represents trust, the

interfaces through which participants express their actions, and the mechanisms that determine whether those actions should result in an authorisation decision. At the highest level, the architecture consists of three complementary layers: the View Layer, the Controller Layer, and the Model Layer. The View Layer represents the interaction boundary with independent healthcare stakeholders. The Controller Layer represents the security decision and coordination boundary. The Model Layer represents the persistent trust, consent, policy, and authorisation state. Sensitive healthcare data are treated as protected resources whose access is mediated by the Controller rather than directly exposed to the View. Figure 6 illustrates the conceptual relationship among these layers with the architectural separation between stakeholder interaction, trust enforcement, and persistent governance state. The View Layer contains role-specific interaction interfaces through which patients, guardians or other authorised participants, healthcare professionals, and auditors submit or inspect system operations. These interfaces are intentionally separated from the security decision mechanism: an action submitted through the View represents a request or claim rather than a trusted authorisation outcome. The Controller Layer constitutes the principal security enforcement boundary. It receives requests from the View and coordinates the evaluation of the relevant trust conditions. These include request validation, decentralised identity verification, credential and authority verification, multi-party approval evaluation, policy and data-scope evaluation, and final authorisation. The Controller also generates audit evidence associated with the resulting decision. Consequently, the Controller acts as the coordination point through which sensitive operations must pass before protected healthcare data can be accessed. The Model Layer maintains the persistent security and governance state required by these evaluations. It includes identity and DID information, credential and authority evidence, consent objects, approval evidence, policy and data-scope constraints, authorisation evidence, and lifecycle state. The Model therefore provides the information required for the Controller to evaluate an access request, but the existence of a Model object does not itself imply that access is permitted. The protected healthcare data are deliberately positioned outside the three MVC layers as a protected resource. This distinction is important because healthcare data should not be

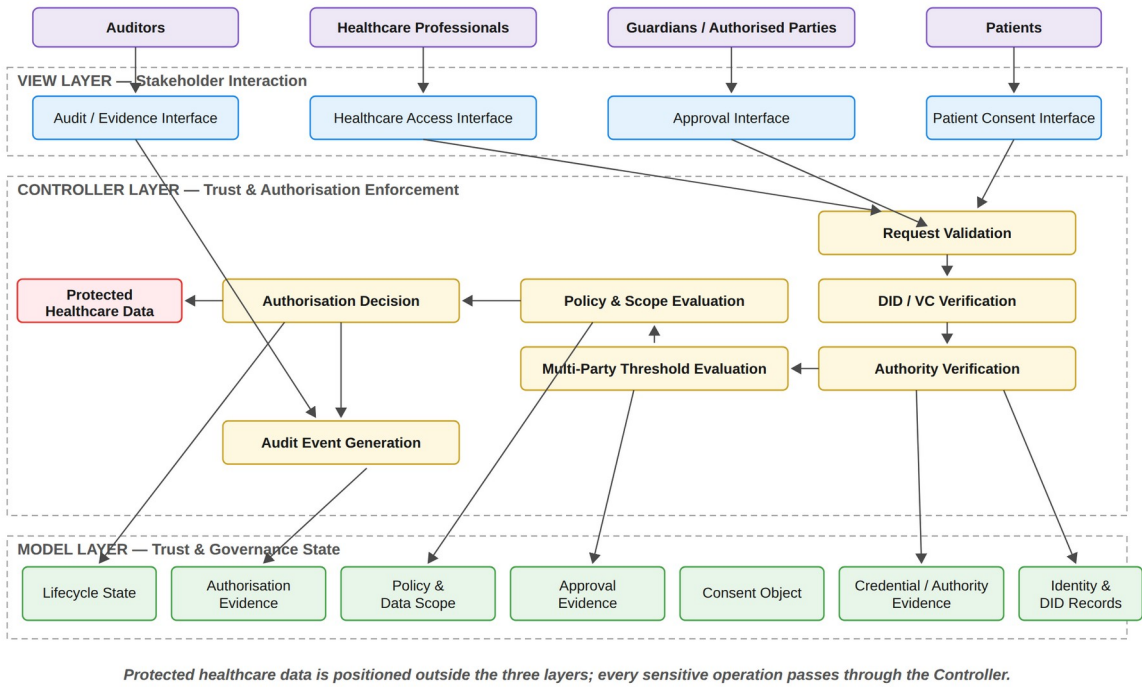


Figure 6: Layered MVC Architecture and Component Decomposition of the HALAH Framework

*[Figure 6: Layered MVC Architecture and Component Decomposition of the HALAH Framework]*

The Controller layer additionally incorporates a ZK Proof Service, responsible for Groth16 proof generation and verification and feeding directly into the Authorisation Decision, together with an On-chain Anchor Service that performs asynchronous minting and revocation; correspondingly, the Model layer contains the ConsentSBTV3 contract deployed on Sepolia alongside the SQLite Audit Ledger, a revocation path flows from the Patient interface through the Controller to both the ledger and the contract, and an external independent verifier, `verify_poc`, reads from both the audit ledger and the Sepolia chain.

It should be acknowledged that, in the present prototype, credential verification consists of a structural well-formedness check on each DID, and the requester's role and jurisdiction are self-declared. This is important because wallet-held signing keys and authenticated verifiable credentials are deferred to the production design and are therefore identified as future work.

treated as ordinary application state that can be directly manipulated by the View. Instead, access to the protected resource is mediated by the Controller after the relevant trust conditions have been evaluated.

### 5.1.1 MVC Component Decomposition

The Controller layer therefore comprises eight principal functions, the two additional functions being Cryptographic Proof Generation and Verification, realised through the Groth16 proving system, and On-chain

Anchoring and State Synchronisation, which performs the Sepolia mint and revoke operations as a background process; the Controller row of Figure 7 reflects these eight functions accordingly.

The three architectural layers are further decomposed into functional components, each corresponding to a distinct responsibility within the trust-oriented authorisation process. Figure 7 presents this decomposition. The View is decomposed according to the principal stakeholder

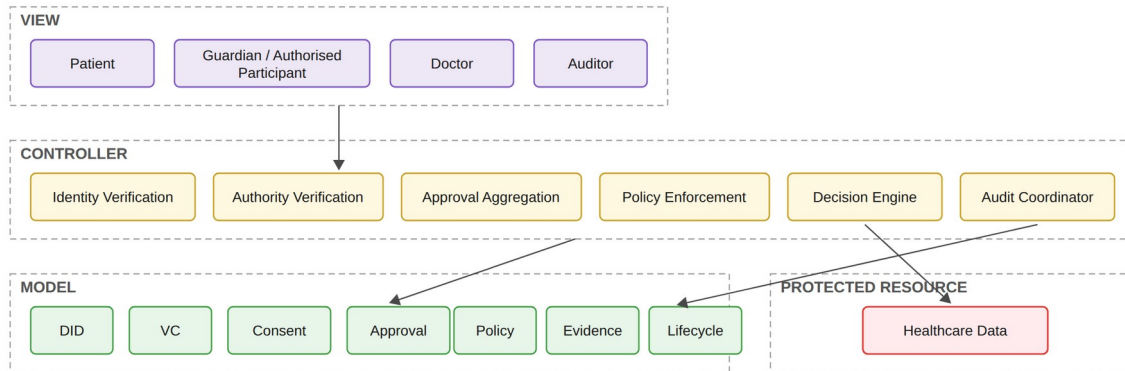


Figure 7: Functional Decomposition of the MVC Components

*[Figure 7: Functional Decomposition of the MVC Components]*

roles. The patient interface supports consent specification and consent-related actions. The guardian or other authorised-participant interface supports independent approval. The healthcare professional interface supports authorised data-access requests. The auditor interface supports inspection of authorisation evidence and audit history. These interfaces represent

different interaction responsibilities but share the same architectural principle: none of them independently determines whether access should be granted. The Controller is decomposed into six principal security functions. Identity Verification establishes whether a participant can be identified through the relevant decentralised identity mechanism. Authority Verification evaluates whether the participant possesses appropriate evidence concerning the required role or authority. Approval Aggregation determines whether independently verified approvals satisfy the predefined threshold. Policy Enforcement evaluates whether the requested purpose and data scope comply with the consent policy. Decision Engine combines the resulting predicates into the final authorisation decision. Finally, Audit Coordination records the relevant evidence and decision events. The Model is decomposed into seven principal state representations. The DID component represents decentralised identity information; the VC component represents credential and authority evidence; the Consent component represents the structured patient authorisation object; the Approval component represents verified multi-party approval evidence; the Policy component

represents purpose and data-scope constraints; the Evidence component represents evidence generated throughout the authorisation process; and the Lifecycle component represents the current state of the consent object and its permissible transitions. This decomposition establishes an explicit distinction between state, interaction, and enforcement. The Model stores and represents security-relevant state, the View expresses stakeholder actions, and the Controller determines whether those actions satisfy the required trust conditions.

### 5.1.2 Trust Evaluation Across the MVC Layers

The architectural layers cooperate through a controlled authorisation sequence rather than through unrestricted direct communication. The relationship between the MVC components and the trust predicates introduced by SRQ1-SRQ5 is illustrated in Figure 8. Figure 8 provides the logical relationship between the architectural components and the integrated trust model. A healthcare data-access request is not evaluated according to a single authentication event. Instead, the Controller coordinates a sequence of trust predicates representing the conditions established by SRQ1-SRQ5. The first condition,  $VI(u)$ , determines whether the requesting participant possesses valid identity and authority evidence. The second condition,  $VA(C)$ , determines whether the required independently verified participants have collectively satisfied the authorisation threshold. The third condition,  $VP(C, R)$ , determines whether the requested operation complies with the consent policy, including purpose and data-scope restrictions. The fourth condition,  $VT(C, t)$ , determines whether the consent remains valid at the time of the request. The fifth condition,  $V_L(C)$ , determines whether the jurisdictional constraint recorded in the consent is satisfied; lifecycle validity and revocation are evaluated within  $V_A$ . The integrated decision can therefore be expressed as

$V_L(C, j)$  verifies that the jurisdiction  $j$  declared by the requester matches the jurisdiction  $L$  recorded within the consent object. This distinction is important because revocation and lifecycle state are not enforced by this function but within  $V_A$ . Consequently, the corresponding component in Figure 8 is depicted as  $V_L(C, j)$ , the jurisdiction verification function, rather than as a lifecycle check.

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (31)$$

The Controller does not itself create these trust conditions. Instead, it evaluates evidence represented by the Model and coordinates the resulting decision. This distinction is important for the interpretation of the architecture: the Controller is a decision-enforcement mechanism, whereas the Model is a representation of trust and governance state. If any required predicate evaluates to false, the decision is

$$\neg(V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L) \Rightarrow Decision(C, R, t) = DENY. \quad (32)$$

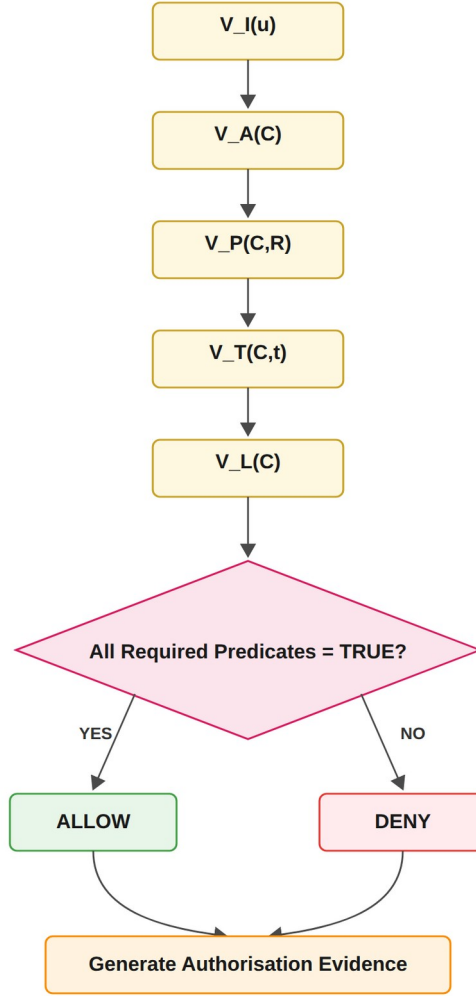


Figure 8: Trust Predicate Evaluation and Authorisation Decision Flow

*[Figure 8: Trust Predicate Evaluation and Authorisation Decision Flow]*

Both successful and unsuccessful decisions are subsequently associated with authorisation evidence. This ensures that the architecture supports not only access enforcement but also accountability and subsequent verification.

### 5.1.3 Relationship Between MVC Layers and Research Questions

The MVC decomposition provides an implementation-oriented mapping of the six sub-research questions. SRQ1 is primarily represented by the Model through the trust-aware consent object. SRQ2 is implemented through the interaction between the Model and Controller, where decentralised identities and verifiable credentials are represented and verified. SRQ3 is primarily enforced by the Controller through verified multi-party approval and threshold evaluation. SRQ4 is implemented through the interaction between the consent and policy representations in the Model and the policy-enforcement functions of the Controller. SRQ5 extends the Model and Controller with temporal and lifecycle information.

Temporal conditions and lifecycle state are represented in the Model, while their validity is evaluated by the Controller before an access decision is produced. SRQ6 operates across the complete architecture rather than being confined to a single MVC layer. Formal security assurance evaluates the logical properties of the integrated model, while empirical validation evaluates whether the implementation consistently realises those properties. The relationship can therefore be summarised as follows

*SRQ1 → Model; SRQ2 → Model + Controller; SRQ3 → Controller; SRQ4 → Model + Controller;  
SRQ5 → Model + Controller; SRQ6 → Model + View + Controller.*

This mapping demonstrates that MVC functions as the implementation architecture through which the conceptual research questions are operationalised. It does not replace the trust model; rather, it provides the structural boundaries through which the trust model can be implemented, evaluated, and validated.

#### **5.1.4 Architectural Boundary and Trust Assumptions**

The layered architecture also establishes explicit trust boundaries. The View is considered an interaction boundary and therefore cannot be treated as a trusted source of authorisation decisions. Participant actions originating from the View must be independently verified by the Controller. The Controller represents the security enforcement boundary. It is responsible for applying the authorisation rules consistently and for preventing direct access to protected healthcare data when the required trust conditions are not satisfied. The Model represents the security-state boundary. Its records provide the evidence and state required for authorisation evaluation, but stored state alone does not constitute permission. In particular, the presence of a consent record, credential, or approval record cannot independently produce an access decision.

The protected healthcare data represent the final resource boundary. Access is permitted only through the authorisation path enforced by the Controller. This separation reduces the possibility that presentation-layer operations or stored records can bypass the security decision mechanism. These boundaries are important for interpreting the security contribution of the architecture. The proposed framework does not claim that MVC itself provides security. Instead, security arises from the explicit placement of trust-sensitive operations within the Controller, the structured representation of security state within the Model, and the prevention of direct security decisions at the View layer. Accordingly, the MVC architecture provides the structural foundation for implementing the trust-oriented authorisation model. The subsequent sections describe each layer in greater detail, beginning with the Model representation of trust-aware consent and authorisation state, followed by the View interaction mechanisms and Controller-based enforcement mechanisms.

## 5.2 Trust-Oriented Consent Authorisation Workflow

Figure 9 presents the end-to-end workflow of the proposed trust-oriented patient consent authorisation framework. The workflow operationalizes the central premise of this research that trustworthy healthcare data access cannot be established by a single mechanism, such as a blockchain record or an authenticated identity. Instead, an access decision should be established through the coordinated verification of consent specifications, participant identity and authority, multi-party authorisation, and policy compliance. Accordingly, the proposed workflow transforms a patient's consent from a static permission record into an evaluable authorisation object that can be verified before healthcare data are released. The workflow begins when the patient creates a consent request and specifies the conditions under which healthcare data may be accessed. The consent specification defines the intended purpose, permitted data scope, and other authorisation conditions. This step establishes what the patient intends to authorize and provides the policy context against which subsequent access requests can be evaluated. Therefore, consent is not represented merely as an approval flag, but as a structured object containing the information required for subsequent authorisation decisions. The next stage performs decentralised identity and authority verification using Decentralised Identifiers (DIDs) and Verifiable Credentials (VCs). The purpose of this stage is to establish both the identity of the participant and the evidence supporting the participant's claimed role or authority. Importantly, the framework explicitly separates identity authentication from authorisation. A successfully verified DID or VC demonstrates that a participant can be identified and that relevant credentials are valid; it does not, by itself, grant permission to access patient data. This distinction is fundamental to the proposed trust model because an authenticated participant should not automatically be considered an authorized participant. After identity and authority verification, the framework identifies the participants required to establish the consent decision. The authorisation requirement may involve multiple independent participants, such as a patient together with one or more guardians or other authorized parties. The framework then collects their independent approvals and evaluates whether the predefined authorisation threshold has been satisfied. Let  $A_v$  denote the set of successfully verified approvals and let  $N$  denote the required authorisation threshold. Multi-party authorisation is satisfied when

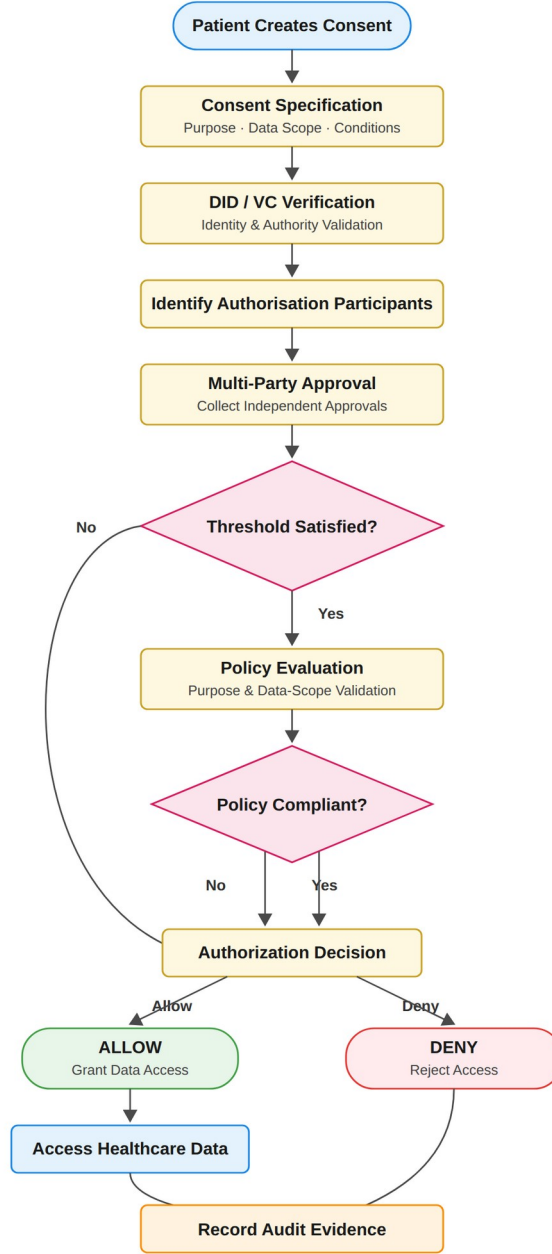


Figure 9: End-to-End Workflow of Trust-Oriented Consent Authorisation Framework

[Figure 9: End-to-End Workflow of Trust-Oriented Consent Authorisation Framework]  
Once all  $|G|$  guardians have signed, satisfying the N-of-N condition, the consent token is minted in the local ledger while a background job anchors the mint on Sepolia asynchronously; the temporal check  $V_T$  and the jurisdictional check  $V_L$  are then evaluated before the Authorisation Decision, a Groth16 proof is generated and verified on the ALLOW branch, and after the audit evidence is recorded the flow continues through patient-initiated revocation, the corresponding on-chain revoke transaction, and finally auditor review together with independent verification through `verify_poc`.

$$V_A(C) = 1, |A_v| \geq N; 0, |A_v| < N. \quad (33)$$

In the implemented prototype the threshold is fixed at  $N = |G|$ , so that every listed guardian must provide a valid approval before activation; the evaluated configuration is therefore 2-of-2. Configurable k-of-n thresholds constitute a direct generalisation that is deferred to future work.

If the required threshold is not satisfied, the authorisation process terminates with a denial decision. This prevents a single participant from unilaterally establishing authorisation when the consent policy requires collective approval. When the authorisation threshold is satisfied, the workflow proceeds to policy evaluation. At this stage, the requested access is evaluated against the purpose and data-scope constraints defined in the consent object. This step addresses an important limitation of identity-based and approval-based access control: a legitimate participant may still request data that fall outside the scope of the patient's consent. For example, if a consent permits access to Observation, Medication, a request additionally containing Procedure should not be authorized because

$$S_R \not\subseteq S_C, \quad (34)$$

where SR represents the requested data scope and SC represents the consent-authorized scope. Similarly, the requested purpose must be consistent with the purpose specified in the consent. Consequently, a valid identity and sufficient multi-party approval are necessary but not sufficient conditions for access. The final authorisation decision is therefore determined by the conjunction of identity and authority verification, multi-party authorisation, and policy compliance. For the current stage scope of the proposed framework, the decision can be expressed as

$$Decision(C, R) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R), \quad (35)$$

where VI (u) represents the validity of the requesting participant's identity and authority evidence, VA (C) represents satisfaction of the required multi-party authorisation threshold, and VP (C, R) represents compliance between the access request and the consent policy. If any of these conditions is false, the request is denied. Only when all required conditions are satisfied is healthcare data access granted. Finally, the framework records the resulting authorisation evidence in the audit layer. Importantly, both successful and denied decisions should be recorded because a trustworthy authorisation framework requires accountability not only for data that were released but also for access attempts that were rejected. The audit evidence can therefore provide a traceable record of the authorisation decision, including the relevant consent, participants, policy evaluation, decision outcome, and associated evidence. In this manner, the workflow connects consent specification with identity trust, collective authorisation, policy enforcement, and accountability, providing the operational foundation of the proposed trust-oriented authorisation framework.

### 5.3 Model: Trust-Aware Consent and Authorisation Representation

The implementation realises this representation in full, including temporal validity, expiration, on-chain revocation and an explicit lifecycle state machine. Formal verification of the associated security properties, however, remains a matter for future work.

The Model layer represents the persistent security state of the proposed consent-management framework. Rather than treating consent as a simple binary permission, the framework models

consent as a structured authorisation object that captures the security conditions under which healthcare data may be accessed. For the current stage scope, the core consent object is represented as

$$C = (I, A, P, T, L, E) \quad (36)$$

where T represents the temporal validity window of the consent and L represents the jurisdiction in which the consent may be exercised, both defined exactly as they are realised in the implementation.

where I represents identity-related information associated with the relevant participants, A represents the authorisation requirements that must be satisfied before access can be granted, P represents the policy conditions governing purpose and healthcare data scope, and E represents the evidence generated throughout the authorisation process. The identity component I does not simply store a username or centrally issued account identifier. It represents decentralised identities and the associated evidence required to establish the legitimacy of participating entities. This allows patients, guardians, healthcare professionals, and other participants to be represented as independently identifiable actors rather than as entries controlled exclusively by a central authority. The authorisation component A defines the conditions under which a consent object may become operational. In particular, it specifies whether a single participant is sufficient or whether multiple independent entities are required to jointly authorise a sensitive healthcare data operation. Let  $A_v$  denote the set of participants whose identities and authority have been successfully verified, and let N denote the minimum required approval threshold. The authorisation condition can then be represented as

$$V_A(C) = I, |A_v| \geq N; 0, |A_v| < N. \quad (37)$$

This mechanism provides an important departure from conventional consent systems. In a traditional single-owner model, compromise, error, or misuse of one privileged account may be sufficient to produce an authorisation decision. In the proposed framework, trust can instead be distributed across multiple independently verified participants. A sensitive access decision becomes valid only when the defined collective authorisation condition has been satisfied. The policy component P represents the contextual restrictions associated with the consent. These

restrictions may include the intended purpose of access and the healthcare data categories that are permitted to be disclosed. Therefore, the existence of a valid identity and sufficient approval evidence does not automatically authorise unrestricted access to all patient information. Let  $S_C$  denote the healthcare data scope authorised by the consent object and  $S_R$  denote the scope requested by an entity. Policy compliance requires

$$S_R \subseteq S_C. \quad (38)$$

If the requested data exceeds the authorised scope, the request must be rejected even if the requester has successfully authenticated and the required number of participants has approved the consent. The evidence component  $E$  represents the verifiable information generated during the authorisation process. This may include identity-verification results, credential-verification results, approval records, policy-evaluation outcomes, access decisions, and audit events. The purpose of  $E$  is not merely to record that a decision occurred, but to provide evidence concerning why the decision was produced.

This distinction is particularly important for trustworthy consent governance. A conventional immutable record may demonstrate that a transaction was stored, whereas the proposed model seeks to preserve evidence concerning the conditions that justified the resulting authorisation decision. Consequently, the Model acts as a security-bearing representation of the consent lifecycle rather than as a passive permission database.

## 5.4 View: Controlled Interaction Among Independent Participants

The View layer provides the interaction environment through which independent stakeholders participate in the consent-management process. In the HALAH prototype, these stakeholders may include patients, guardians, healthcare professionals, and auditors. Although these participants interact with different functions of the system, their interfaces do not directly determine the security outcome of an authorisation request. This separation is essential because user interaction and security enforcement should not be treated as equivalent. For example, a healthcare professional may successfully submit an access request through the interface, but this interaction alone does not establish the right to access patient information. Similarly, a guardian may submit an approval, but the approval does not become effective unless the corresponding identity and authority conditions have been verified and the required multi-party threshold has been satisfied. The View therefore functions as a controlled mechanism for expressing requests and authorisation intent. A patient may create a consent specification and identify the relevant healthcare participant, authorised purpose, permitted data categories, and required approval conditions. Guardians or other authorised participants may subsequently submit their approval.

Healthcare professionals may submit data-access requests, while auditors may inspect the resulting evidence and authorisation history. The separation between interaction and enforcement prevents the user interface from becoming the source of trust. A request submitted through the View represents an input to the authorisation process, rather than an authorisation decision itself. The actual security decision remains the responsibility of the Controller. This distinction is particularly important in decentralised environments where different stakeholders may not fully trust one another. The proposed architecture therefore treats each user action as a claim that must be independently evaluated rather than as an automatically trusted system operation.

## 5.5 Controller: Trusted Multi-Party Authorisation Enforcement

The Controller represents the central decision coordination mechanism of the proposed framework. Its responsibility is to transform consent specifications, participant credentials, approval evidence, and access requests into a deterministic authorisation decision. The Controller first evaluates whether the requesting entity and relevant authorisation participants possess valid identities and credentials. Identity verification can be represented as

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u), \quad (39)$$

where  $\text{VerifyDID}(u)$  determines whether the decentralised identity of participant  $u$  can be verified and  $\text{VerifyVC}(u)$  determines whether the associated credential provides valid evidence of the relevant authority or role. A central principle of the proposed architecture is that identity verification and authorisation authority are not equivalent. A participant may possess a valid identity while lacking the authority required to access a particular patient's healthcare information. Therefore,

$$\text{Identity} \neq \text{Authorisation}. \quad (40)$$

This distinction prevents successful authentication from being incorrectly interpreted as unrestricted permission. After identity and authority conditions have been evaluated, the Controller determines whether the multi-party authorisation requirements associated with the consent object have been satisfied. Only independently verified participants can contribute to the authorisation evidence set  $A_v$ . If the number of valid approvals is below the required threshold  $N$ , the consent cannot produce an effective authorisation decision. The Controller then evaluates the relationship between the access request  $R$  and the policy conditions contained within the consent object. This process determines whether the requested healthcare data, operation, and intended purpose remain within the permitted authorisation boundary. The corresponding policy predicate can be represented as

$$V_P(C, R) = \text{Policy}(C, R). \quad (41)$$

The overall current stage authorisation decision is therefore determined by the conjunction of the foundational trust conditions:

$$Decision(C, R) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R). \quad (42)$$

Equivalently, the decision can be represented as

$$Decision(C, R) = ALLOW, V_I(u) = 1 \wedge V_A(C) = 1 \wedge V_P(C, R) = 1; DENY, otherwise. \quad (43)$$

The security significance of this formulation is that no individual condition is sufficient to produce an access decision. A valid identity without sufficient multi-party approval does not result in access. Similarly, sufficient approval without policy compliance cannot authorise disclosure beyond the permitted healthcare data scope. This creates a conjunctive trust model in which the failure of any required condition prevents the final authorisation decision. More importantly, the Controller provides a single security-enforcement point through which all sensitive operations must be evaluated. This reduces the risk that different components independently interpret consent conditions and produce inconsistent access decisions.

## 5.6 Multi-Party Consent as Distributed Trust Establishment

A central contribution of the proposed architecture is the treatment of multi-party consent as a distributed trust-establishment mechanism rather than as a simple collection of multiple signatures. In conventional approval systems, multiple signatures may simply be appended to a document or transaction. However, the presence of multiple approvals does not necessarily establish that the approving entities were legitimate, possessed the appropriate authority, or approved the same policy conditions. The proposed framework therefore associates each approval with independently verifiable identity and authority information. An approval contributes to the effective authorisation condition only when the corresponding participant satisfies the identity and credential requirements defined by the framework. Let the set of submitted approvals be denoted by

$$A_s = \{a_1, a_2, \dots, a_m\}. \quad (44)$$

The verified approval set is then derived as

$$A_v = \{a_i \in A_s \mid V_I(a_i) = 1 \wedge Authority(a_i) = Valid\}. \quad (45)$$

Only the verified set  $A_v$  contributes to the threshold condition. Consequently, an arbitrary number of unverified or unauthorised approvals cannot satisfy the multi-party authorisation requirement. This mechanism provides resistance against several classes of authorisation failure. A compromised or unauthorised participant cannot independently activate access when the threshold has not been satisfied. Similarly, an invalid identity cannot increase the approval count merely by submitting an approval action through the user interface. The architectural contribution therefore lies in the combination of identity verification and

collective decision making. Trust is not assumed to reside in a single privileged entity. Instead, it emerges from the coordinated satisfaction of independently verifiable requirements across multiple participants.

## 5.7 Policy-Aware Consent Enforcement

Another important feature of the architecture is the explicit separation between approval validity and access scope validity. Even when all required participants have approved a consent request, the resulting authorisation remains bounded by the policy encoded within the consent object. Suppose that a consent permits access to the following healthcare data categories:

$$S_C = \{Observation, Medication\}. \quad (46)$$

If a healthcare professional subsequently requests

$$S_R = \{Observation, Medication, Procedure\}, \quad (47)$$

the request exceeds the authorised data scope because

$$S_R \not\subseteq S_C. \quad (48)$$

The Controller must therefore return

$$Decision(C, R) = DENY. \quad (49)$$

This property is important because conventional authentication and role-based access control mechanisms may determine that an entity is generally authorised to access a category of healthcare information without adequately considering the specific policy conditions associated with an individual patient's consent. The proposed architecture instead binds the access decision to the consent policy itself. Consent therefore becomes an active authorisation constraint rather than a historical indication that a participant was once granted permission. This policy-centric approach also provides a basis for future extensions. While the current stage implementation focuses on purpose and healthcare data scope, the same mechanism can subsequently incorporate additional contextual conditions, including location, organisation, treatment relationship, emergency status, temporal restrictions, and other regulatory constraints.

## 5.8 Authorisation Evidence and Auditability

In the implementation, consent activation and revocation are anchored on the Sepolia blockchain through the ConsentSBTV3 soulbound contract. This anchoring is performed asynchronously, and the audit ledger records the transaction hash and block number of each anchoring operation, thereby providing tamper-resistant evidence of the consent state.

The proposed architecture further distinguishes between making an authorisation decision and demonstrating how that decision was made. For this reason, the Controller generates evidence associated with each

relevant stage of the authorisation process. Conceptually, an authorisation evidence record can be represented as

$$E_R = \{ID, Credential, Approval, Policy, Decision, Audit\}. \quad (50)$$

where ID represents identity-verification evidence, Credential represents authority or role verification evidence, Approval represents the verified multi-party approval state, Policy represents the result of policy evaluation, Decision represents the final access outcome, and Audit represents the associated event record. The resulting audit trail provides a stronger governance capability than a simple record of successful access. An auditor can examine not only whether access occurred, but also whether the requester possessed a valid identity, whether the required authorisation threshold was satisfied, whether the requested data complied with the authorised scope, and which conditions produced the final decision. However, the blockchain itself is not treated as the source of trust. Its role is to strengthen integrity, non-repudiation, and auditability of the evidence generated by the authorisation process. The trustworthiness of the access decision instead originates from the coordinated enforcement of identity, authority, multi-party approval, and policy conditions.

## 5.9 Architectural Security Properties

The proposed MVC architecture provides several foundational security properties for the current stage. These properties emerge from the interaction between the Model, View, and Controller rather than from any single technology.

First, the architecture provides identity-dependent participation. A participant cannot contribute to the authorisation process solely by interacting with the system interface. The corresponding identity and credential must satisfy the verification requirements. Second, the architecture provides authority separation. Possession of a valid identity does not automatically result in permission to access patient data. Identity verification provides evidence concerning who an entity is, whereas authority verification determines whether that entity may perform a particular role within the authorisation process. Third, the architecture provides collective authorisation integrity. Sensitive healthcare data access can be configured to require multiple independently verified participants. Therefore, a single participant cannot unilaterally activate access when the defined authorisation threshold has not been reached. Fourth, the architecture provides policy-bounded access. A valid requester with sufficient approval evidence cannot access healthcare information beyond the purpose or data scope defined by the consent object. Finally, the architecture provides decision accountability. The system maintains evidence concerning the conditions that produced an authorisation decision, thereby supporting auditing and subsequent verification. These properties can be summarised as shown in Table 5.

## 5.10 MVC Architecture and the Research Objectives

The MVC architecture also provides a direct implementation structure for the research objectives. RO1 is primarily represented in the Model through the development of the trust-aware consent object. RO2 is implemented through the identity and authority verification mechanisms coordinated by the Controller. RO3 is realised through the multi-party approval and threshold evaluation process. RO4 is implemented through the policy evaluation mechanisms that constrain the authorised purpose and healthcare data scope. As shown in Table 6, the View provides the operational environment through which these mechanisms are exercised by independent participants. Importantly, the View does not determine whether an operation is authorised. Instead, it captures participant actions and forwards them to the Controller, which evaluates the security predicates defined by the Model.

## 5.11 Architectural Contribution and Scope

The principal contribution of the proposed architecture is not the use of MVC itself, but the way in which MVC is employed to operationalise a trust-oriented authorisation model. The Model provides a structured representation of the conditions that define valid consent. The View enables multiple independent stakeholders to express consent-related intentions without directly determining security outcomes. The Controller coordinates independently verifiable trust conditions and produces the final authorisation decision. This design transforms multi-party consent management from a conventional record-management problem into a distributed security-governance problem. The key innovation is that consent is treated as an active and evaluable authorisation object whose effectiveness depends on the joint satisfaction of identity, authority, collective approval, and policy conditions. For the current stage, the architecture therefore establishes the foundational mechanisms required to answer RQ1-RQ4. The implemented HALAH prototype provides the practical

**Table 5:** Security Properties Supported by the Proposed MVC-Based Consent Architecture

| Security Property                | Architectural Mechanism                                                                          | Security Significance                                                                               |
|----------------------------------|--------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|
| Identity-dependent participation | DID and credential verification before a participant can contribute to the authorisation process | Designed to prevent unverified entities from being treated as legitimate participants.              |
| Authority separation             | Independent evaluation of identity and role or authority evidence                                | Designed to prevent successful authentication from being interpreted as unrestricted authorisation. |

| Security Property                         | Architectural Mechanism                                                                       | Security Significance                                                                                                                        |
|-------------------------------------------|-----------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| Multi-party authorisation integrity       | Threshold evaluation over independently verified approval participants                        | Designed to prevent a single participant from unilaterally activating sensitive healthcare data access when collective approval is required. |
| Policy-bounded access                     | Evaluation of purpose and requested data scope against consent policy                         | Designed to prevent otherwise valid identities and approvals from being used to obtain data beyond the authorised scope.                     |
| Authorisation evidence                    | Recording of verification results, approval evidence, policy evaluation, and final decisions  | Designed to provide traceability and support accountability, auditing, and future verification.                                              |
| Separation of interaction and enforcement | The View submits requests while the Controller independently determines the security decision | Designed to prevent user-interface actions from being interpreted directly as trusted authorisation outcomes.                                |

**Table 6:** Mapping Between Research Objectives and MVC Components

| Research Objective | Primary MVC Component | Core Mechanism                             | Expected Contribution                                                                                                            |
|--------------------|-----------------------|--------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------|
| RO1                | Model                 | Trust-aware consent representation         | Transforms consent from a passive permission record into a structured and evaluable authorisation object.                        |
| RO2                | Controller and Model  | DID and VC verification                    | Establishes trustworthy participants while explicitly separating identity from authorisation authority.                          |
| RO3                | Controller            | Verified multi-party threshold evaluation  | Establishes collective trust and prevents unilateral authorisation when multiple approvals are required.                         |
| RO4                | Controller and Model  | Policy, purpose, and data-scope evaluation | Ensures that valid participants and sufficient approvals remain constrained by the authorised purpose and healthcare data scope. |

| Research Objective | Primary MVC Component       | Core Mechanism                                      | Expected Contribution                                                                                                                                                                                                                     |
|--------------------|-----------------------------|-----------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RO5                | Model and Controller        | Temporal validity and consent lifecycle enforcement | Ensures that authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced.                                         |
| RO6                | Model, View, and Controller | Formal security analysis and empirical validation   | Will provide formal assurance (next stage) of the defined trust and authorisation properties and empirically evaluates whether the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions. |

environment in which these mechanisms can be instantiated and evaluated through representative healthcare data-sharing scenarios. The subsequent stage will extend the architecture beyond the current foundational authorisation model. The consent Model will be expanded to include temporal validity, expiration, revocation, and controlled lifecycle transitions. The Controller will subsequently incorporate the corresponding temporal and lifecycle predicates into the authorisation decision. In addition, the complete decision model will be subjected to formal security analysis and broader empirical validation. Accordingly, the current stage architecture establishes the foundational security core of the research, while the next stage will investigate whether this core can maintain trust dynamically over time beyond the lifecycle mechanisms already demonstrated in the prototype, satisfy formally defined security properties, and consistently enforce the complete trust-oriented authorisation model under representative and adversarial healthcare data-sharing conditions.

## 6 Proposed Solution

### 6.1 Trust-Centric Consent Model for RO1

RO1 addresses RQ1 by developing a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The purpose of this objective is to establish a formal representation of what the patient intends to authorise, who is permitted to participate in the authorisation process, which healthcare data may be accessed, and under what conditions access may be granted. The proposed consent object is represented as

$$C = (I, A, P, T, L, E) \quad (51)$$

where T represents the temporal validity window of the consent and L represents the jurisdiction in which the consent may be exercised.

where I represents patient and participant identity information, A represents authorisation requirements, P represents policy constraints, and E represents authorisation evidence. The identity component identifies the patient and relevant participants. The authorisation component defines the required participants and approval threshold. The policy component specifies the permitted purpose and healthcare data scope. The evidence component records the information required to support subsequent verification and audit. The consent model therefore separates the specification of consent from the final access decision. A consent object does not automatically imply that every subsequent request is authorised. Instead, the object provides the conditions against which a request can be evaluated.

#### 6.1.1 RO1 Consent Creation Workflow

The following workflow describes the creation of a trust-aware consent object. The process begins with a patient request and ends with a structured consent record that can be verified by subsequent authorisation services. The workflow first collects the patient identity and the intended healthcare participants. It then specifies the purpose and data scope of the consent. In the HALAH implementation, the patient interface allows the patient to select a patient DID, specify an authorised doctor, identify guardian DIDs, and select healthcare data modules such as Observation, Medication, Condition, and Procedure. The implementation also collects the start and expiry time of the consent.

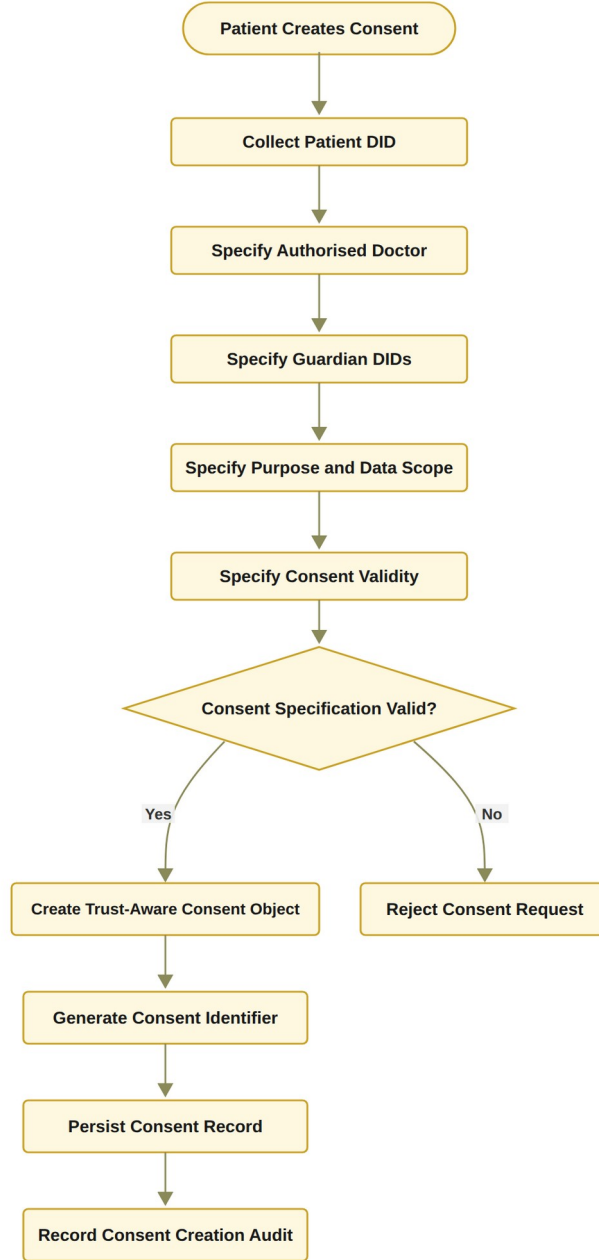


Figure 10: RO1 workflow for trust-centric consent creation

Whereas Figure 10 describes the behaviour of consent creation, Figure 11 presents the structure of the resulting consent object. It shows each of the six components of  $C = (I, A, P, T, L, E)$ , the content that each component holds in the HALAH system, and the party that supplies it. The patient supplies the identity, authority, policy, temporal and jurisdictional components; the threshold  $N = |G|$  and the consent identifier  $id_C$  are generated by the system; and the evidence component is accumulated by the audit layer, the guardians' signatures and the blockchain as the consent progresses.

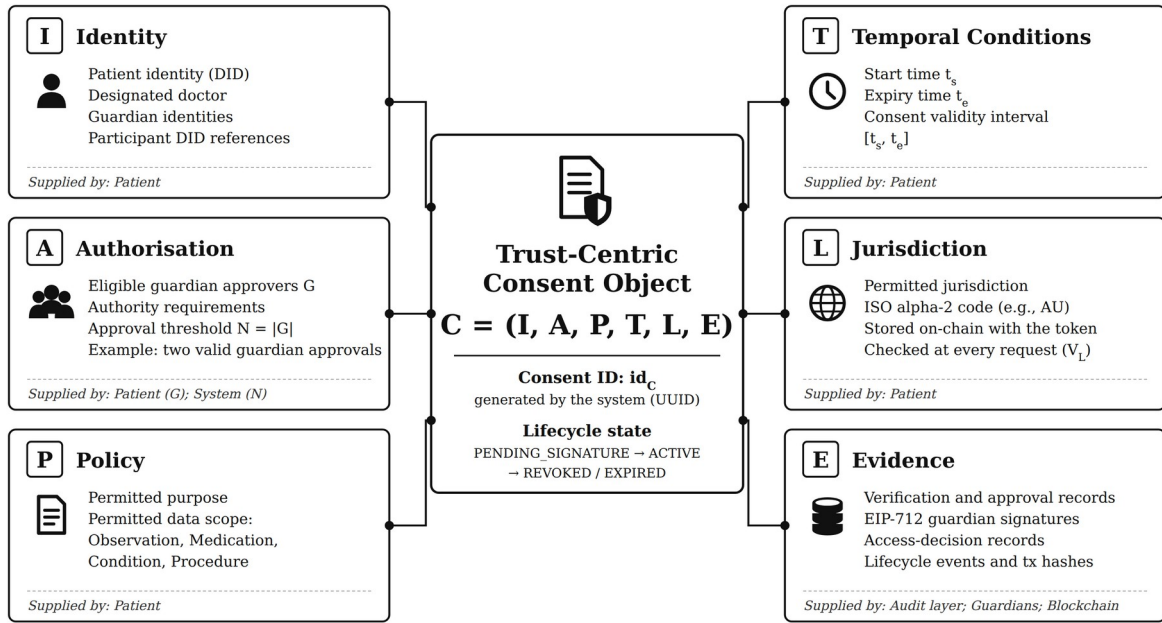


Figure 11: Six-component trust-centric consent model  $C = (I, A, P, T, L, E)$ , showing the content and the supplier of each component, the system-generated consent identifier, and the lifecycle state carried by the consent object.

The specification is accepted only when the required fields are valid. For example, the expiry time must be later than the start time. After validation, the system creates the consent object, assigns a consent identifier, persists the record, and records the creation event in the audit layer. This process ensures that the consent object contains sufficient information for subsequent identity verification, multi-party authorisation, policy evaluation, and auditability.

The declared jurisdiction  $L$  is validated as a well-formed ISO alpha-2 territory code, AU in the demonstrated transactions, and is bound to the consent object at creation. This is important because the subsequent access decision is evaluated against it. Consequently, the construction sequence becomes  $I_p \rightarrow D \rightarrow G \rightarrow P_u \rightarrow S_c \rightarrow T \rightarrow L \rightarrow A \rightarrow id_C \rightarrow C \rightarrow E$ .

### 6.1.2 Procedure for Trust-Aware Consent Creation

The Trust-Aware Consent Creation procedure establishes a valid and auditable consent object by sequentially validating the participating entities, consent purpose, data scope, and temporal constraints before the consent is persisted. The procedure consists of the following steps. 1. Step 1 - Validate Patient Identity. The system first validates the patient's identity  $I_p$ . The identity is checked against the available identity and credential verification mechanisms to ensure that the consent request originates from a recognised patient entity. If  $I_p$  cannot be successfully validated, the procedure terminates immediately and returns REJECT. 2. Step 2 - Validate the Authorised Doctor. The system validates the identity and authorisation status of the designated doctor  $D$ . This step determines whether the doctor is a recognised healthcare participant and whether the

presented credentials are sufficient for participation in the requested consent relationship. An invalid or unauthorised doctor results in rejection of the consent request.

3. Step 3 - Validate Guardian or Proxy Participants. If a guardian or proxy is specified, the system validates the guardian set  $G$ . Each guardian is checked to determine whether the individual or entity possesses the required authority to participate in consent-related decisions. This step prevents an arbitrary third party from being treated as an authorised representative of the patient.

4. Step 4 - Validate the Intended Purpose. The intended data-use purpose  $P_u$  is validated to ensure that the purpose is explicitly specified and conforms to the supported healthcare-use policies. The purpose is subsequently bound to the consent object so that authorisation is not interpreted as unrestricted access to the patient's healthcare information.

5. Step 5 - Validate the Data Scope. The requested data scope  $S_c$  is validated to determine precisely which healthcare resources may be accessed under the consent. The scope may represent specific resource categories, such as observations, medications, procedures, or other FHIR resources. This step establishes the principle of least privilege by ensuring that consent is associated with explicitly defined data resources rather than the patient's entire healthcare record.

6. Step 6 - Validate the Consent Validity Interval. The system validates the temporal validity interval  $T = (t_s, t_e)$ , where  $t_s$  represents the consent start time and  $t_e$  represents the expiration time. The system verifies that the interval is logically valid by requiring  $t_e > t_s$ . If this condition is not satisfied, the consent request is rejected.

In the current prototype this validation is a structural check that each identifier constitutes a well-formed DID. The doctor is not independently authenticated at this stage, and credential-based verification of the presented identity is deferred to the production design.

7. Step 7 - Define the Authorisation Requirement. After all input elements have been validated, the system defines the authorisation requirement  $A$ . This requirement specifies the conditions that must subsequently be satisfied before access can be granted. Depending on the system configuration,  $A$  may incorporate patient approval, guardian approval, doctor authority, role requirements, multi-party approval, scope restrictions, purpose restrictions, and temporal constraints.

8. Step 8 - Generate a Unique Consent Identifier. The system generates a unique consent identifier  $id_c$ . The identifier is not supplied by any participant: it is generated by the Consent Service at the moment the patient submits the consent, as a universally unique identifier (UUID). It is then displayed to the patient, who shares it with the designated guardians and the authorised doctor so that they can approve the consent or request access. Possession of the identifier alone grants no access, because every subsequent request is evaluated by the complete decision rule, and the on-chain token identifier is assigned separately by the smart contract only when the consent is activated. This identifier provides a persistent reference to the consent object and enables subsequent operations,

including consent verification, access authorisation, modification, revocation, and audit. 9. Step 9 – Construct the Consent Object. The validated information is combined to construct the consent object  $C = (I, A, P, T, L, E)$ , where  $I$  represents the verified identity information,  $A$  represents the authorisation requirements,  $P$  represents the consent purpose and associated permissions, and  $E$  represents the evidence associated with the consent decision. The resulting object therefore captures not only the patient’s preference but also the evidence required to support subsequent authorisation decisions. 10. Step 10 – Persist the Consent Object. The constructed consent object  $C$  is persisted in the consent-management infrastructure. The persistence mechanism provides a stable representation of the consent state that can subsequently be referenced by the access-control and authorisation components. 11. Step 11 – Record Consent Creation Evidence. Finally, the system records evidence associated with the creation event, including the consent identifier, participating entities, relevant timestamps, and the resulting consent state. This evidence provides an auditable record that can be used to reconstruct and verify the consent lifecycle. 12. Step 12 – Return the Consent Result. If all validation and construction operations are completed successfully, the system returns the newly created consent object  $C$ . If any mandatory validation fails during the process, the system terminates the procedure and returns REJECT. The overall procedure can therefore be represented as a sequential trust establishment process such that  $I_p \rightarrow D \rightarrow G \rightarrow P_u \rightarrow S_c \rightarrow T \rightarrow L \rightarrow A \rightarrow id_c \rightarrow C \rightarrow E$ . This sequence ensures that consent is created only after the relevant identity, authority, purpose, scope, and temporal constraints have been validated. Consequently, the resulting consent object serves not merely as a record of patient preference, but as a structured authorisation artefact that can provide evidence for subsequent healthcare data-access decisions.

---

**Algorithm 1** Trust-Aware Consent Creation

---

**Require:** Patient identity  $I_p$ , authorised doctor  $D$ , guardian set  $G$ , purpose  $P_u$ , data scope  $S_c$ , validity interval  $T$

**Ensure:** Consent object  $C$  or rejection

- 1: Validate  $I_p$
- 2: **if**  $I_p$  is invalid **then**
  - 3: **return** REJECT
- 4: **end if**
- 5: Validate authorised doctor  $D$
- 6: Validate guardian set  $G$
- 7: Validate purpose  $P_u$
- 8: Validate data scope  $S_c$
- 9: Validate validity interval  $T = (t_s, t_e)$
- 10: **if**  $t_e \leq t_s$  **then**
  - 11: **return** REJECT
- 12: **end if**
- 13: Define authorisation requirement  $A$
- 14: Generate consent identifier  $id_c$
- 15: Construct  $C = (I, A, P, T, L, E)$

```

16: Persist C
17: state ← PENDING_SIGNATURE ▷ nothing is anchored on-chain until all
    guardians approve
18: Record consent creation evidence
19: return C

```

---

### 6.1.3 Algorithm 1: Trust-Aware Consent Creation

Algorithm 1 formalises the creation process. The algorithm does not grant data access directly. Instead, it creates a consent object that can later be evaluated by the authorisation mechanism. This distinction is important because the research treats consent as a structured policy-bound object rather than as a simple Boolean permission. The algorithm also establishes the relationship between RO1 and the remaining objectives. RO2 uses the identity and authority information contained in I, RO3 evaluates the authorisation requirements contained in A, and RO4 evaluates the policy constraints contained in P. Consequently, RO1 provides the data structure upon which the subsequent trust-oriented authorisation mechanisms operate.

## 6.2 Decentralised Identity and Authority Trust for RO2

RO2 addresses RQ2 by developing a decentralised identity and authority verification mechanism using Decentralised Identifiers and Verifiable Credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority. The central principle of RO2 is

*Identity ≠ Authorisation.* (52)

A valid DID provides an identity reference, while a valid VC provides evidence associated with a participant's role, authority, or other relevant attribute. Neither mechanism should automatically grant access to patient data. Instead, the verified identity and authority information become inputs to the subsequent authorisation process. The identity verification condition can be expressed as

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u), \quad (53)$$

where  $u$  is the requesting participant. The DID verification process establishes whether the identity reference is valid. The VC verification process establishes whether the participant possesses valid authority evidence. The final authorisation decision remains dependent on the consent requirements and access policy.

### 6.2.1 RO2 Identity and Authority Verification Workflow

The workflow begins when a participant attempts to participate in the consent process or requests access to healthcare data. The system

resolves and verifies the participant's DID and then retrieves the associated VC. The credential is checked for validity and its claims are examined to determine whether the participant possesses the authority required by the consent. The output of RO2 is not an access-grant decision. It is a verified identity and authority result that can be consumed by RO3 and RO4. This separation prevents a participant from obtaining access merely by presenting a valid identity credential.

### **6.2.2 Procedure for DID and VC Identity and Authority Verification**

The DID and VC Identity and Authority Verification procedure determines whether a participant possesses a valid decentralised identity and sufficient verifiable authority to participate in the consent-defined authorisation process. The procedure establishes a verifiable relationship between the participant *u*, the identity information represented by the DID, the attributes contained in the associated VC, and the authority requirements specified by the consent object *C*. The procedure consists of the following steps. 1. Step 1 – Resolve the Participant's DID. The system first resolves the decentralised identifier (DID) associated with participant *u*. DID resolution retrieves the DID-related information required to establish the participant's decentralised identity and identify the corresponding DID document. If the DID cannot be successfully resolved, the verification process terminates and returns INVALID. 2. Step 2 – Verify the DID Document. After successful resolution, the system verifies the DID document and its associated identity information. The verification process determines whether the document is structurally valid and whether the relevant cryptographic information, such as verification methods and public keys, can be trusted for subsequent credential verification. A failed DID verification results in an INVALID outcome.

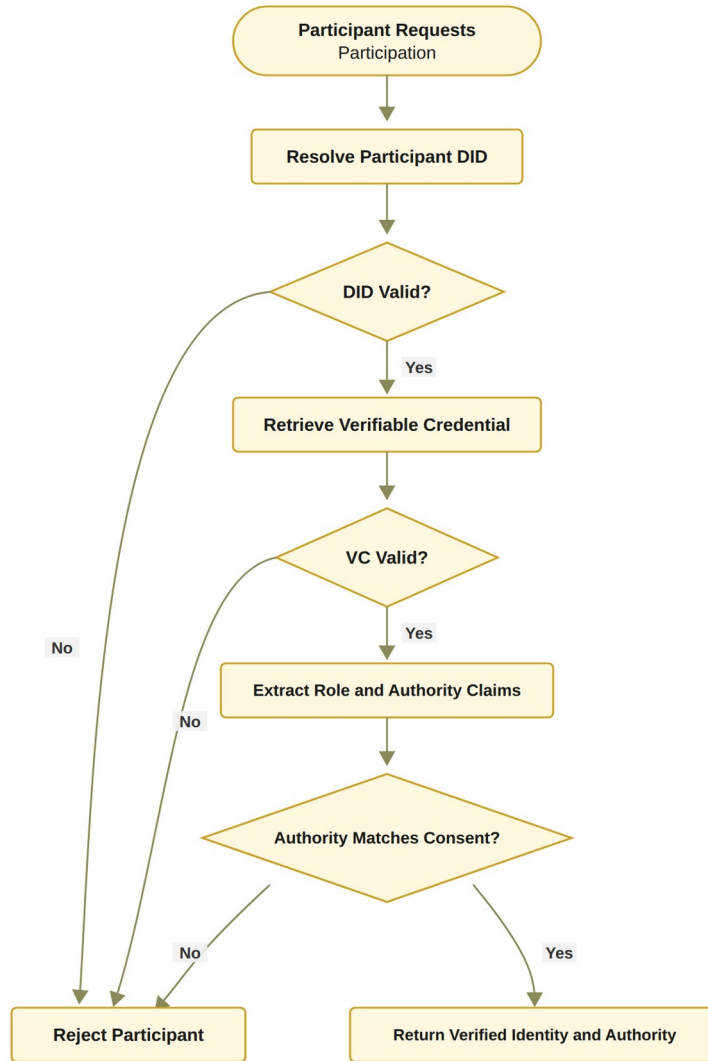


Figure 12: RO2 workflow for decentralised identity and authority verification

[Figure 12: RO2 workflow for decentralised identity and authority verification]

3. Step 3 – Retrieve the Participant’s Verifiable Credential. The system retrieves the verifiable credential (VC) associated with participant  $u$ . The VC provides machine-verifiable claims concerning the participant, such as professional role, organisational affiliation, or delegated authority. If an appropriate VC cannot be retrieved, the participant cannot establish the required authority and the verification process returns INVALID. 4. Step 4 – Verify the Verifiable Credential. In the target design the retrieved VC is cryptographically and semantically validated; the current prototype performs a structural check of the credential reference, and full cryptographic validation is specified as the production behaviour. The system verifies the credential signature, issuer, subject, and validity conditions. In particular, the system determines whether the credential was issued by an acceptable issuer, whether it refers to the current participant, whether its signature is valid, and whether the credential remains within its validity period. Formally, the credential can be considered valid only when  $VC_{\text{valid}} = \text{Sig}_{VC} \wedge \text{Issuer}_{\text{valid}} \wedge \text{Subject}_{\text{match}} \wedge$

$\text{Time}_{\text{valid}}$ . If any of these conditions fails, the verification process returns INVALID. 5. Step 5 - Extract Role and Authority Claims. Once the VC has been successfully verified, the system extracts the relevant role and authority claims associated with participant  $u$ . Depending on the healthcare scenario, these claims may identify a doctor, guardian, researcher, auditor, or another authorised participant. The extracted claims provide the evidence required for determining whether the participant satisfies the authority requirements of the consent object. 6. Step 6 - Compare Authority Claims with Consent Requirements. The extracted role and authority claims are compared against the authorisation requirements  $A$  specified in the consent object  $C$ . The purpose of this step is to ensure that possession of a valid identity or credential is not automatically interpreted as permission to access healthcare information. The authority verification condition can therefore be represented as  $\text{Authority}(u, C) = \text{Claims}(u) \models A_C$ , where  $\text{Claims}(u)$  denotes the verified claims associated with participant  $u$ , and  $A_C$  denotes the authority requirements defined by consent object  $C$ . If the participant's claims do not satisfy the required authority conditions, the system returns INVALID. 7. Step 7 - Establish Identity-Authority Binding. After the claims have satisfied the consent requirements, the system establishes the binding between the verified participant identity and the corresponding authority. This step ensures that the authority being exercised is associated with the same participant whose DID and VC have been successfully verified, thereby reducing the possibility of an unrelated credential being used to obtain access.

This condition defines the target verification model rather than the behaviour presently exercised. The current prototype implements  $V_I(u)$  as a structural DID-format check and records its outcome in the audit ledger; cryptographic validation of verifiable credentials against the four conditions above is specified here as the production behaviour and is not yet exercised by the demonstration.

8. Step 8 - Record Identity and Authority Evidence. The system records the evidence generated during the verification process. The evidence may include the resolved DID, verification status, credential identifier, issuer information, relevant authority claims, verification timestamp, and the relationship between the verified claims and the consent requirements. This evidence provides an auditable basis for subsequent access-authorisation decisions. 9. Step 9 - Return the Verification Result. If DID resolution, DID verification, VC retrieval, VC verification, and authority validation are all successfully completed, the system returns  $V_I(u) = \text{VALID}$ . Otherwise, the procedure terminates at the first failed mandatory verification condition and returns  $V_I(u) = \text{INVALID}$ . The overall verification process can therefore be represented as:  $\text{DID}_{\text{resolve}} \rightarrow \text{DID}_{\text{verify}} \rightarrow \text{VC}_{\text{retrieve}} \rightarrow \text{VC}_{\text{verify}} \rightarrow \text{Claims}_{\text{extract}} \rightarrow \text{Authority}_{\text{match}} \rightarrow \text{Evidence}_{\text{record}} \rightarrow V_I(u)$ . The procedure establishes an important separation between identity verification and authority verification. A participant is not considered valid merely because

a DID can be resolved or because a VC has a valid cryptographic signature. Instead, the participant must demonstrate that the verified credential claims satisfy the authority requirements associated with the specific consent object C. Consequently, the procedure can be interpreted as a two-layer verification mechanism  $\text{Identity}(u) \wedge \text{CredentialValidity}(u) \wedge \text{Authority}(u, C) \Rightarrow V_I(u) = \text{VALID}$ . This distinction is important for the proposed framework because a valid healthcare identity does not imply unrestricted access to healthcare data. DID and VC mechanisms provide trustworthy identity and attribute evidence, while the consent object provides the context against which those claims are evaluated. The resulting verification evidence can then be consumed by the subsequent policy, scope, and access-authorisation stages.

### 6.2.3 Algorithm 2: DID and VC Identity and Authority Verification

Algorithm 2 establishes that identity verification and authority verification are related but distinct operations. A participant may possess a valid DID while lacking the authority required by the consent. Similarly, a credential may be structurally valid but irrelevant to the specific authorisation requirement. Therefore, the algorithm verifies both credential validity and authority relevance. This mechanism contributes to the trust-oriented framework by converting identity and authority claims into verifiable evidence. However, it does not independently establish collective consent or policy compliance. Those conditions are evaluated by RO3 and RO4.

---

#### Algorithm 2 DID and VC Identity and Authority Verification

---

**Require:** Participant  $u$ , consent object  $C$

**Ensure:** Verification result  $V_I(u)$

- 1: Resolve DID of  $u$
- 2: **if** DID resolution fails **then**
  - 3: **return** INVALID
- 4: **end if**
- 5: Verify DID document and associated identity information
- 6: **if** DID verification fails **then**
  - 7: **return** INVALID
- 8: **end if**
- 9: Retrieve VC associated with  $u$
- 10: **if** VC retrieval fails **then**
  - 11: **return** INVALID
- 12: **end if**
- 13: Verify VC signature, issuer, subject, and validity
- 14: **if** VC verification fails **then**
  - 15: **return** INVALID
- 16: **end if**
- 17: Extract role and authority claims from VC
- 18: **if** claims do not satisfy the authority requirements of  $C$  **then**
  - 19: **return** INVALID
- 20: **end if**
- 21: Record identity and authority verification evidence

### 6.3 Trustworthy Multi-Party Authorisation for RO3

RO3 addresses RQ3 by developing a threshold-based multi-party authorisation mechanism. The objective is to ensure that sensitive healthcare data cannot be accessed through unilateral approval when the consent requires participation from multiple independently verified parties. Let  $A_v$  denote the set of valid approvals and let  $N$  denote the required authorisation threshold. The threshold condition is defined as

$$V_A(C) = \{ 1, |A_v| \geq N; 0, |A_v| < N \}. \quad (54)$$

The threshold mechanism establishes collective authorisation. For example, a consent may require two valid guardian approvals. In this case, one valid approval is insufficient, whereas two valid approvals satisfy the threshold.

In the current implementation the threshold is fixed to the full guardian set,  $N = |G|$ , so that every designated guardian must approve before the consent is activated; the demonstrated configuration is therefore 2-of-2. This distinction is important because a configurable k-of-n threshold, while a direct generalisation of the implemented mechanism, is left to future work.

#### 6.3.1 RO3 Multi-Party Authorisation Workflow

The workflow first identifies the participants required by the consent. Each participant must submit an approval that can be independently verified. Invalid approvals are rejected and must not contribute to the threshold count. Valid approvals are recorded and the current approval count is updated. The authorisation becomes active only when the number of valid approvals reaches the required threshold. In the HALAH implementation, the Guardian workflow verifies the guardian VC, appends the guardian DID to the consent signatures, and displays the current approval count relative to the threshold. When the threshold is reached, the implementation assigns an SBT identifier and records the corresponding minting event. The SBT should be interpreted as an activation or representation mechanism for the consent state rather than as the fundamental source of trust. The trust decision is established by the verification of participants and the satisfaction of the authorisation threshold. The blockchain or token layer provides persistence, traceability, and evidence of the resulting state.

In the HALAH implementation, the guardian's authority is evidenced by an EIP-712 typed-data signature bound to the consent identifier, the guardian DID and the Sepolia chain identifier, and verified through off-chain signer recovery. The VC verification that precedes it is presently a DID-format

check, and the signing keys are derived deterministically from the guardian DIDs in place of wallet-held keys, a substitution acknowledged as a prototype limitation.

### **6.3.2 Procedure for Threshold-Based Multi-Party Authorisation**

The Threshold-Based Multi-Party Authorisation procedure determines whether a consent-defined authorisation requirement has received sufficient valid approvals from the designated participants. Rather than relying on a single approval authority, the procedure requires a predefined number of eligible participants to independently provide valid approvals. This mechanism reduces reliance on a single decision-maker and provides an auditable basis for activating consent-related authorisation.

1. Step 1 – Retrieve the Required Participant Set. The system first retrieves the required participant set  $G$  associated with the consent object  $C$ . The set  $G$  defines which participants are eligible to contribute an approval to the authorisation process. Depending on the consent configuration,  $G$  may contain healthcare professionals, guardians, institutional representatives, or other authorised parties.

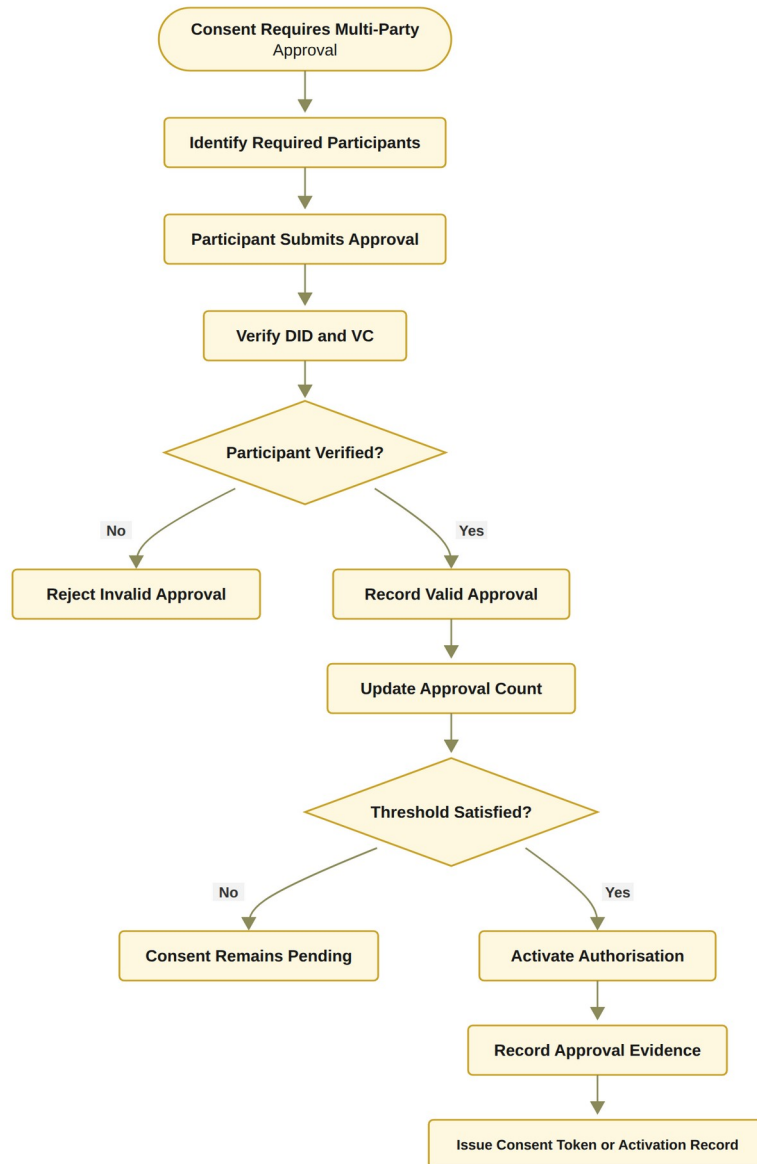


Figure 13: RO3 workflow for threshold-based multi-party authorisation

*[Figure 13: RO3 workflow for threshold-based multi-party authorisation]*

2. Step 2 - Define the Authorisation Threshold. The system obtains the threshold value  $N$ , which specifies the minimum number of valid and distinct approvals required to activate the authorisation. The threshold must satisfy  $1 \leq N \leq |G|$ . The threshold therefore determines how many eligible participants must independently approve the consent before the authorisation becomes active. 3. Step 3 - Receive a Participant Approval. A participant submits an approval  $a$  associated with consent object  $C$ . The approval is treated as a candidate authorisation contribution and is not considered valid until the identity and authority of the submitting participant have been verified. 4. Step 4 - Verify the Identity and Authority of the Approving Participant. The system verifies the identity and authority of the participant submitting  $a$ . The verification process may invoke the DID and VC verification procedure described in Algorithm 2. The system

therefore determines whether the participant possesses a valid identity and whether the associated authority claims satisfy the requirements of consent object C. If the verification fails, the approval is classified as invalid. The system records the invalid approval event and returns DENY for that approval attempt.

5. Step 5 – Verify Participant Eligibility. If the participant’s identity and authority are successfully verified, the system determines whether the participant belongs to the required participant set G. Formally,  $u \in G$ . If the participant is not a member of G, the approval cannot contribute to the threshold. The system records the event as an unauthorised approval attempt and returns DENY.

6. Step 6 – Check for Duplicate Approval. The system checks whether the participant has already approved consent object C. This prevents a single participant from submitting multiple approvals and artificially satisfying the threshold. Formally, for the valid approval set  $A_v$  that  $u \notin A_v$ . If the participant has already submitted a valid approval, the system records a duplicate approval event and rejects the additional approval.

7. Step 7 – Record the Valid Approval. If the participant is both authorised and eligible, and no previous approval from that participant exists, the system records the approval a as valid. The corresponding participant is added to the valid approval set  $A_v$ . The approval set is therefore updated according to  $A_v \leftarrow A_v \cup \{a\}$ . Each valid approval becomes an independent piece of authorisation evidence associated with consent object C.

8. Step 8 – Evaluate the Approval Threshold. The system evaluates the number of valid approvals currently associated with the consent:  $|A_v| \geq N$ . This comparison determines whether the minimum number of required participants has been reached. Importantly, only approvals that have passed identity, authority, membership, and duplicate checks are included in  $A_v$ .

9. Step 9 – Activate the Authorisation if the Threshold Is Satisfied. If  $|A_v| \geq N$ , the required threshold has been satisfied. The system activates the authorisation associated with consent object C. The activation indicates that the consent has obtained sufficient valid multi-party approval to proceed to the subsequent access-control or data-access stage.

10. Step 10 – Generate Activation Evidence. Following successful threshold satisfaction, the system generates activation or token evidence associated with the authorisation decision. The evidence may include the consent identifier, threshold value N, identities of the approving participants, approval timestamps, and the resulting authorisation state. This evidence provides a verifiable representation of how the authorisation was activated and which participants contributed to the decision.

11. Step 11 – Record the Threshold-Satisfied Event. The system records a threshold-satisfied event in the audit infrastructure. This event provides an immutable or otherwise tamper-evident record of the transition from a pending consent state to an active authorisation state.

12. Step 12 – Maintain Pending State if the Threshold Is Not Satisfied. If  $|A_v| < N$ , the consent does not yet satisfy the required multi-party authorisation condition. The system therefore maintains the consent in a PENDING state rather than activating access. The system records a threshold-pending event so that the current

authorisation state and the remaining approval requirement can be reconstructed during subsequent verification or audit.

13. Step 13 - Return the Authorisation Result. The final result is determined according to the threshold condition:  $\text{Authorisation}(C) = \{ \text{ALLOW}, |A_v| \geq N; \text{PENDING}, |A_v| < N \}$ . Invalid, unauthorised, or duplicate approval attempts are rejected and do not contribute to the valid approval count. The overall procedure can therefore be represented as:

$$G \rightarrow N \rightarrow a \rightarrow \text{Identity/Authority} \rightarrow \text{Eligibility} \rightarrow \text{Duplicate Check} \rightarrow A_v \rightarrow |A_v| \geq N \rightarrow \{ \text{ALLOW}; \text{PENDING} \} \quad (55)$$

The threshold condition can be expressed more explicitly as  $[\forall u_i \in A_v, \text{Identity}(u_i) \wedge \text{Authority}(u_i, C) \wedge (u_i \in G)] \wedge |A_v| \geq N \Rightarrow \text{Authorisation}(C) = \text{ALLOW}$ . This formulation is important because the threshold is not calculated from the number of submitted approvals alone. Instead, only valid, authorised, eligible, and non-duplicate approvals contribute to the threshold. Consequently, the procedure prevents a participant from satisfying the authorisation requirement merely by submitting multiple approvals or by presenting a valid identity without possessing the required authority. The procedure also introduces a clear distinction between approval and authorisation. An individual approval represents one participant's contribution to the decision, whereas authorisation is activated only when the collective evidence satisfies the predefined threshold. This provides a distributed decision mechanism in which no single participant necessarily has unilateral authority to activate the consent. From a trust perspective, the procedure can therefore be interpreted as

$$\text{Individual Trust Evidence} \rightarrow \text{Collective Approval Evidence} \rightarrow \text{Threshold Satisfaction} \rightarrow \text{Authorisation Activation} \quad (56)$$

### 6.3.3 Algorithm 3: Threshold-Based Multi-Party Authorisation

Algorithm 3 explicitly distinguishes between invalid, duplicate, and valid approvals. This distinction is important because simply counting submitted signatures could incorrectly treat unauthorised or repeated approvals as independent evidence. The algorithm also demonstrates why multi-party authorisation is a trust mechanism rather than merely a user-interface feature. The final decision depends on independently verified participants and a predefined collective requirement. Therefore, a single participant cannot unilaterally activate the consent when the threshold has not been satisfied. This mechanism complements the DID/VC verification procedure in Algorithm 2. Algorithm 2 establishes whether an individual participant possesses a valid identity and sufficient authority, whereas Algorithm 3 determines whether a sufficient number of independently verified participants have collectively satisfied the consent-defined authorisation requirement. The resulting activation evidence can subsequently be consumed by the policy and scope enforcement layer before healthcare data are released.

---

**Algorithm 3** Threshold-Based Multi-Party Authorisation

---

**Require:** Consent object  $C$ , participant approval  $a$

**Ensure:** Authorisation result

- 1: Retrieve required participant set  $G$
  - 2:  $N \leftarrow |G|$
  - 3:  $\text{signer} \leftarrow \text{RecoverEIP712}(\text{domain}, \{\text{id}_C, g, \text{APPROVE}\}, \text{sig}_a) \triangleright \text{off-chain recovery}$
  - 4: **if**  $\text{signer} \neq \text{Addr}(g)$ , or the signature binds a different consent, guardian, or chain **then**
    - 5: Record invalid approval
    - 6: **return** DENY
  - 7: **end if**
  - 8: **if** participant is not in  $G$  **then**
    - 9: Record unauthorised approval attempt
    - 10: **return** DENY
  - 11: **end if**
  - 12: **if** participant has already approved  $C$  **then**
    - 13: Record duplicate approval
    - 14: **return** DENY
  - 15: **end if**
  - 16: Record  $\text{signature\_data}[g] \leftarrow (\text{signer}, \text{sig}_a)$
  - 17: Update valid approval set  $A_v$
  - 18: **if**  $|A_v| \geq N$  **then**
    - 19: Activate authorisation
    - 20:  $\text{state} \leftarrow \text{PENDING\_TOKEN}$
    - 21: submit  $\text{mintConsentV3}(\text{addr}_p, \text{addr}_r, \text{keccak}(P_u), t_s, t_e, L, \text{burnAuth})$  via the owner account  $\triangleright$  background job; reconciled on next lookup
    - 22: on confirmation:  $\text{state} \leftarrow \text{ACTIVE}$ ; record the token identifier
    - 23: Record threshold-satisfied event
    - 24: **return** ACTIVATED  $\triangleright$  activation is distinct from the access decision
  - 25: **else**
    - 26: Keep consent in pending state
    - 27: Record threshold-pending event
    - 28: **return** PENDING
  - 29: **end if**
- 

## 6.4 Policy- and Context-Aware Access Control for RO4

RO4 addresses RQ4 by developing a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent. The objective is based on the observation that a valid identity and sufficient approval do not necessarily imply that every requested operation is permitted. A doctor may be a legitimate participant and may possess a valid consent, but the requested data may exceed the authorised scope or the requested purpose may not match the purpose specified by the patient. Let  $S_C$  denote the data scope authorised by the consent and  $S_R$  denote the data scope requested by the participant. The scope condition is

$$V_S(C, R) = 1 \Leftrightarrow S_R \subseteq S_C. \quad (57)$$

The policy condition can therefore be expressed as

$$V_P(C, R) = V_U(C, R) \wedge V_S(C, R), \quad (58)$$

where  $V_U(C, R)$  represents purpose compatibility and  $V_S(C, R)$  represents data-scope compatibility. The complete current-stage authorisation decision is

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L \quad (59)$$

where the five verification functions are evaluated at every access request, and the resulting decision matrix is recorded in the audit ledger together with each GRANTED or DENIED outcome.

#### 6.4.1 RO4 Policy-Aware Access Workflow

The workflow begins when a doctor submits a request for patient data. The system retrieves the relevant consent object and verifies the requesting participant. It then checks whether the required multi-party authorisation has been established. After the identity and authorisation conditions are satisfied, the system evaluates the requested purpose and data scope. A request is permitted only when the purpose is compatible with the consent and the requested data scope is contained within the authorised scope. The HALAH implementation provides a concrete basis for this objective. The Doctor interface retrieves a consent, evaluates its state, allows a requested scope to be selected from the consent scope, generates a proof, checks the requested scope, and invokes the authorisation function before returning data. For example, if

$$S_C = Observation, Medication, \quad (60)$$

and

$$S_R = Observation, Medication, Procedure, \quad (61)$$

then

$$S_R \not\subseteq S_C, \quad (62)$$

and the request must be denied. This rule prevents a legitimate participant from obtaining data outside the patient's authorised scope.

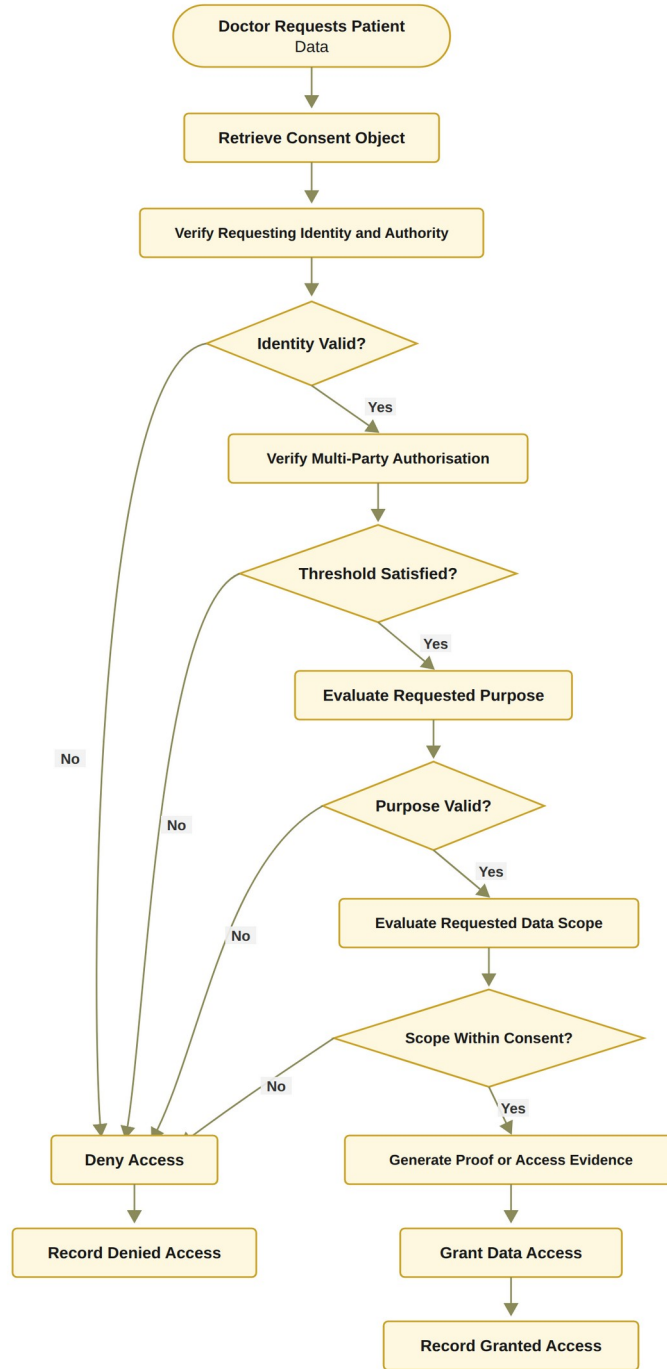


Figure 14: RO4 workflow for policy- and context-aware access control

[Figure 14: RO4 workflow for policy- and context-aware access control]

### 6.4.2 Algorithm 4: Policy-Aware Access Decision

---

#### Algorithm 4 Policy-Aware Access Decision

---

**Require:** Consent object  $C$ , access request  $R$ , requesting participant  $u$

**Ensure:** Access decision

- 1: Verify DID and VC of  $u$
- 2: **if** identity or authority verification fails **then**
- 3: Record denied decision

```

4: return DENY
5: end if
6: Evaluate consent state
7: if consent is not active then
8:   Record denied decision
9:   return DENY
10: end if
11: Verify multi-party authorisation
12: if threshold is not satisfied then
13:   Record denied decision
14:   return DENY
15: end if
16: Evaluate requested purpose
17: if purpose is incompatible with consent then
18:   Record denied decision
19:   return DENY
20: end if
21: Evaluate requested data scope
22: if  $S_R = \emptyset$  or  $S_R \not\subseteq S_C$  then
23:   Record denied decision
24:   return DENY
25: end if
26: if  $t < t_s$  or  $t > t_e$  then Record denied decision; return DENY end if
27: if  $Jur(R) \neq Jur(C)$  then Record denied decision; return DENY end if
28: Generate and verify a Groth16 proof that Poseidon(secret, expiry) equals the
   public commitment and that  $t \leq t_e$ ; record proof_mode = groth16
29: Retrieve authorised healthcare data
30: Record granted decision
31: return ALLOW

```

---

Algorithm 4 demonstrates that policy evaluation is performed after identity and multi-party authorisation verification but before data release. This ordering is important because it prevents the system from treating identity validity or collective approval as unrestricted permission.

The algorithm also establishes the connection between the proposed framework and the HALAH access-control implementation. The system must not only determine whether a consent exists, but also evaluate whether the current request satisfies the consent's scope and purpose constraints. Both granted and denied requests should be recorded to support accountability and auditability.

### 6.4.3 Procedure for Policy-Aware Access Decision

The Policy-Aware Access Decision procedure determines whether a specific healthcare data-access request should be authorised by jointly evaluating the requesting participant's identity and authority, the current consent state, the required multi-party authorisation condition, the intended purpose, and the requested data scope. Rather than treating successful authentication as sufficient for access, the procedure evaluates

the complete set of conditions defined by the consent and applicable access-control policies. The procedure consists of the following steps. 1. Step 1 - Receive and Parse the Access Request. The system receives an access request  $R$  from requesting participant  $u$ . The request specifies the healthcare resources requested by the participant and the intended purpose of access. The requested data scope is denoted by  $S_R$ , while the purpose associated with the request is denoted by  $P_R$ . The access request can therefore be represented as  $R = (u, P_R, S_R)$ . The system associates  $R$  with the relevant consent object  $C$  before continuing with the authorisation process. 2. Step 2 - Verify the Requesting Participant's DID and VC. The system verifies the DID and VC associated with participant  $u$ . This step invokes the identity and authority verification procedure defined in Algorithm 2. The system determines whether the participant possesses a valid decentralised identity and whether the associated verifiable credentials provide sufficient authority for the requested healthcare interaction. If identity or authority verification fails, the request is denied and the denial event is recorded. Formally,  $V_I(u) = \text{VALID}$  must hold before the request can proceed to the subsequent authorisation stages. 3. Step 3 - Evaluate the Current Consent State. After successful identity verification, the system evaluates the current state of consent object  $C$ . The system determines whether the consent is active and whether it remains within its defined validity period. In particular, the system verifies that the consent has not expired, been revoked, or otherwise transitioned into an inactive state. If  $\text{State}(C) \neq \text{ACTIVE}$ , the access request is denied and the decision is recorded.

4. Step 4 - Verify Multi-Party Authorisation. The system verifies whether the multi-party authorisation requirement associated with consent object  $C$  has been satisfied. The valid approval set  $A_v$  is evaluated against the required threshold  $N$ . The authorisation condition is expressed as  $|A_v| \geq N$ . If the threshold has not been satisfied, the consent cannot be used to authorise the requested access. The system therefore records a denied decision and returns DENY. 5. Step 5 - Evaluate the Requested Purpose. The system compares the purpose specified in the access request  $P_R$  with the purpose permitted by the consent object  $P_C$ . The purpose compatibility condition can be represented as  $P_R \models P_C$ , which means the requested purpose is required to satisfy the privacy constraint  $P_C$  before access can proceed. The evaluation pipeline is designed so that a request violating the privacy constraint is refused before any data is released; a formal proof of this property forms part of the next stage security analysis. If the requested purpose is incompatible with the patient's consent, the request is denied. This step prevents a participant from using otherwise valid credentials and consent to access healthcare information for a purpose that was not authorised by the patient. 6. Step 6 - Evaluate the Requested Data Scope. The system evaluates whether the requested data scope  $S_R$  is contained within the data scope authorised by the consent, denoted by  $S_C$ . The required containment relationship is  $S_R \subseteq S_C$ . If  $S_R \not\subseteq S_C$ , the requested

access exceeds the patient's authorised data scope. The system records a denied decision and returns DENY. This step is particularly important for fine-grained healthcare data access because authorisation to access one category of healthcare information does not imply authorisation to access all categories of the patient's record.

7. Step 7 - Evaluate the Complete Authorisation Policy. After the individual conditions have been successfully evaluated, the system performs the final policy evaluation. The decision is based on the conjunction of identity validity, active consent, sufficient multi-party approval, purpose compatibility, and scope containment. The overall authorisation condition can be represented as  $\text{Authorised}(R, C, u) = V_I(u) \wedge \text{Active}(C) \wedge (|A_v| \geq N) \wedge \text{PurposeMatch}(P_R, P_C) \wedge \text{ScopeMatch}(S_R, S_C)$ . Access can proceed only when all required conditions evaluate to true.

8. Step 8 - Generate or Verify Access Evidence. If the policy evaluation succeeds, the system generates or verifies the evidence supporting the access decision. The evidence may include the consent identifier, requesting participant DID, relevant VC claims, consent state, approval threshold, approving participants, requested purpose, requested scope, and decision timestamp. This evidence provides an auditable relationship between the access request and the conditions that justified the resulting authorisation.

9. Step 9 - Retrieve the Authorised Healthcare Data. Once the request has been successfully authorised, the system retrieves only the healthcare data satisfying the authorised scope  $S_R$ . The retrieval operation must enforce the same scope constraints that were evaluated during the policy decision. Thus,  $\text{Data}_{\text{returned}} \subseteq S_C$ . This prevents a mismatch between the policy decision and the actual data returned to the requester.

10. Step 10 - Record the Granted Decision. The system records the successful access-authorisation event. The recorded evidence may include the request identifier, consent identifier, requester identity, authorised purpose, authorised data scope, authorisation result, and relevant timestamp. The resulting event provides an auditable record of why and under which conditions access was granted.

11. Step 11 - Return the Final Access Decision. If all mandatory conditions have been satisfied, the system returns  $\text{AccessDecision} = \text{ALLOW}$ . If any mandatory condition fails during the evaluation process, the system records the corresponding denial evidence and returns  $\text{AccessDecision} = \text{DENY}$ . The overall decision process can therefore be represented as  $R \rightarrow \text{DID/VC} \rightarrow \text{Consent State} \rightarrow \text{Threshold} \rightarrow \text{Purpose} \rightarrow \text{Scope} \rightarrow \text{Policy Eval.} \rightarrow \text{Evidence} \rightarrow \text{Data Retr.} \rightarrow \{ \text{ALLOW}; \text{DENY} \}$

In the implemented system the approval threshold is N-of-N:  $N = |G|$ , so that every designated guardian must sign, and the evaluated configuration is accordingly 2-of-2. Consequently, a configurable k-of-n threshold remains an item of future work rather than a property of the demonstrated prototype.

In the demonstrated prototype, purpose compatibility is evaluated as an exact match against the consent purpose, which is stored on-chain as

keccak256(purpose). Therefore, a formal proof that no execution path can violate the privacy policy is deliberately left to future work.

The final access decision can be formally expressed as  $\text{ALLOW} \Leftarrow \text{Identity} \wedge \text{Consent} \wedge \text{Authority} \wedge \text{Threshold} \wedge \text{Purpose} \wedge \text{Scope} \wedge \text{Evidence}$  where the individual conditions represent verified participant identity, active consent, sufficient authority, satisfied multi-party approval, compatible purpose, authorised data scope, and sufficient decision evidence, respectively. This procedure establishes an important distinction between authentication, consent, and authorisation. A successfully authenticated participant is not automatically granted access. Instead, authentication provides identity evidence, consent provides patient-defined permission constraints, multi-party approval provides distributed authority evidence, and policy evaluation determines whether the particular request satisfies all applicable conditions. The procedure also implements the principle of least privilege through the explicit scope-containment condition that  $S_R \subseteq S_C$ . Consequently, even when a participant possesses a valid DID, a valid VC, and sufficient authority, the participant cannot retrieve healthcare resources outside the scope explicitly authorised by the consent. Similarly, a valid consent cannot be used for an incompatible purpose or before the required multi-party authorisation threshold has been reached. From an architectural perspective, Algorithm 4 therefore acts as the final policy-enforcement layer of the proposed authorisation lifecycle. Algorithm 1 establishes the consent constraints, Algorithm 2 establishes trustworthy identity and authority evidence, and Algorithm 3 establishes collective authorisation evidence. Algorithm 4 integrates these evidence sources with the specific access request and determines whether the requested healthcare data can actually be released. The resulting end-to-end authorisation lifecycle can be summarised as

*Consent Creation  $\rightarrow$  Identity Verification  $\rightarrow$  Multi-Party Auth  $\rightarrow$  Policy Decision*

This architecture transforms healthcare data access from a simple credential-based permission check into an evidence-based authorisation process in which identity, consent, authority, distributed approval, purpose, scope, and audit evidence jointly determine the final access decision.

## 6.5 Temporal and Lifecycle Trust for RO5

RO5 addresses RQ5 and extends the foundational current-stage authorisation model with temporal validity and consent lifecycle controls. This objective belongs primarily to CA3 because it investigates how an authorisation remains trustworthy as time passes and as the consent state changes. The current stage model evaluates identity, collective authorisation, and policy compliance. RO5 extends this model by introducing temporal and lifecycle conditions that

$$V_T(C, t) = 1, t_s \leq t \leq t_e; 0, \text{ otherwise.} \quad (63)$$

The lifecycle condition can be expressed as

$$V_L(C, R) = 1 \Leftrightarrow Jur(R) = Jur(C) \vee Jur(C) = \emptyset \quad (64)$$

where  $Jur(\cdot)$  denotes the jurisdiction attribute, recorded on-chain as a two-letter ISO code, and where lifecycle state and revocation are evaluated within  $V_A$  rather than within this predicate. This is important because it is precisely this check that produced the demonstrated denial in which a request declaring jurisdiction SA was refused against a consent issued for AU.

The extended authorisation decision is therefore

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (65)$$

The purpose of RO5 is not simply to add an expiry field. It is to ensure that the validity of a consent depends on both its temporal interval and its current lifecycle state. A consent that has expired or been revoked must not remain usable merely because its original approval threshold was satisfied.

### 6.5.1 RO5 Temporal and Lifecycle Workflow

Temporal and lifecycle enforcement is implemented in the demonstrated prototype. In particular, the Consent Engine evaluates  $t_s \leq t \leq t_e$  at every access request, the deployed contract stores the `notBefore` and `expiry` fields and exposes the `checkValid` and `checkValidAt` functions, and revocation is executed both in the application state and as an on-chain `revoke` transaction confirmed in block 11,771,307.

The implemented workflow evaluates the consent's temporal interval, lifecycle state, and revocation status before the system proceeds with the remaining authorisation conditions. This design ensures that a consent is not treated as permanently valid after it has expired or entered a state that no longer permits access.

### 6.5.2 Procedure for Temporal and Lifecycle Validation

The Temporal and Lifecycle Validation procedure determines whether a consent object remains temporally valid and whether the requested operation is permitted under its current lifecycle state. Unlike static authorisation checks, this procedure explicitly considers the temporal validity, revocation status, and state-transition rules of the consent object. It therefore ensures that a previously valid consent cannot be treated as permanently valid after expiration, revocation, or an unauthorised lifecycle transition.

1. Step 1 – Retrieve the Consent Validity Interval. The system retrieves the start time  $t_s$  and expiry time  $t_e$  associated with consent object  $C$ . These temporal attributes define the period during which the consent is potentially valid. The consent validity interval is represented as  $T_C = [t_s, t_e]$ . The system uses the current time  $t$  to determine whether the consent is currently within its defined validity period.
2. Step 2 – Validate the Current

Time. The system compares the current time  $t$  with the consent validity interval. Temporal validity requires  $t_s \leq t \leq t_e$ . If  $t < t_s$  or  $t > t_e$ , the consent is considered temporally invalid. The system records the temporal invalidity evidence and returns INVALID. This step prevents a consent from being used before its effective start time or after its expiration time.

3. Step 3 – Retrieve the Current Lifecycle State. If the temporal condition is satisfied, the system retrieves the current lifecycle state of consent object  $C$ . Typical lifecycle states may include CREATED, PENDING, ACTIVE, SUSPENDED, REVOKED, and EXPIRED, depending on the system configuration. The current state is used to determine whether the requested operation can legally and logically be performed.

4. Step 4 – Validate State-Dependent Operations. The system evaluates whether the current lifecycle state permits the requested operation  $q$ . Different operations may be permitted only in specific lifecycle states. For example, activation may require a consent to be in a pending state, while data access may require the consent to be active.

The implemented lifecycle states are PENDING\_SIGNATURE, PENDING\_TOKEN, NOT\_STARTED, ACTIVE, EXPIRED and REVOKED.

The state transition condition can be represented as  $\text{State}(C) \models q$ . If the current state does not permit operation  $q$ , the system records an invalid lifecycle-state event and returns INVALID.

5. Step 5 – Check Revocation Status. The system explicitly checks whether consent object  $C$  has been revoked. Revocation represents a deliberate termination of the previously granted consent and must therefore override an otherwise valid temporal interval. Formally,  $\text{Revoked}(C) = \text{false}$  must hold for the consent to remain usable. If  $\text{Revoked}(C) = \text{true}$ , the system records revocation-based invalidity and returns INVALID.

6. Step 6 – Validate the Requested Lifecycle Transition. If the consent is temporally valid, in an appropriate lifecycle state, and has not been revoked, the system validates the requested transition  $q$ . The transition is evaluated against the predefined lifecycle-transition policy:  $\text{State}(C) \rightarrow^q \text{State}'(C)$ . The transition is valid only when  $q$  is explicitly permitted from the current state. If the transition is not permitted, the system records an unauthorised state-transition event and returns INVALID.

7. Step 7 – Establish Temporal and Lifecycle Consistency. After all individual checks have succeeded, the system establishes that the consent is simultaneously valid in terms of time, lifecycle state, revocation status, and requested transition. The overall lifecycle-validity condition can therefore be expressed as  $V_s(C, t, q) = \text{TimeValid}(C, t) \wedge \text{StateValid}(C, q) \wedge \neg \text{Revoked}(C) \wedge \text{TransitionValid}(C, q)$ . Only when all four conditions are satisfied can the consent proceed to the subsequent operation.

8. Step 8 – Record Temporal and Lifecycle Evidence. The system records evidence associated with the successful validation. The evidence may include the consent identifier, current timestamp, validity interval, current lifecycle state, revocation status, requested transition, and validation result. This evidence establishes an auditable relationship between the consent's lifecycle state and the

operation performed at a particular point in time. Here  $V_s$  denotes the composite temporal-state predicate evaluated by this procedure; it is distinct from the jurisdictional predicate  $V_L(C)$  of the decision rule, which is evaluated separately.

9. Step 9 - Return the Lifecycle Validation Result. If all temporal and lifecycle conditions are satisfied, the system returns  $V_s(C, t, q) = \text{VALID}$ . If any mandatory condition fails, the procedure returns  $V_s(C, t, q) = \text{INVALID}$ . The overall validation process can therefore be represented as  $C \rightarrow T_c \rightarrow t \rightarrow \text{State}(C) \rightarrow \text{Revocation} \rightarrow q \rightarrow \text{Lifecycle Validation} \rightarrow \text{Evidence} \rightarrow \{ \text{VALID}; \text{INVALID} \}$ . The complete lifecycle-validity condition can be summarised as  $\text{VALID} \iff (t_s \leq t \leq t_e) \wedge \text{State}(C) \models q \wedge \neg \text{Revoked}(C) \wedge \text{TransitionPermitted}(q)$ . This procedure establishes that consent validity is not a static property. Instead, the validity of consent is a function of both time and lifecycle state that  $\text{Validity}(C) = f(t, \text{State}(C), \text{Revocation}(C))$ . Consequently, a consent that was valid at time  $t_1$  may become invalid at a later time  $t_2$  because it has expired, been revoked, suspended, or otherwise transitioned into a state that does not permit the requested operation. The explicit lifecycle validation also introduces an important distinction between consent existence and consent usability. The existence of a consent record in the system does not imply that the consent remains effective. Similarly, a consent that has successfully passed identity and authority verification may still be unusable if its validity period has expired or if it has subsequently been revoked. This temporal property can be represented as:  $\text{ConsentExists}(C) \neq \text{ConsentUsable}(C, t)$ . Instead,  $\text{ConsentUsable}(C, t) \Rightarrow \text{TimeValid}(C, t) \wedge \text{StateValid}(C) \wedge \neg \text{Revoked}(C)$ . The procedure therefore provides the lifecycle control required to connect the initial consent creation process with subsequent access decisions. Algorithm 1 establishes the consent object and its validity interval, Algorithm 2 verifies the identity and authority of participating entities, Algorithm 3 establishes multi-party approval, and Algorithm 4 evaluates the specific access request. Algorithm 5 complements these mechanisms by ensuring that the consent and its associated authorisation remain valid throughout their operational lifecycle. From the perspective of the overall HALAH architecture, the overall flow can therefore be summarised as  $\text{Consent} \rightarrow \text{Identity} \rightarrow \text{Authority} \rightarrow \text{Policy} \rightarrow \text{Temporal/Lifecycle Validation} \rightarrow \text{Access}$

the lifecycle validation mechanism can therefore be interpreted as a per-request validity layer: validity is re-established at each evaluated access request and recorded as a `STATE_CHECK` event in the audit ledger, rather than being assumed to persist between requests.

Rather than treating authorisation as a one-time event, this approach enables the system to determine whether authorisation remains valid at the precise time an operation is requested. This is particularly important for dynamic consent environments in which permissions may expire, be revoked, suspended, renewed, or otherwise modified during the lifecycle of a healthcare data-sharing relationship.

### 6.5.3 Algorithm 5: Temporal and Lifecycle Validation

---

**Algorithm 5** Temporal and Lifecycle Validation

---

**Require:** Consent object  $C$ , current time  $t$ , requested transition  $q$

**Ensure:** Lifecycle validity result

- 1: Retrieve consent start time  $t_s$  and expiry time  $t_e$
  - 2: **if**  $t < t_s$  or  $t > t_e$  **then**
  - 3:   Record temporal invalidity
  - 4:   **return** INVALID
  - 5: **end if**
  - 6: Retrieve current lifecycle state of  $C$
  - 7: **if** current state does not permit the requested operation **then**
  - 8:   Record invalid lifecycle state
  - 9:   **return** INVALID
  - 10: **end if**
  - 11: Check whether  $C$  has been revoked
  - 12: **if**  $C$  is revoked **then**
  - 13:   Record revocation-based invalidity
  - 14:   **return** INVALID
  - 15: **end if**
  - 16: Validate requested transition  $q$
  - 17: **if** transition  $q$  is not permitted **then**
  - 18:   Record unauthorised state transition
  - 19:   **return** INVALID
  - 20: **end if**
  - 21: Record valid temporal and lifecycle evidence
  - 22: **return** VALID
- 

Algorithm 5 is implemented in the current prototype. Its checks are executed at every access request and recorded as STATE\_CHECK events in the audit ledger, so that expiration, revocation and controlled state transitions already condition the demonstrated access decisions rather than awaiting a later implementation stage.

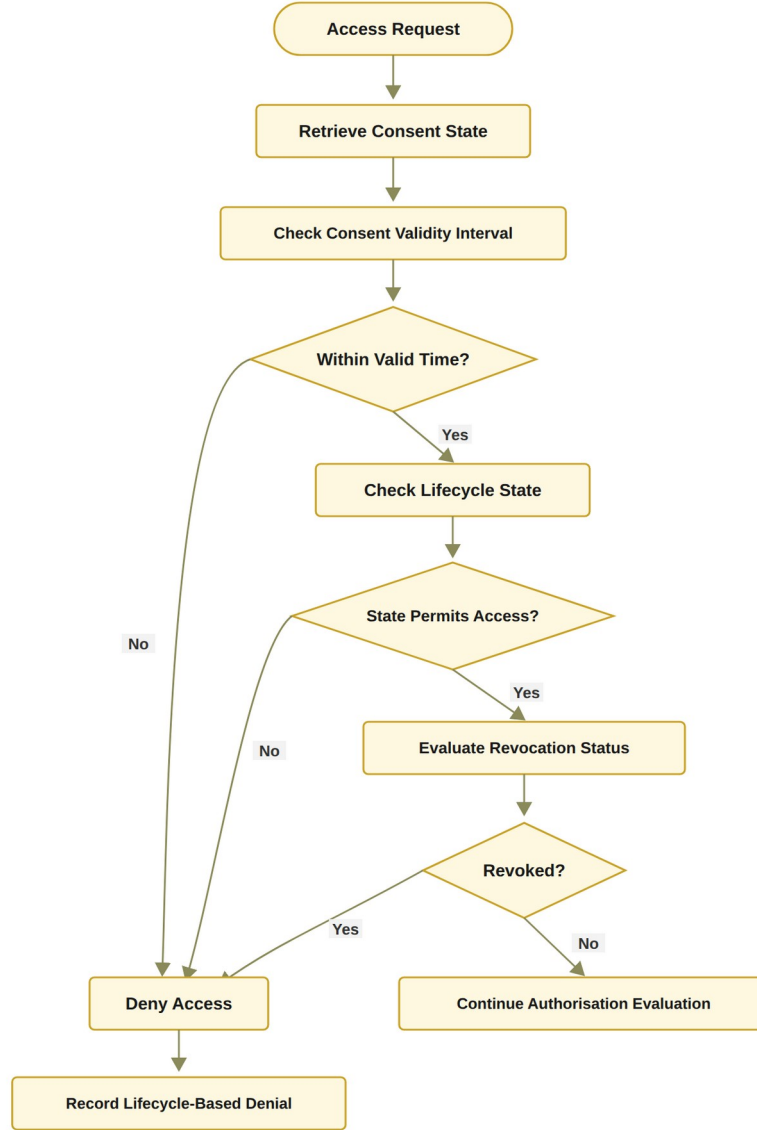


Figure 15: RO5 workflow for temporal and consent lifecycle trust

*[Figure 15: RO5 workflow for temporal and consent lifecycle trust]*

Algorithm 5 extends the current-stage decision process by ensuring that consent validity is dynamic rather than permanent.

## 6.6 Formal Security Assurance and Empirical Validation for RO6

RO6 addresses RQ6 by formally analysing and empirically evaluating whether the proposed trust-oriented authorisation framework satisfies its defined security and authorisation properties. The objective combines two complementary forms of assurance. Formal security assurance specifies the conditions under which the authorisation mechanism should be considered secure and consistent. Empirical validation evaluates whether the implemented system behaves according to those conditions under

representative healthcare data-sharing scenarios. The formal decision model is expressed as

The empirical half of this objective has been carried out on the demonstrated prototype, whereas formal proofs and model checking of the authorisation properties remain future work. Figure 16 accordingly presents the RO6 workflow for security assurance, in which the empirical branch has been executed and the formal branch remains planned.

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (66)$$

$Decision(C, R) = ALLOW \Rightarrow V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L$ , where this soundness property is the one actually validated: each conjunct is exercised by a dedicated per-dimension failure test that confirms access is denied when that predicate alone fails.

$$Decision(C, R) = ALLOW \Rightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R). \quad (67)$$

This implication expresses the soundness requirement that every granted request must satisfy the identity, authorisation, and policy conditions. Conversely, if any mandatory condition is violated, the request must be denied:

$$\neg V_I(u) \vee \neg V_A(C) \vee \neg V_P(C, R) \Rightarrow Decision(C, R) = DENY. \quad (68)$$

### 6.6.1 RO6 Assurance and Validation Workflow

The validation process begins by defining the security and authorisation properties that the framework is expected to satisfy. These properties include identity validity, threshold correctness, policy compliance, denial of unauthorised requests, and consistency between the authorisation decision and the audit evidence. The HALAH prototype provides the implementation basis for this evaluation. The current system includes separate patient, guardian, doctor, and auditor interfaces. It also records consent creation, guardian approval, token minting, state checks, and data-access events.

### 6.6.2 Procedure for Formal and Empirical Authorisation Validation

The Formal and Empirical Authorisation Validation procedure evaluates whether the proposed framework  $F$  correctly implements the intended authorisation model under normal, invalid, and adversarial conditions. Rather than validating the framework only through successful

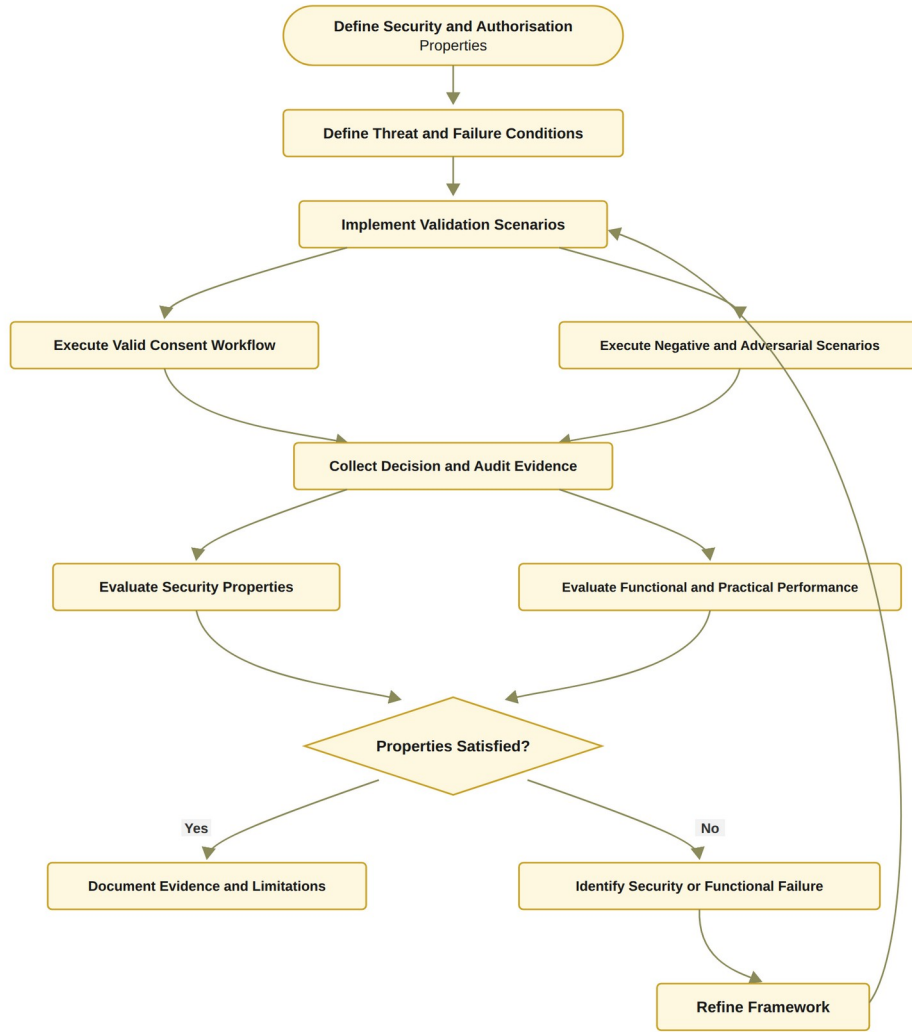


Figure 16: RO6 workflow for formal security assurance and empirical validation

[Figure 16: RO6 workflow for formal security assurance and empirical validation]

execution cases, the procedure systematically evaluates both positive and negative behaviours and examines whether observed authorisation decisions are consistent with the formally defined security properties. The procedure therefore combines scenario-based empirical testing with property-oriented validation of authorisation correctness, denial behaviour, threshold enforcement, policy and scope compliance, and audit consistency.

1. Step 1 - Define the Expected Authorisation Properties. The first step is to define the security and authorisation properties  $P$  that the framework is expected to satisfy. These properties provide the formal evaluation criteria against which the observed system behaviour will subsequently be compared. The properties may include authorisation soundness, correct denial of unauthorised requests, threshold correctness, policy compliance, scope enforcement, temporal consistency, and audit consistency. Formally,  $P = \{P_{\text{sound}}, P_{\text{deny}}, P_{\text{threshold}}, P_{\text{policy}}, P_{\text{scope}}, P_{\text{audit}}\}$ .

2. Step 2 - Define Valid Scenarios. The system defines a set of valid scenarios  $S_{\text{valid}}$ , representing legitimate healthcare data-access workflows. These

scenarios should contain valid patient identities, valid credentials, active consent, sufficient authority, satisfied multi-party approval, compatible purposes, and authorised data scopes. The purpose of these scenarios is to verify that legitimate requests are successfully authorised and that the framework does not incorrectly reject valid operations. 3. Step 3 - Define Negative Scenarios. The system defines a set of negative scenarios  $S_{\text{negative}}$ , representing requests that violate one or more authorisation conditions. Examples include invalid identities, expired consent, revoked consent, insufficient approval, unauthorised roles, incompatible purposes, and requests for data outside the consent scope. These scenarios test whether the framework correctly prevents access when an authorisation requirement is not satisfied. 4. Step 4 - Define Adversarial Scenarios. The system defines adversarial scenarios  $S_{\text{adv}}$ , representing attempts to circumvent or manipulate the authorisation process. Such scenarios may include replayed approvals, duplicate approvals, unauthorised participants attempting to satisfy a threshold, invalid or forged credentials, attempts to access data outside the authorised scope, and attempts to use a revoked or expired consent object. The adversarial test set is particularly important because a framework should not only demonstrate that legitimate requests succeed, but also demonstrate resilience against foreseeable attempts to bypass its security controls. 5. Step 5 - Construct the Complete Validation Scenario Set. The three scenario classes are combined into the complete validation set:  $S = S_{\text{valid}} \cup S_{\text{negative}} \cup S_{\text{adv}}$ .

Each scenario  $s \in S$  is associated with an expected authorisation outcome and the security properties that it is intended to evaluate. 6. Step 6 - Execute Each Scenario Using the Framework. The system executes each scenario  $s$  using the implemented framework  $F$ . During execution, the framework performs the corresponding consent, identity, authority, threshold, policy, scope, and lifecycle checks. The execution process is treated as an empirical observation of the implemented authorisation model that  $F(s) \rightarrow D_{\text{obs}}$ , where  $D_{\text{obs}}$  denotes the observed authorisation decision. 7. Step 7 - Collect the Observed Authorisation Decision. After each scenario has been executed, the system records the resulting authorisation decision. Depending on the operation, the observed result may be ALLOW, DENY, PENDING, or another explicitly defined lifecycle state. The observed decision is stored together with the corresponding scenario identifier to enable subsequent comparison with the expected outcome. 8. Step 8 - Collect Supporting Authorisation Evidence. In addition to the final decision, the system collects the evidence generated during the authorisation process. This evidence may include identity verification results, VC validation results, participant approvals, threshold status, consent state, purpose evaluation, scope evaluation, timestamps, and audit records. The collected evidence can therefore be represented as  $E_s = \{E_i, E_A, E_C, E_T, E_P, E_S, E_L\}$ , where the individual components represent identity, authority, consent, threshold, policy, scope, and lifecycle

evidence. 9. Step 9 - Compare Observed and Expected Decisions. The observed decision is compared with the expected decision defined for scenario  $s$ . Let  $D_{\text{exp}}(s)$  denote the expected decision and  $D_{\text{obs}}(s)$  denote the observed decision. The scenario passes when  $D_{\text{obs}}(s) = D_{\text{exp}}(s)$ . Otherwise, the scenario is classified as a validation failure.

10. Step 10 - Record the Scenario Result. The system records whether each scenario has passed or failed. For each failure, the corresponding condition, observed behaviour, expected behaviour, and supporting evidence are retained for subsequent analysis. This enables validation results to be traced from the final decision back to the individual authorisation conditions that produced that decision. 11. Step 11 - Evaluate Authorisation Soundness. The system evaluates the soundness property to determine whether every granted request satisfies the required authorisation conditions. Formally,  $D_{\text{obs}}(s) = \text{ALLOW} \Rightarrow \text{Authorised}(s) = \text{TRUE}$ . A sound framework should not grant access when one or more mandatory authorisation conditions are violated. 12. Step 12 - Evaluate Denial Correctness. The system evaluates whether invalid or unauthorised requests are correctly denied. The denial property can be represented as  $\text{Authorised}(s) = \text{FALSE} \Rightarrow D_{\text{obs}}(s) \neq \text{ALLOW}$ . This evaluation is particularly important for negative and adversarial scenarios because successful operation under valid conditions alone cannot demonstrate that unauthorised access is reliably prevented. 13. Step 13 - Evaluate Threshold Correctness. The system evaluates whether multi-party authorisation is activated only when the required threshold condition is satisfied. The expected threshold property is  $\text{Authorisation}(C) = \text{ALLOW} \Rightarrow |A_v| \geq N$ . The evaluation should also verify that invalid, duplicate, or unauthorised approvals do not contribute to  $A_v$ . This ensures that the threshold cannot be artificially satisfied by repeated or illegitimate approval submissions. 14. Step 14 - Evaluate Policy and Scope Enforcement. The system evaluates whether every granted request satisfies the consent-defined policy and data-scope constraints. In particular, the scope enforcement property is  $D_{\text{obs}}(s) = \text{ALLOW} \Rightarrow S_R \subseteq S_C$ .

The evaluation should verify that a participant cannot obtain healthcare resources outside the scope authorised by the patient's consent, even when the participant possesses a valid identity and authority credential. Purpose compatibility is evaluated similarly:  $D_{\text{obs}}(s) = \text{ALLOW} \Rightarrow P_R \models P_C$ . 15. Step 15 - Evaluate Audit Consistency. The system evaluates whether the recorded audit evidence is consistent with the actual authorisation decision and the underlying verification events. For an access event  $e$ , the audit record should provide sufficient evidence to establish a relationship between the request, requester, consent, policy evaluation, authorisation result, and timestamp. Therefore,  $\text{Audit}(e) \models \text{Decision}(e)$ . An audit inconsistency occurs when the recorded evidence does not correspond to the actual system decision or when critical authorisation evidence is missing. 16. Step 16 - Analyse Failures and Limitations. Any failed scenario is analysed to determine the source and significance of the

failure. The analysis distinguishes between implementation defects, policy-definition errors, integration problems, incomplete security controls, and limitations of the experimental environment. The purpose of this step is not to conceal unsuccessful cases but to determine whether observed failures represent violations of the intended security properties or limitations that should be addressed in future work. 17. Step 17 - Consolidate the Validation Results. Finally, the individual scenario results and property-level evaluations are consolidated into an overall validation result. The resulting evidence includes:  $V = \{R_{\text{scenario}}, R_{\text{sound}}, R_{\text{deny}}, R_{\text{threshold}}, R_{\text{policy}}, R_{\text{scope}}, R_{\text{audit}}\}$ . The framework is considered empirically consistent with the specified authorisation model when the observed decisions satisfy the expected outcomes across the defined validation scenarios and no critical security property is violated. The overall validation process can therefore be represented as

$$P \rightarrow S_{\text{valid}} \cup S_{\text{negative}} \cup S_{\text{adv}} \rightarrow F(s) \rightarrow D_{\text{obs}} \rightarrow E_s \rightarrow D_{\text{obs}} \stackrel{?}{=} D_{\text{exp}} \rightarrow \text{Property Evaluation} \rightarrow \text{Failure Analysis} \rightarrow \text{Validation Evidence}$$

The fundamental scenario-level validation criterion is  $\text{Pass}(s) \iff D_{\text{obs}}(s) = D_{\text{exp}}(s)$  while the framework-level validation can be expressed as:  $\text{Valid}(F) \Rightarrow P_{\text{sound}} \wedge P_{\text{deny}} \wedge P_{\text{threshold}} \wedge P_{\text{policy}} \wedge P_{\text{scope}} \wedge P_{\text{audit}}$ . This procedure establishes a distinction between functional correctness and security correctness. A system may successfully execute an access request and return data without necessarily demonstrating that the request should have been authorised. The proposed validation therefore does not treat successful execution as sufficient evidence of correctness. Instead, the observed decision must be consistent with the formally specified authorisation conditions. The use of three complementary scenario classes is particularly important. Valid scenarios establish that legitimate users can obtain authorised access, negative scenarios establish that invalid requests are correctly rejected, and adversarial scenarios examine whether security controls can resist deliberate attempts to circumvent the authorisation process. Together, these scenarios provide a more balanced evaluation of both the positive security property of granting legitimate access and the negative security property of preventing illegitimate access. The validation procedure also provides traceability between the final access decision and its supporting evidence. For each scenario, the decision can be interpreted as:  $\text{Decision}(s) = f(\text{Identity}, \text{Authority}, \text{Consent}, \text{Threshold}, \text{Purpose}, \text{Scope}, \text{Lifecycle}, \text{Evidence})$ . Consequently, validation does not merely determine whether the final output is ALLOW or DENY ; it also determines whether the underlying evidence is consistent with the decision. This is particularly important for a trust-aware framework because a correct decision without sufficient supporting evidence cannot provide strong assurance regarding how the decision was reached. The relationship between the six algorithms can therefore be represented as Algorithm 1 : Create Consent Algorithm 2 : Verify Identity and Authority Algorithm 3 : Establish Multi-Party Authorisation Algorithm 4 : Evaluate Access Request Algorithm 5 : Validate Temporal and Lifecycle State Algorithm 6 : Validate

the Complete Framework Algorithm 6 therefore operates at the highest level of the proposed methodology. Algorithms 1–5 define the operational authorisation lifecycle, whereas Algorithm 6 evaluates whether the complete lifecycle behaves according to its intended security properties. This creates a closed methodological loop Design → Implementation → Execution → Observation → Verification → Validation The resulting validation methodology provides empirical evidence that the proposed authorisation model is not merely conceptually defined but is operationally enforceable and testable under legitimate, invalid, and adversarial conditions.

---

**Algorithm 6** Formal and Empirical Authorisation Validation

---

**Require:** Framework implementation  $F$ , validation scenarios  $S$ , security properties  $P$

**Ensure:** Validation evidence and evaluation results

- 1: Define expected authorisation properties  $P$
  - 2: Define valid scenarios  $S * \text{valid}$
  - 3: Define negative scenarios  $S * \text{negative}$
  - 4: Define adversarial scenarios  $S * \text{adv}$
  - 5: **for** each scenario  $s$  in  $S * \text{valid} \cup S * \text{negative} \cup S * \text{adv}$  **do**
    - 6: Execute  $s$  using framework  $F$
    - 7: Collect authorisation decision
    - 8: Collect identity, approval, policy, and audit evidence
    - 9: Compare observed decision with expected decision
    - 10: Record pass or failure result
  - 11: **end for**
  - 12: Evaluate soundness property
  - 13: Evaluate denial property
  - 14: Evaluate threshold correctness
  - 15: Evaluate policy-scope enforcement
  - 16: Evaluate audit consistency
  - 17: Analyse failures and limitations
  - 18: **return** Validation results
- 

### 6.6.3 Algorithm 6: Formal and Empirical Authorisation Validation

Algorithm 6 provides a structured method for evaluating the framework. It does not assume that successful execution of a consent workflow is sufficient evidence of security. Instead, it requires the system to demonstrate that invalid conditions produce appropriate denial decisions and that the recorded evidence is consistent with the decision. The formal and empirical components are complementary. Formal reasoning defines what the framework should guarantee, while empirical testing examines whether the implementation satisfies those guarantees in representative operational scenarios. This combination is necessary because a system may be conceptually correct but incorrectly implemented, or may pass functional tests while failing under invalid or adversarial conditions.

## 6.7 Algorithms and the Research Objectives

The six algorithms correspond directly to the six research objectives and provide a progressive development structure for the proposed framework. Algorithm 1 establishes the consent representation, while Algorithm 2 verifies the identity and authority information contained in that representation. Algorithm 3 then establishes collective authorisation through independently verified approvals. Algorithm 4 evaluates whether a specific access request satisfies the consent policy before healthcare data are released. The final two algorithms extend this foundational mechanism. Algorithm 5 introduces temporal and lifecycle validity, while Algorithm 6 provides formal and empirical assurance of the complete framework. This structure reflects the staged research design in which current stage establishes the foundational authorisation mechanisms and CA3 investigates their

dynamic validity, security assurance, and comprehensive practical effectiveness. The overall trust-oriented authorisation process can therefore be summarised as Trustworthy Access with 1) Identity Trust, 2) Authority Trust, 3) Collective Authorisation, 4) Policy Compliance, 5) Temporal and Lifecycle Trust. For the current stage implementation, the operational decision is based on

Algorithms 1-5 are all realised in the current prototype, and the empirical branch of Algorithm 6 has been executed against it. Consequently, only the formal-assurance branch, together with configurable k-of-n thresholds and authenticated requesters, remains for the next stage.

$$Decision(C, R) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R). \quad (69)$$

The CA3 extension incorporates temporal and lifecycle conditions such that

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (70)$$

The implemented system enforces the complete rule of Equation (70): access is granted only when all five predicates hold, revocation is evaluated within  $V_A$ , and every decision, whether granted or denied, is logged together with the full decision matrix; Equation (69) is retained as the historical current-stage formulation.

These equations demonstrate that trust is not provided by blockchain alone. Blockchain contributes integrity, tamper resistance, persistence, and auditability. DID and VC mechanisms contribute identity and authority evidence. Multi-party authorisation contributes collective decision-making. Policy evaluation contributes contextual compliance. Temporal and lifecycle controls contribute dynamic validity. The proposed framework integrates these mechanisms into a coherent authorisation process in which access is granted only when the required trust conditions are satisfied.

The remainder of this chapter moves from the formal design to its realisation. Section 6.8 presents the implemented HALAH system and its live demonstration on the Sepolia test network, so that every algorithm introduced above can be traced to observable behaviour and to publicly verifiable on-chain transactions.

## 6.8 Implementation and Live Demonstration of the Proposed Solution

The HALAH implementation provides a role-based patient consent management environment that operationalises the proposed multi-party healthcare data-sharing framework. The subsystem is organised around four principal functions: patient consent creation, guardian cryptographic approval, authorised doctor data access, and independent audit of the consent lifecycle. Rather than treating consent as a single approval event, the implementation represents consent as a lifecycle in which a consent request is created, independently authorised by designated parties, and cryptographically activated on a public blockchain. It is then continuously checked for validity, subsequently used to control access to specific electronic medical record (EMR) modules, and finally revoked by the patient.

The activation and revocation of a consent are not confined to the application. Instead, they are executed as real transactions on the **Ethereum Sepolia** test network. Consequently, the essential state changes of a consent can be verified by any third party on a public block explorer. The overall workflow implemented by the system is therefore consistent with the proposed authorisation model as

*Create Consent → Guardian Approval → Multi-signature Validation → On-chain Consent Activation  
→ Doctor Access → Consent Revocation → Independent Audit*

This sequence provides an end-to-end demonstration of how the conceptual consent model is translated into an operational healthcare data-sharing process. Each stage is documented below with a screenshot of the running system and, where the stage produces a blockchain transaction, with the corresponding transaction on Sepolia Etherscan.

This operational sequence realises the trust-oriented authorisation model developed in the preceding sections of this chapter. The consent object of Eq. (51), the identity and authority verification of Algorithm 2, the threshold-based multi-party authorisation of Algorithm 3, and the trust-predicate evaluation of Figure 8 are each exercised in this workflow by a real transaction on the Ethereum Sepolia test network, so the conceptual model and the running system can be verified against one another.

### 6.8.1 The HALAH System

The main HALAH subsystem presents itself as a Patient Consent Management Platform for History Access by Authorised Healthcare Providers. The subsystem provides a role-oriented environment in which different participants interact with the same consent lifecycle according to their respective authorisation responsibilities.

The implementation does not expose the underlying blockchain and cryptographic mechanisms as isolated technical components. Instead,

these mechanisms are incorporated into the user workflow. Consequently, the subsystem presents the system from the perspective of the healthcare participants while the underlying implementation performs identity verification, consent-state checking, multi-party approval, cryptographic validation, on-chain anchoring and audit recording.

This design corresponds to the overall HALAH architecture, in which decentralised identifiers (DIDs) provide identity pointers, the consent object defines the authorisation conditions, cryptographic signatures provide evidence of approval, and the blockchain-based ledger provides lifecycle traceability.

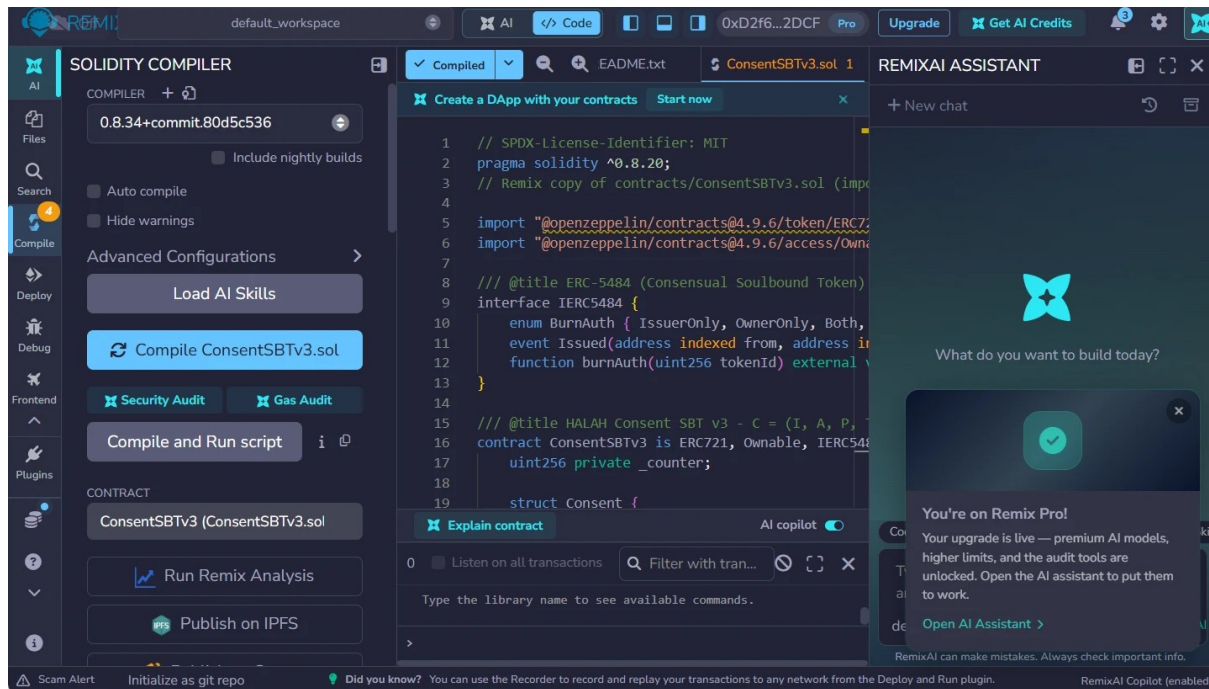


Figure 17: Compilation of ConsentSBTV3 in Remix: the compiler reports a successful compilation and the contract is selected for deployment.

As shown in the figure above, the consent token contract, **ConsentSBTV3**, was first compiled in Remix without errors; the deployment record lists solc 0.8.34 with the optimiser enabled. The contract was then deployed to the Sepolia test network from the project test wallet through MetaMask. The contract implements a soulbound ERC-721 token. Transfers between accounts are blocked. Consequently, an activated consent can never be traded or moved; burning is possible only through the ERC-5484 consensual-burn interface. Each token stores the pseudonymous patient and requester addresses, a hash of the purpose, the validity window, a two-letter jurisdiction code and a revocation flag. The purpose is stored only as a keccak256 hash, and no medical content is written to the chain; the plaintext purpose and the EMR data remain in the application.

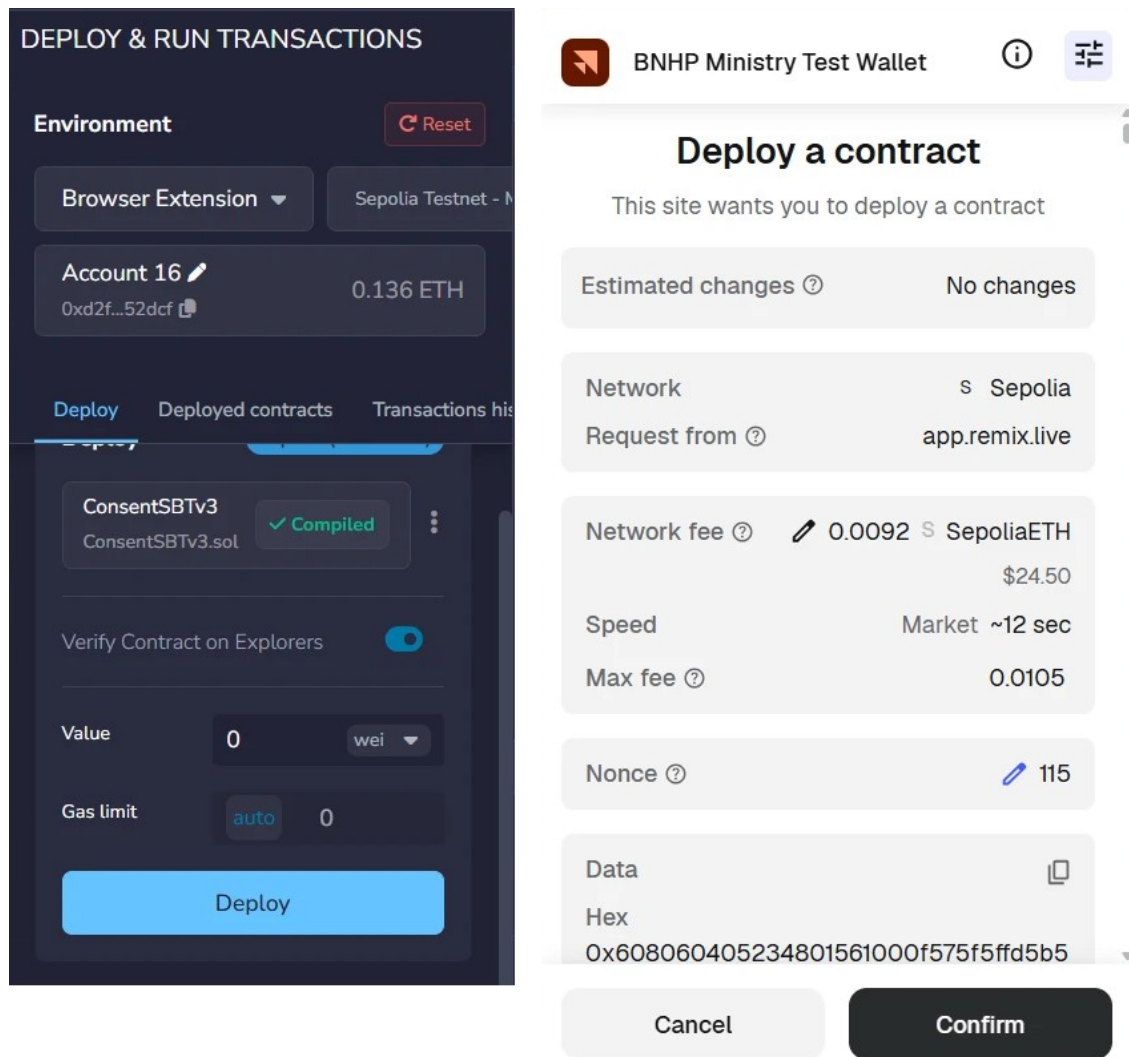


Figure 18: Deployment of ConsentSBTV3 from Remix through MetaMask on the Sepolia network.

As shown in the figure above, the deployment is an ordinary Ethereum transaction that the wallet owner must explicitly confirm: the project test wallet (displayed as BNHP Ministry Test Wallet) shows the target network (Sepolia), the estimated network fee and the account nonce before the contract is created. This is important because it demonstrates that consent activation in HALAH ultimately rests on the same transaction-signing discipline as any other blockchain operation.

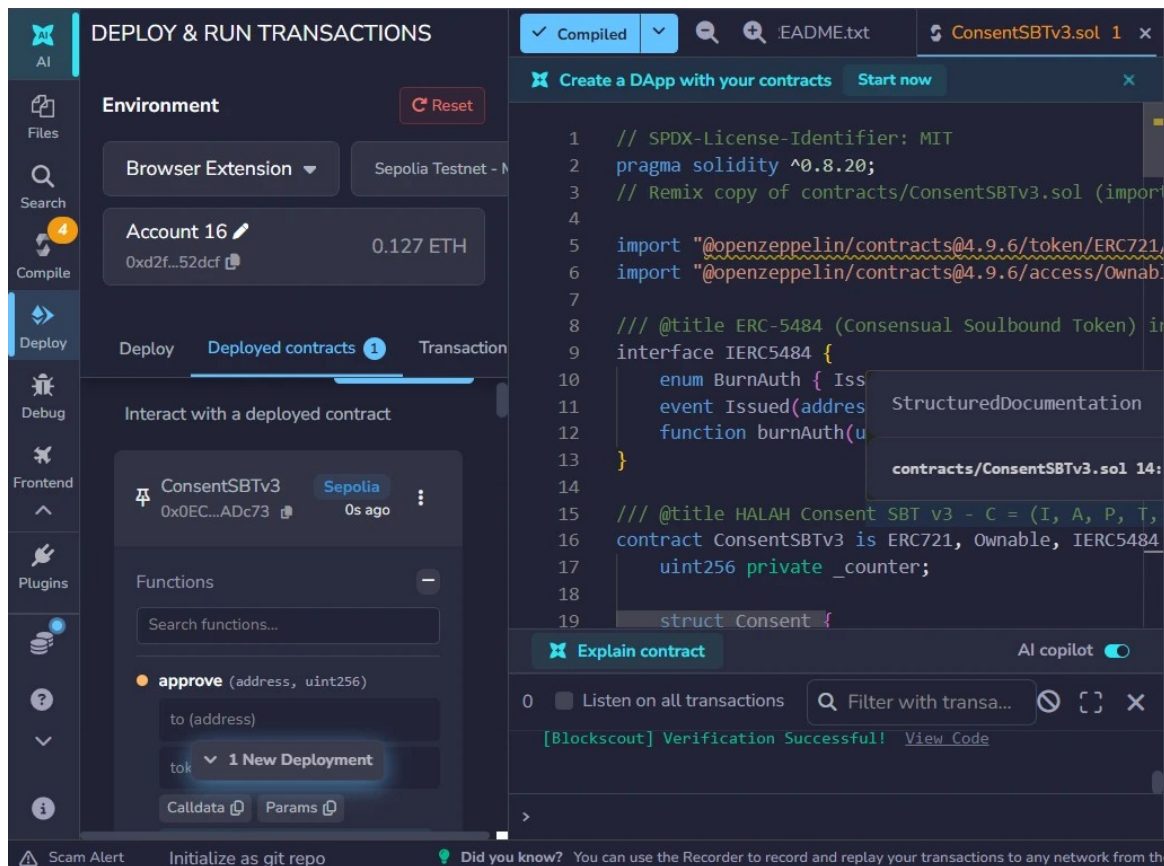


Figure 19: Remix after deployment: the contract appears under Deployed Contracts and the source verification service reports Verification Successful.

As shown in the figure above, the deployed instance is listed in Remix under Deployed Contracts, and the source code was submitted for verification, which completed with Verification Successful. This is important because it ties the published bytecode on Sepolia to the audited Solidity source, so any party can confirm which rules the consent registry actually enforces.

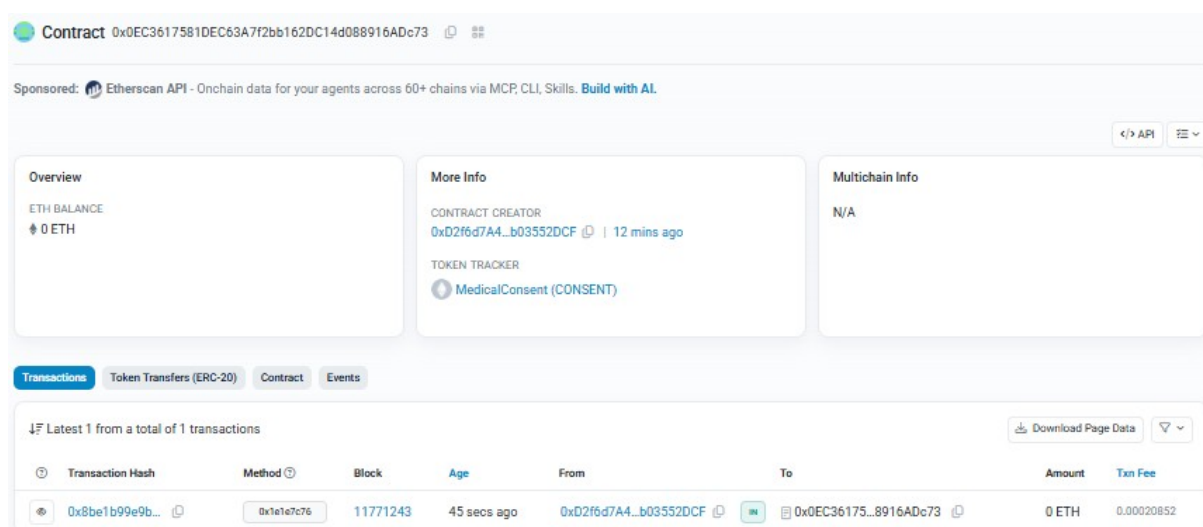


Figure 20: The deployed contract on Sepolia Etherscan, with the creator wallet, the MedicalConsent (CONSENT) token tracker and the first mint transaction.

As shown in the figure above, the deployed contract is publicly listed at 0x0EC3617581DEC63A7f2bb162DC14d088916ADc73 on Sepolia Etherscan, together with its creator wallet and the token tracker MedicalConsent (CONSENT). Consequently, the existence of the consent registry itself, and every activation or revocation recorded on it, can be inspected independently of the HALAH application.

### 6.8.2 Create Smart Consent Contract: Patient Subsystem

The first functional subsystem is the Create Smart Consent Contract module. This module represents the patient-side initiation of a consent transaction and corresponds directly to the construction of the proposed consent object.

The subsystem requires the patient to specify the Patient DID, Authorised Doctor DID, Data Access Scope, Designated Guardian DIDs, the Jurisdiction, and the temporal validity of the consent. These fields collectively operationalise the proposed consent representation:

$$C = (I, A, P, T, L, E)$$

where the identity of the patient is represented through a DID, the authorised actor is explicitly specified, the permitted data scope is constrained to selected EMR modules, the temporal fields define when the authorisation becomes valid and when it expires, the jurisdiction field constrains where the consent may be exercised, and the enforcement state records whether the consent is active or revoked.

The form fields therefore instantiate the consent object defined in Section 6.1. The demonstrated representation realises the six-component object  $C = (I, A, P, T, L, E)$  of Eq. (51) and Figure 11, in which the temporal validity window  $T$ , captured through the Start Time and Expiry Time fields, and the jurisdiction  $L$  are stored on-chain by the deployed ConsentSBTV3 contract and evaluated at every access decision.

### Create Smart Consent Contract

Patient DID (Identity Pointer)

Designated Guardian DIDs (Comma Separated)

Authorised Doctor DID

Jurisdiction (VL)

Data Access Scope (EMR Modules)

Contract Temporal Validity  
 Start Time (YYYY-MM-DD HH:MM:SS)  
  
 Expiry Time (YYYY-MM-DD HH:MM:SS)

Consent contract created and logged (off-chain).

```
[CONSENT CREATED - OFF-CHAIN]
• Consent ID: 04da25f5-b16f-4d9a-af39-a78f0a83b17f
• TxHash: OFF-CHAIN - anchoring happens after guardian 2/2 approval
• Block Number: pending
```

**My Consents**

|                                |                   |                     |                                       |
|--------------------------------|-------------------|---------------------|---------------------------------------|
| 04da25f5... → did:hospital:001 | PENDING_SIGNATURE | 0/2 sigs - token: - | <input type="button" value="Revoke"/> |
|--------------------------------|-------------------|---------------------|---------------------------------------|

Figure 21: The patient subsystem after consent creation: four EMR modules, two designated guardians, jurisdiction AU, and the state PENDING\_SIGNATURE.

As shown in the figure above, the Patient DID provides the identity pointer for the data subject, while the Authorised Doctor DID limits the intended healthcare recipient. This is important because the implementation does not represent consent as a general permission to access a patient's medical information. Instead, the authorisation is bound to a specific identity and therefore supports subject-specific and actor-specific access control.

The Data Access Scope is particularly important to the proposed framework. Instead of granting access to the complete EMR, the patient selects particular modules; in the demonstrated transaction all four modules (Observation, Medication, Condition and Procedure) were selected. This implements the principle of purpose- and scope-limited consent and corresponds to the P component of the consent object. The implementation additionally validates the input before the consent is stored: a consent with an empty data scope is rejected, and every guardian entry must be a well-formed DID.

The Designated Guardian DIDs establish the additional parties required to participate in the authorisation process. Their presence in the consent-creation subsystem demonstrates that multi-party consent is incorporated at the point at which the consent contract is constructed rather than being added after authorisation.

Finally, the Start Time and Expiry Time implement temporal constraints on the consent, and the Jurisdiction field records the legal territory (AU in the

demonstrated transaction). Consequently, authorisation is not represented as a permanent or universal permission. Instead, the consent has a defined lifecycle and territory and can subsequently be evaluated by the Consent Engine according to both. At this point the consent exists only in the application ledger, in the state `PENDING_SIGNATURE`; nothing is written to the blockchain until the guardians have approved.

Two consent lifecycles appear in the demonstration and should be distinguished. The evaluated consent, `f050c29a`, was carried through the complete lifecycle — activation as **token #1**, granted access, refused access and final revocation — and all transaction evidence in this chapter follows it. Because a revoked consent cannot be photographed in its earlier states, the screenshots of consent creation, guardian approval and granted access were captured from a second lifecycle with the same configuration — the same four-module scope, the same guardians, jurisdiction, purpose and doctor — executed for a different demonstration patient (consent `04da25f5`, anchored as **token #2** in block 11,771,581). The two lifecycles were executed with the same code and the same contract.

From a system perspective, this module therefore corresponds primarily to **Consent Object Construction and Patient Initiation**.

### 6.8.3 Guardian Cryptographic Approval

The second part is the Guardian Cryptographic Approval. As shown in the figure below, it operationalises the multi-party authorisation component of the proposed framework.

**Guardian Cryptographic Approval**

Enter Target Consent ID

04da25f5-b16f-4d9a-af39-a78f0a83b17f

Found active transaction for Patient: did:patient:5f01f823-c8e8-9e40-c911-54b7b1ad843a

Select Your Guardian DID Identity

did:parent:A

Sign Consent via VC

EIP-712 signature verified (signer 0x3Af549b0...). Multi-sig: 1/2

Figure 22: The guardian subsystem at the first approval: the EIP-712 signature of `did:parent:A` is verified and the multi-signature count is 1/2.

As shown in the figure above, the first guardian (`did:parent:A`) approves the consent and the subsystem reports EIP-712 signature verified (signer `0x3Af549b0...`) with the multi-signature count 1/2. The consent remains pending, because the approval condition has not yet been satisfied. The second guardian then repeats the same procedure.

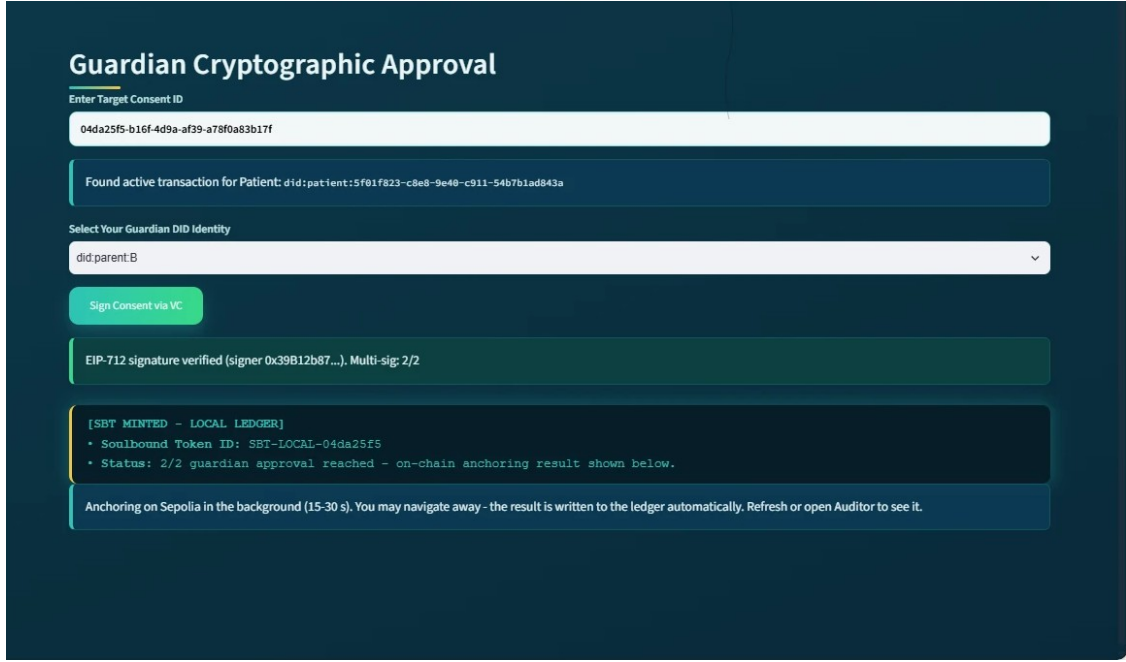


Figure 23: The guardian subsystem at the moment of the second approval: the EIP-712 signature is verified, the 2/2 threshold is reached, the SBT is minted in the local ledger and the Sepolia anchoring starts in the background.

As shown in the figure above, the guardian first enters the target Consent ID, after which the system retrieves the corresponding active transaction and displays the associated patient DID. The guardian then selects their own Guardian DID identity and approves the consent with an EIP-712 typed-data signature, which binds the approval to this specific consent, this guardian and this network (chainId 11155111). The system verifies each signature by recovering the signer address and comparing it with the address associated with that guardian DID. A signature produced for another consent, another guardian or another chain is rejected, and the interface refuses a second signature from the same guardian.

Each approval is evaluated by the procedure formalised in Algorithm 3. In the implemented configuration the authorisation threshold is derived from the designated guardian set as  $N = |G|$ , so that every listed guardian must produce a valid EIP-712 signature before activation; the demonstrated 2-of-2 ceremony is consequently an N-of-N instantiation of the threshold condition of Eq. (54).

The subsystem subsequently reports:

EIP-712 signature verified (signer 0x39B12b87...). Multi-sig: 2/2

This is an important implementation-level demonstration because the consent is not activated merely because the patient created it. Instead, the system requires the predefined guardian approval condition to be satisfied. The implementation therefore enforces the logical authorisation rule:

$$ALLOW = VI \wedge VA \wedge VP \wedge VT \wedge VL$$

where identity verification, authorisation verification, purpose verification, temporal verification and jurisdictional verification must all be satisfied

before access can be granted. For the demonstrated two-guardian configuration, the approval process can also be represented as:

$$\sum_{g \in G} \text{Sign}(g, C) \geq |G| = 2$$

where G represents the designated guardians and every listed guardian must provide a valid signature for activation. Once the required signatures have been obtained, the subsystem displays SBT MINTED together with the Soulbound Token identifier, and a background job submits the mint transaction to Sepolia. While the background job is running, the subsystem reports the intermediate state explicitly.

The screenshot shows a web interface titled "Guardian Cryptographic Approval". It features a dark blue background with white and green text and buttons. The interface is divided into several sections:

- Header:** "Guardian Cryptographic Approval" in white text.
- Input Field:** "Enter Target Consent ID" with a text box containing "04da25f5-b16f-4d9a-af39-a78f0a83b17f".
- Status Bar:** A green bar indicating "Found active transaction for Patient: did:patient:5f01f823-c8e8-9e40-c911-54b7b1ad843a".
- Threshold Message:** A green bar stating "Threshold 2/2 reached but NOT anchored on Sepolia yet (token: SBT-LOCAL-04da25f5). Click below and wait ~30 s without touching anything."
- Buttons:** Two green buttons: "Sync from Sepolia (find existing mint)" and "Anchor on Sepolia now (background)".
- Progress Bar:** A green bar showing "Anchoring in progress - refresh in ~30 s."
- Dropdown Menu:** "Select Your Guardian DID Identity" with a dropdown menu showing "did:parent:B".
- Buttons:** A green button labeled "Sign Consent via VC".
- Footer:** A green bar at the bottom stating "This guardian has already signed this consent (one signature per guardian)."

Figure 24: The guardian subsystem while the mint transaction is pending: the 2/2 threshold is reached but not yet anchored, the anchoring runs in the background, and a repeated signature from the same guardian is refused.

As shown in the figure above, the subsystem reports that the threshold has been reached but the consent is not yet anchored, offers a manual synchronisation with the chain, and refuses a second signature from the same guardian. This is important because the one-signature-per-guardian rule prevents a single guardian from satisfying the multi-signature threshold alone. When the guardian later re-enters the Consent ID, the subsystem reports Already anchored on Sepolia together with the on-chain token number (token #2 for the photographed lifecycle, token #1 for the evaluated consent).



reports the status Success, the block number 11,771,243, the transaction fee, and the transfer of one MedicalConsent token to the pseudonymous patient address derived from the patient DID. The transaction can be inspected on Sepolia Etherscan (mint transaction 0x8be1b99e...daf13d, listed in the verification links of Section 6.8.12). This provides an implementation-level demonstration that consent activation can be verified independently of the application.

The guardian subsystem consequently corresponds to **Multi-Party Approval, Cryptographic Verification and Consent Activation** in the proposed architecture.

#### **6.8.4 Secure Patient Data Access for the Doctor**

The third module is the Secure Patient Data Access module and represents the healthcare-provider side of the authorisation process.

The doctor enters an authorised Consent ID, after which the system retrieves and displays the associated consent information. The subsystem shows the patient DID, Consent ID, purpose, and current consent state:

*State = ACTIVE*

This is important because the doctor does not directly access patient data based solely on possession of a Consent ID. The system first evaluates whether the underlying authorisation remains valid, and it does so for every component of the consent object. The decision matrix displayed to the doctor reports the outcome of each check individually.

The screenshot displays a web interface for a doctor subsystem. At the top, there is a field labeled 'Enter Authorised Consent ID' containing the value 'f050c29a-3d92-4131-8605-63bcb1ff8d92'. Below this, the 'Consent Information' section is divided into three boxes: 'Patient' with 'did:pat...', 'Consent ID' with 'f050c2...', and 'Purpose' with 'Treat...'. A 'Requester jurisdiction (VL check)' dropdown menu is set to 'AU'. A 'Decision matrix' table shows five checks (VI, VA, VP, VT, VL) all with a 'PASS' status, leading to an 'ALLOW = PASS' result. At the bottom, a green bar indicates 'Consent State: ACTIVE'.

| VI   | VA   | VP   | VT   | VL   | ALLOW |
|------|------|------|------|------|-------|
| PASS | PASS | PASS | PASS | PASS | PASS  |

Consent State: ACTIVE

Figure 27: The doctor subsystem with requester jurisdiction AU (the evaluated consent f050c29a, captured before its revocation): all five checks report PASS, ALLOW = PASS, and the consent state is ACTIVE.

As shown in the figure above, the five checks VI (identity), VA (authorisation), VP (purpose), VT (time) and VL (jurisdiction) all report PASS, and consequently ALLOW = PASS. The subsystem then presents the Authorised Data Scope, showing that only the EMR modules specified in the original consent are available. In the demonstrated transaction, the authorised modules are:

$$\text{Scope} = \{ \text{Observation}, \text{Medication}, \text{Condition}, \text{Procedure} \}$$

The five columns of the decision matrix are the operational form of the decision rule  $\text{Decision}(C, R) = \text{ALLOW} \iff \text{VI}(u) \wedge \text{VA}(C) \wedge \text{VP}(C, R) \wedge \text{VT}(C, t) \wedge \text{VL}(C)$ , which extends the three-predicate rule of Eq. (59) with the temporal and jurisdictional verdicts. The jurisdiction predicate is satisfied if and only if the requester's declared jurisdiction equals the jurisdiction recorded in the consent, which the jurisdiction-violation demonstration below confirms empirically.

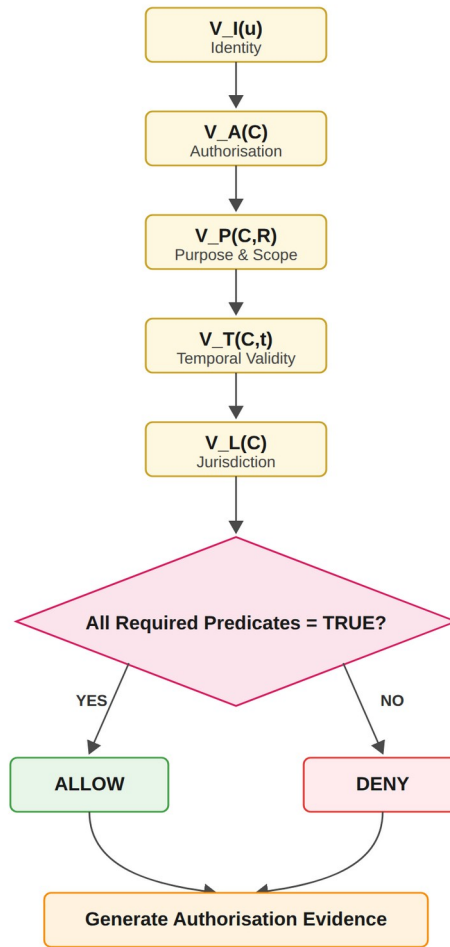


Figure 28: Trust Predicate Evaluation and Authorisation Decision Flow, as enforced by the implemented Consent Engine.

The doctor must subsequently select the modules to request; the request must be a non-empty subset of the authorised scope. The system displays the requested modules and performs cryptographic verification before granting access. In this version, the verification also generates and verifies a Groth16 zero-knowledge proof, whose public inputs are a Poseidon commitment and the current time, and whose private witnesses are a secret and the expiry time; the proof establishes that the commitment is satisfied and that the current time does not exceed the expiry. Because the prover and the verifier currently run on the same server, the proof demonstrates the integration of the zero-knowledge toolchain rather than an additional privacy guarantee (see the limitations discussed at the end of this section). The audit ledger records the proof mode (groth16) with every access granted in the demonstrated lifecycles, and the subsystem then shows the message Cryptographic Verification Successful — Access Granted.



| CONDITION |            |         |                                      |                                      |                        |           |                                                   |
|-----------|------------|---------|--------------------------------------|--------------------------------------|------------------------|-----------|---------------------------------------------------|
|           | START      | STOP    | PATIENT                              | ENCOUNTER                            | SYSTEM                 | CODE      | DESCRIPTION                                       |
| 24        | 1977-03-16 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-3d12-6259d9e41d28 | http://snomed.info/sct | 40055000  | Chronic sinusitis (disorder)                      |
| 25        | 1987-07-17 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-5cb5-c909fa7070c  | http://snomed.info/sct | 224299000 | Received higher education (finding)               |
| 26        | 1993-01-01 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-a174-4b0d42609415 | http://snomed.info/sct | 162864005 | Body mass index 30+ - obesity (finding)           |
| 27        | 1993-12-20 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-e3e7-db542cc62f06 | http://snomed.info/sct | 428251008 | History of appendectomy (situation)               |
| 28        | 1995-05-10 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-b64e-6f71fd99cd0  | http://snomed.info/sct | 161744009 | Past pregnancy history of miscarriage (situation) |
| 29        | 1997-09-19 | 2016-01 | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-94a5-c564d96e7a37 | http://snomed.info/sct | 706893006 | Victim of intimate partner abuse (finding)        |
| 30        | 2005-04-23 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1340-b2438b25d99a | http://snomed.info/sct | 267020005 | History of tubal ligation (situation)             |
| 31        | 2014-02-02 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-fb96-afce40df3554 | http://snomed.info/sct | 82423001  | Chronic pain (finding)                            |
| 32        | 2014-02-02 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-fb96-afce40df3554 | http://snomed.info/sct | 278860009 | Chronic low back pain (finding)                   |
| 33        | 2014-08-01 | 2017-01 | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-ec33-e038d0a52a26 | http://snomed.info/sct | 160903007 | Full-time employment (finding)                    |

Download CSV

| PROCEDURE |                      |                      |                                      |                                      |                        |                 |               |
|-----------|----------------------|----------------------|--------------------------------------|--------------------------------------|------------------------|-----------------|---------------|
|           | START                | STOP                 | PATIENT                              | ENCOUNTER                            | SYSTEM                 | CODE            | DESCRIPTION   |
| 170       | 2016-08-12T02:26:12Z | 2016-08-12T02:41:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | http://snomed.info/sct | 430193006       | Medication    |
| 171       | 2016-08-12T02:26:12Z | 2016-08-12T03:15:24Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | http://snomed.info/sct | 710824005       | Assessment    |
| 172       | 2016-08-12T03:15:24Z | 2016-08-12T03:26:34Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | http://snomed.info/sct | 428211000124100 | Assessment    |
| 173       | 2016-08-12T03:26:34Z | 2016-08-12T03:48:35Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | http://snomed.info/sct | 763302001       | Assessment    |
| 174       | 2016-08-19T02:26:12Z | 2016-08-19T02:38:17Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-f486-ee6219a882da | http://snomed.info/sct | 76601001        | Intramuscular |
| 175       | 2016-11-18T02:26:12Z | 2016-11-18T02:43:39Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-c961-c9e35afa9c77 | http://snomed.info/sct | 76601001        | Intramuscular |
| 176       | 2017-02-17T02:26:12Z | 2017-02-17T02:37:40Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-f45f-17f268bac16c | http://snomed.info/sct | 76601001        | Intramuscular |
| 177       | 2017-05-19T02:26:12Z | 2017-05-19T02:37:14Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b5b-214bb8245e13 | http://snomed.info/sct | 76601001        | Intramuscular |
| 178       | 2017-08-18T02:26:12Z | 2017-08-18T02:41:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-eba1-0e85ddb2dddb | http://snomed.info/sct | 430193006       | Medication    |
| 179       | 2017-08-18T02:26:12Z | 2017-08-18T02:57:42Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-eba1-0e85ddb2dddb | http://snomed.info/sct | 710824005       | Assessment    |

Figure 30: The remaining authorised modules of the same request: the Condition and Procedure records, with the Condition module's export control visible.

The two figures above demonstrate the transition from consent verification to data-access authorisation; the checks are recorded in the audit ledger as STATE\_CHECK events, one for every evaluated access request, so validity is re-established at each request rather than assumed. This distinction is central to the HALAH design. Consent and data access are not treated as identical events. Instead, the flow proceeds as follows:

*Consent → Verification → AccessDecision*

The doctor is therefore authorised only when the requested resources are consistent with the consent object and the consent remains active. The final Authorised Medical Records section presents the actual data modules available to the doctor. Because the subsystem separates the OBSERVATION, MEDICATION, CONDITION and PROCEDURE modules, it provides a direct visual demonstration of fine-grained EMR access control.

Thus, the doctor subsystem corresponds to **Consent-State Validation, Scope Enforcement and Authorised Data Access**.

### 6.8.5 Negative Demonstration: Jurisdiction Violation

The fourth part is the negative demonstration. This is important because a consent framework must be evaluated not only on whether it grants

legitimate access, but also on whether it refuses illegitimate access. The same doctor therefore repeated the request for the evaluated consent while declaring the requester jurisdiction as SA, whereas the consent was issued for AU.

The screenshot displays a web interface for a doctor subsystem. At the top, there is a field labeled "Enter Authorised Consent ID" containing the value "f050c29a-3d92-4131-8605-63bcb1ff8d92". Below this is a section titled "Consent Information" with three cards: "Patient" showing "did:pat...", "Consent ID" showing "f050c2...", and "Purpose" showing "Treat...". A dropdown menu for "Requester jurisdiction (VL check)" is set to "SA". Below the dropdown is a "Decision matrix - ALLOW = VI AND VA AND VP AND VT AND VL" table. The table has six columns: VI, VA, VP, VT, VL, and ALLOW. The rows show the results: VI is PASS, VA is PASS, VP is PASS, VT is PASS, VL is FAIL, and ALLOW is FAIL. At the bottom, a green bar indicates "Consent State: ACTIVE".

| VI   | VA   | VP   | VT   | VL   | ALLOW |
|------|------|------|------|------|-------|
| PASS | PASS | PASS | PASS | FAIL | FAIL  |

Consent State: ACTIVE

Figure 31: The doctor subsystem with requester jurisdiction SA: VL reports FAIL and consequently ALLOW = FAIL, although the consent state remains ACTIVE.

As shown in the figure above, the decision matrix immediately reports VL = FAIL and consequently ALLOW = FAIL, even though the consent itself is still ACTIVE, the guardian signatures remain valid and all other checks pass. This is important because it demonstrates that the access decision is taken over the complete consent tuple rather than over the consent state alone.

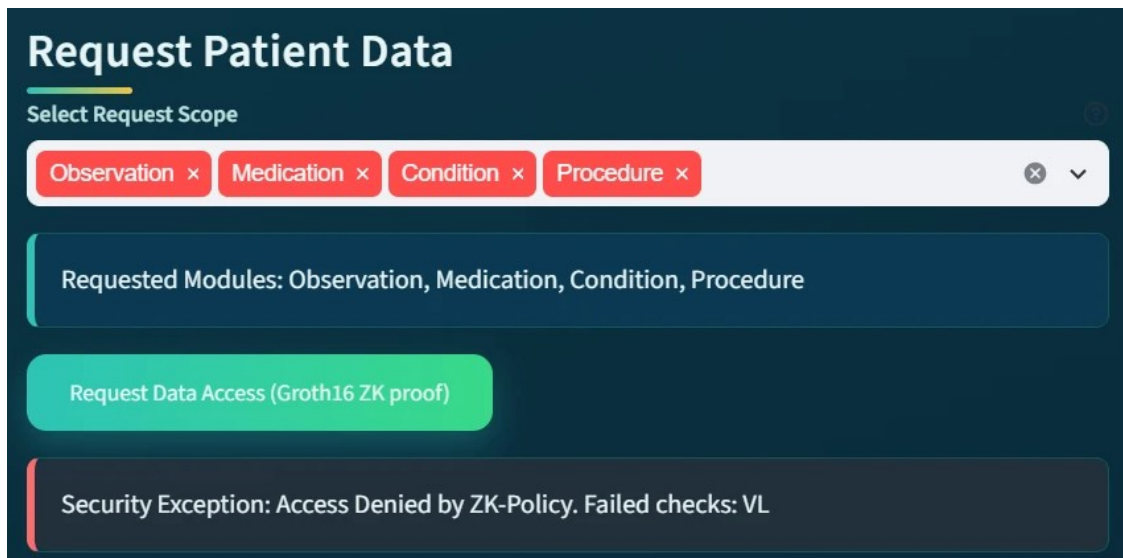


Figure 32: The refused request: 'Security Exception: Access Denied by ZK-Policy. Failed checks: VL'.

As shown in the figure above, when the doctor submits the request, access is refused and the failed check is named explicitly. The corresponding audit-ledger entry records the result DENIED together with the complete decision matrix, so that the refusal is itself auditable. This is important because the jurisdiction check is included in the access decision rather than merely displayed.

This demonstration corresponds to **Jurisdictional Constraint Enforcement and Fail-Closed Access Control**.

### 6.8.6 Consent Revocation

The fifth module is the Consent Revocation module. This module operationalises the enforcement component of the consent object, which requires that a patient can withdraw consent and that the withdrawal takes effect for every subsequent request. In the patient's My Consents view, each consent is listed with its state, signature count and token. The patient then selects Revoke, after which the system updates the application state and submits a revoke transaction to the contract on Sepolia.

### My Consents

|                                   |                       |                                          |                         |
|-----------------------------------|-----------------------|------------------------------------------|-------------------------|
| 2502632b... →<br>did:hospital:001 | REVOKED               | 0/2 sigs - token: -                      | REVOKED                 |
| aca837a1... →<br>did:hospital:001 | REVOKED               | 0/2 sigs - token: -                      | REVOKED                 |
| cd9a24bd... →<br>did:hospital:001 | REVOKED               | 2/2 sigs - token: SBT-LOCAL-<br>cd9a24bd | REVOKED                 |
| 011bbb21... →<br>did:hospital:001 | REVOKED               | 2/2 sigs - token: SBT-8                  | REVOKED                 |
| 0975c645... →<br>did:hospital:001 | PENDING_SIGNA<br>TURE | 0/2 sigs - token: -                      | <button>Revoke</button> |
| f050c29a... →<br>did:hospital:001 | ACTIVE                | 2/2 sigs - token: SBT-1                  | <button>Revoke</button> |

Revoking on Sepolia - waiting for block confirmation...

Figure 33: The patient subsystem during revocation: 'Revoking on Sepolia - waiting for block confirmation...'.

As shown in the figure above, the withdrawal is submitted as a blockchain transaction and the subsystem waits for the block confirmation before reporting the final state.

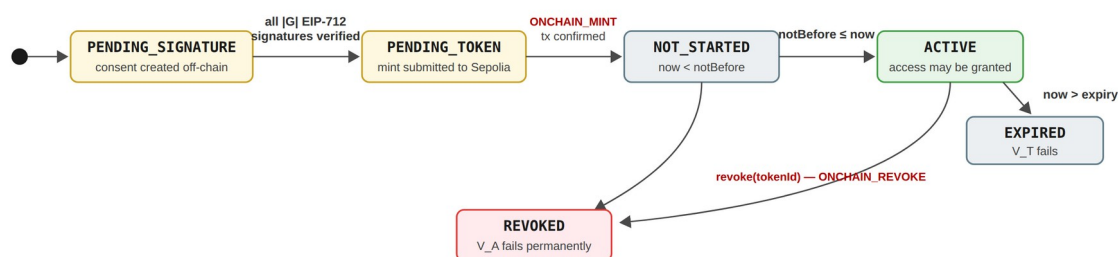
### My Consents

|                                   |                       |                                          |                         |
|-----------------------------------|-----------------------|------------------------------------------|-------------------------|
| 2502632b... →<br>did:hospital:001 | REVOKED               | 0/2 sigs - token: -                      | REVOKED                 |
| aca837a1... →<br>did:hospital:001 | REVOKED               | 0/2 sigs - token: -                      | REVOKED                 |
| cd9a24bd... →<br>did:hospital:001 | REVOKED               | 2/2 sigs - token: SBT-LOCAL-<br>cd9a24bd | REVOKED                 |
| 011bbb21... →<br>did:hospital:001 | REVOKED               | 2/2 sigs - token: SBT-8                  | REVOKED                 |
| 0975c645... →<br>did:hospital:001 | PENDING_SIGNA<br>TURE | 0/2 sigs - token: -                      | <button>Revoke</button> |
| f050c29a... →<br>did:hospital:001 | REVOKED               | 2/2 sigs - token: SBT-1                  | REVOKED                 |

Figure 34: The patient subsystem after revocation: the evaluated consent f050c29a is REVOKED with token #1 (displayed as SBT-1). The other rows are earlier trial consents.

As shown in the figure above, the revoked consent is displayed as REVOKED together with its on-chain token number. The revocation was confirmed on Sepolia in block 11,771,307, and from that point the contract itself reports the token as no longer valid, so any verifier that reads the chain observes the withdrawal.

The demonstrated revocation completes the consent lifecycle anticipated by the temporal and lifecycle model of Section 6.5: the consent progresses through the controlled states PENDING\_SIGNATURE, PENDING\_TOKEN, NOT\_STARTED, ACTIVE and REVOKED, and the activating and revoking transitions are themselves verifiable Sepolia transactions (blocks 11,771,243 and 11,771,307). Trust is therefore not treated as permanently established at the moment a consent is created, which is precisely the lifecycle-trust principle stated there.



*Solid transitions are recorded in the audit ledger; the transitions marked in red are anchored as real Sepolia transactions.*

Figure 35: The implemented consent lifecycle: every consent progresses through controlled states, and the activating and revoking transitions are anchored as verifiable Sepolia transactions.

**Secure Patient Data Access**

Enter Authorised Consent ID

**Consent Information**

|                            |                          |                  |
|----------------------------|--------------------------|------------------|
| Patient                    | Consent ID               | Purpose          |
| <b>did:patient:fe62...</b> | <b>f050c29a-3d92-...</b> | <b>Treatment</b> |

Requester jurisdiction (VL check)

Decision matrix - ALLOW = VI AND VA AND VP AND VT AND VL

| VI   | VA   | VP   | VT   | VL   | ALLOW |
|------|------|------|------|------|-------|
| PASS | FAIL | PASS | PASS | PASS | FAIL  |

Consent is not active. Current state: REVOKED

The Doctor cannot access patient data because the consent is not currently valid.

Figure 36: The doctor subsystem after revocation: VA reports FAIL and the consent is reported as 'not active. Current state: REVOKED'.

As shown in the figure above, when the doctor subsequently enters the same Consent ID, the authorisation check VA fails and the subsystem reports that the consent is not active. Consequently, revocation is not merely a change of display: it removes the authorisation on which every later access decision depends.

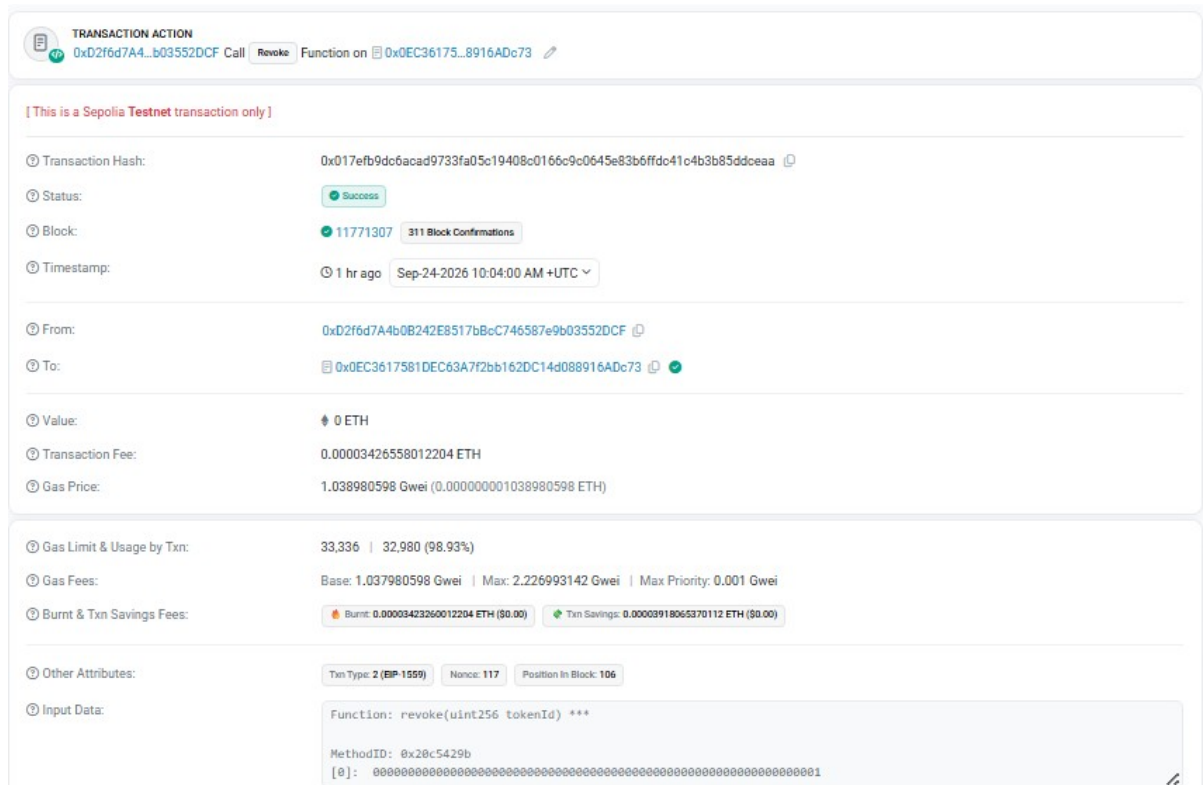


Figure 37: The revocation transaction on Sepolia Etherscan: status Success, block 11,771,307, decoded input 'Function: revoke(uint256 tokenId)' with tokenId = 1.

As shown in the figure above, the revocation is again a publicly verifiable transaction, whose decoded input names the contract function revoke and the token identifier. The transaction can be inspected on Sepolia Etherscan (revoke transaction 0x017efb9d...dceaa, listed in the verification links of Section 6.8.12). The revocation subsystem therefore corresponds to **Enforcement State Management and Consent Withdrawal**.

### 6.8.7 Blockchain Audit and Consent Lifecycle for the Auditor

The sixth major module is the Blockchain Audit & Consent Lifecycle module. This subsystem provides an independent view of the complete consent process and corresponds to the auditability and accountability component of the HALAH framework.

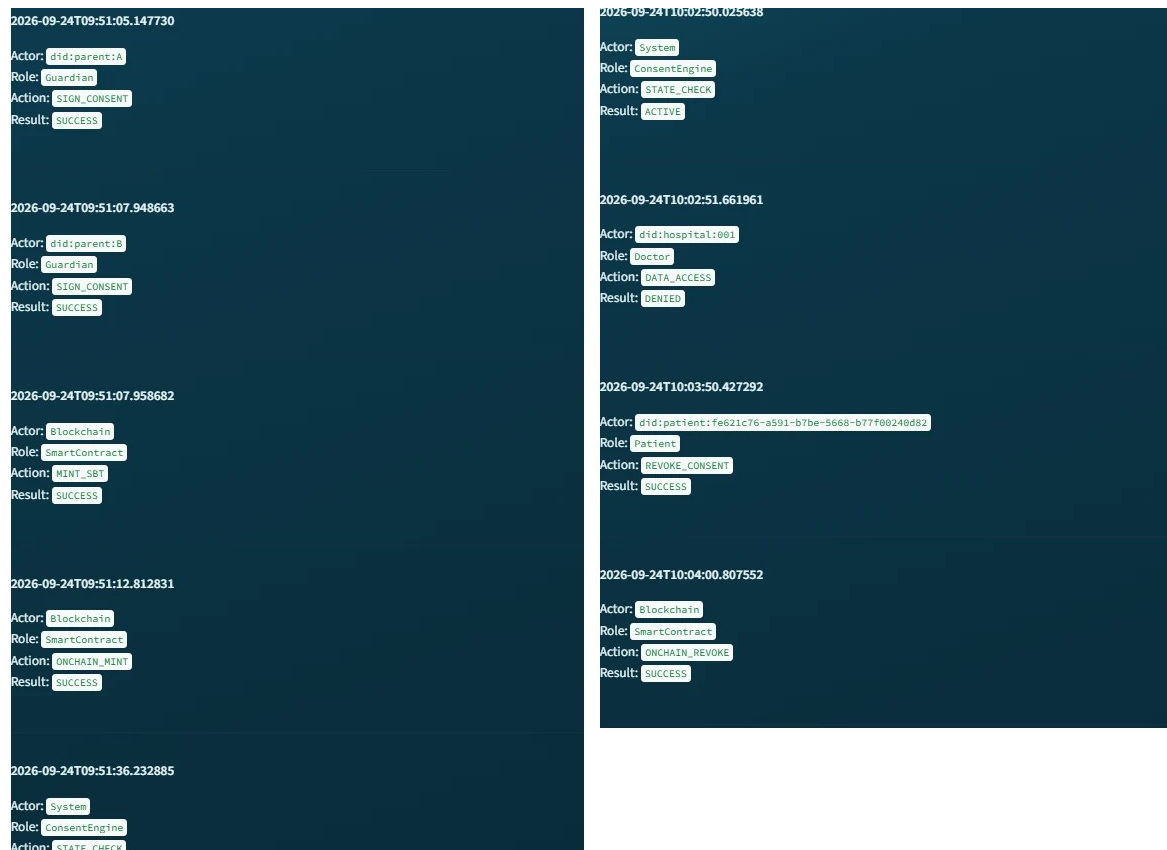


Figure 38: The Consent Lifecycle reconstruction for the evaluated consent: the guardian signatures, MINT\_SBT and ONCHAIN\_MINT on the left, and the STATE\_CHECK, DENIED, REVOKE\_CONSENT and ONCHAIN\_REVOKE events on the right.

As shown in the figure above, the lifecycle view presents each event as a card with its timestamp, actor, role, action and result, so the chronological sequence of the authorisation process can be read directly.

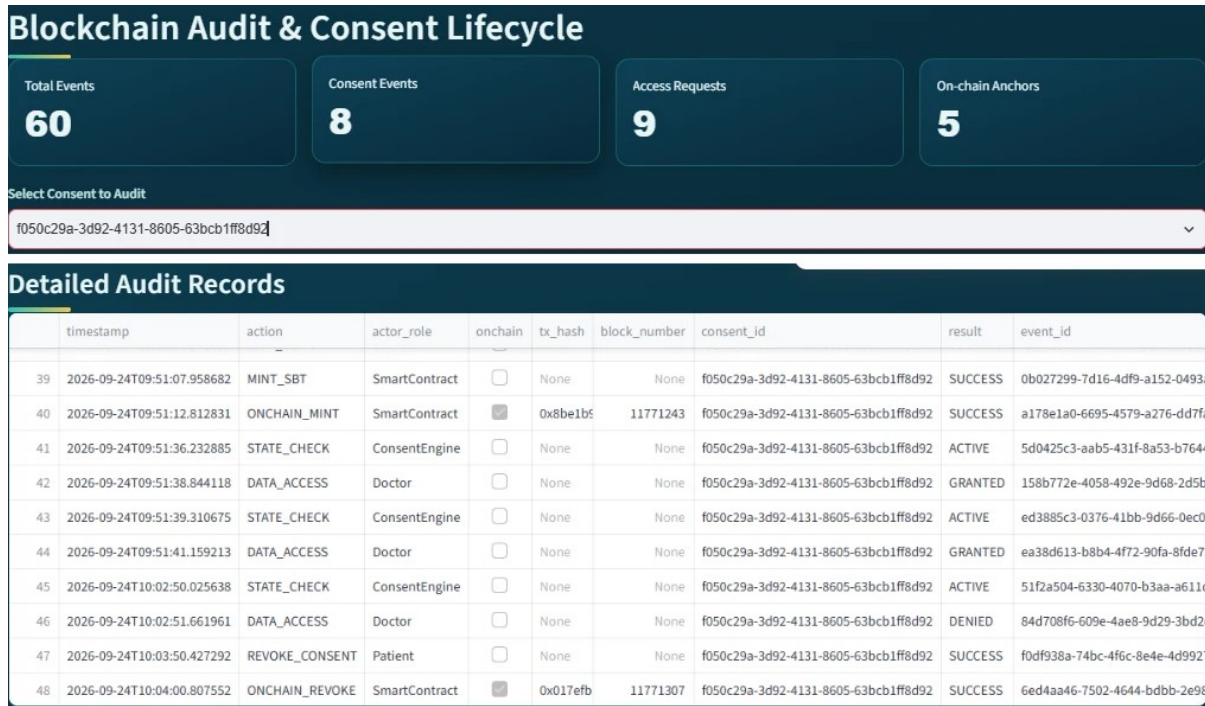


Figure 39: The auditor subsystem with the evaluated consent selected: aggregate indicators and the Detailed Audit Records, in which the on-chain events carry their transaction hashes and block numbers.

As shown in the figure above, the system first provides aggregate indicators including:

*Total Events = 60   Consent Events = 8   Access Requests = 9   On-chain Anchors = 5*

These indicators give the auditor an immediate overview of the recorded system activity and of how many events are anchored on the public chain. The five anchors comprise the mint and revocation of the evaluated consent (token #1), the mint of the photographed lifecycle (token #2), and the mint and revocation of an earlier trial consent on the previous contract; the nine access requests comprise the granted, refused and reproduced requests of the two lifecycles together with three granted requests recorded for the earlier trial consents. More importantly, the Consent Lifecycle section reconstructs the sequence of events associated with a particular consent. The reconstructed records include CREATE\_CONSENT performed by the patient, followed by SIGN\_CONSENT performed by each guardian, followed by MINT\_SBT and ONCHAIN\_MINT performed by the smart contract; in the figure the detailed table is scrolled to the on-chain events, whose rows carry the transaction hashes. The subsequent STATE\_CHECK system events demonstrate that the Consent Engine continuously evaluates the state of the authorisation. The doctor then generates DATA\_ACCESS with the result GRANTED, later DATA\_ACCESS with the result DENIED when the jurisdiction check fails, and finally the patient generates REVOKE\_CONSENT followed by ONCHAIN\_REVOKE performed by the smart contract.

This audit reconstruction, together with the independent verification of every recorded transaction against the public chain, constitutes the empirical component of the security-assurance objective RO6 of Section 6.6: representative valid, invalid and adversarial scenarios have been executed against the running prototype, and the recorded evidence is consistent with the public chain. The formal component — proofs and model checking of the stated properties — remains next-stage work.

This produces an explicit chain of evidence as

$$\begin{aligned} & Patient \rightarrow Guardian\_A \rightarrow Guardian\_B \rightarrow SmartContract(mint) \rightarrow ConsentEngine \rightarrow \\ & \quad Doctor(GRANTED) \\ & \rightarrow Doctor(DENIED) \rightarrow Patient(revoke) \rightarrow SmartContract(revoke) \end{aligned}$$

The audit subsystem therefore allows an auditor to reconstruct not only who accessed the data, but also why that access was permitted or refused, because each access event can be associated with the preceding consent creation, guardian approvals, on-chain activation, state checks and the decision matrix that was in force at that moment.

This corresponds to the proposed requirement for **traceability, accountability and non-repudiable consent evidence**.

### 6.8.8 Detailed Audit Records

The Detailed Audit Records component provides a lower-level view of the events represented in the lifecycle subsystem.

Where the lifecycle view is primarily designed to communicate the chronological sequence of the authorisation process, the detailed audit view provides the underlying event-level evidence. Each event can be associated with attributes such as actor, role, action, result, timestamp, consent context and, for on-chain events, the transaction hash and block number. As shown in the auditor figure above, the ONCHAIN\_MINT and ONCHAIN\_REVOKE rows carry the hashes of the two Sepolia transactions presented in Sections 6.8.3 and 6.8.6, so the ledger and the public chain describe the same events.

This separation is useful because different stakeholders require different levels of information. A clinician may only need to know that a consent is active and valid, whereas an auditor may need to establish precisely when an approval occurred, which identity performed it, and what authorisation decision followed.

The subsystem therefore implements the distinction between operational access information and forensic/audit information.

### 6.8.9 Complete Audit Ledger and Independent Verification

The Complete Blockchain Audit Ledger provides the most comprehensive representation of the recorded consent history. This component demonstrates that the audit mechanism is not limited to successful data-

access events. Instead, the system records the broader lifecycle of the consent, including creation, signatures, state validation, smart-contract actions, refused requests and revocations. Consequently, the ledger provides the evidentiary foundation for evaluating several properties of the proposed framework:

*Accountability + Traceability + Integrity + Non-repudiation*

A ledger kept by the application could in principle contain fabricated entries. Consequently, the implementation provides an independent verification tool. The tool re-reads the ledger and, for every event that carries a transaction hash, fetches the corresponding receipt directly from Sepolia and checks that the transaction exists, succeeded, and was included in the recorded block; for every consent anchored on the current contract it then reads the token back and compares the on-chain revocation state with the local state; the earlier trial token resides on the superseded contract and is reported and skipped.

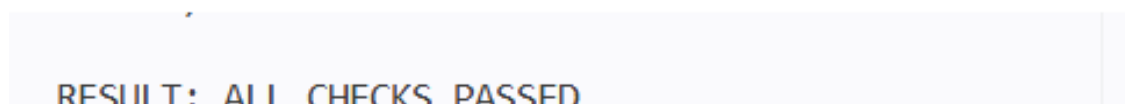


Figure 40: The final verdict of the independent verification, re-executed after the second lifecycle: RESULT: ALL CHECKS PASSED.

As shown in the figure above, the verification was re-executed after the second lifecycle and reports ALL CHECKS PASSED: every recorded transaction was found on Sepolia in its recorded block, and for both tokens on the current contract the revocation state stored by the application matches the state stored by the contract (token #1 revoked, token #2 not revoked). Accordingly, the demonstrated sequence shows that the doctor receives a GRANTED result only while the consent is in the ACTIVE state, and a DENIED or 'not active' result otherwise. This provides an implementation-level demonstration that access decisions are linked to the consent lifecycle rather than being independent application events, and that the recorded lifecycle is consistent with the public chain.

### 6.8.10 Correspondence Between the Subsystems and the Framework

The subsystems collectively implement the principal stages of the proposed framework:

| HALAH Framework Component   | Implementation Subsystem        | Main Function                                                                                 |
|-----------------------------|---------------------------------|-----------------------------------------------------------------------------------------------|
| Consent Object Construction | Create Smart Consent Contract   | Defines patient, authorised doctor, data scope, guardians, jurisdiction and temporal validity |
| Identity & Authorisation    | Guardian Cryptographic Approval | Verifies guardian identities and EIP-712 signatures                                           |
| Multi-party Consent         | Guardian Cryptographic Approval | Implements the 2-of-2 approval condition                                                      |

| <b>HALAH Framework Component</b> | <b>Implementation Subsystem</b>            | <b>Main Function</b>                                                             |
|----------------------------------|--------------------------------------------|----------------------------------------------------------------------------------|
| Consent Activation               | Guardian Cryptographic Approval            | Mints the SBT on Sepolia and marks the consent as fully activated                |
| Consent-State Management         | Secure Patient Data Access                 | Checks whether the consent is ACTIVE                                             |
| Scope Enforcement                | Secure Patient Data Access                 | Restricts access to authorised EMR modules                                       |
| Cryptographic Access Control     | Secure Patient Data Access                 | Verifies the request, including a Groth16 proof, before granting data            |
| Jurisdictional Constraint (L)    | Secure Patient Data Access                 | Refuses requests whose declared jurisdiction differs from the consent            |
| Healthcare Data Access           | Secure Patient Data Access                 | Provides the authorised Observation, Medication, Condition and Procedure records |
| Enforcement / Revocation (E)     | My Consents (Patient)                      | Revokes the consent locally and on-chain                                         |
| Lifecycle Traceability           | Blockchain Audit & Consent Lifecycle       | Reconstructs the chronological consent process                                   |
| Accountability                   | Detailed Audit Records                     | Provides event-level evidence with transaction hashes                            |
| Ledger Integrity                 | Complete Ledger + independent verification | Confirms the recorded history against Sepolia                                    |

*Table 9: Correspondence between the HALAH framework components and the implemented subsystems.*

This mapping demonstrates that the implementation is not merely a collection of independent user-subsystem modules. Rather, the modules correspond to successive stages of the proposed authorisation protocol.

### 6.8.11 Overall System Demonstration

Taken together, the subsystems demonstrate an end-to-end implementation of the proposed HALAH authorisation workflow on a public blockchain. The patient first establishes the consent conditions through the Smart Consent Contract subsystem. The designated guardians then independently authenticate and provide the required cryptographic approvals. Once the multi-signature condition is satisfied, the consent is activated and represented by an SBT minted on Sepolia. The authorised doctor subsequently submits an access request, which is evaluated against the patient's identity, consent state, authorised data scope, temporal validity and jurisdiction. Only when these conditions are satisfied does the system provide access to the specified EMR modules; an out-of-jurisdiction request is refused with the failed check named. The patient finally revokes the consent, the revocation is recorded on-chain, and the complete sequence is exposed through the auditor subsystem and re-verified independently against the chain.

$C \rightarrow MS \rightarrow SBT\_chain \rightarrow StateCheck \rightarrow AccessDecision \rightarrow EMR \rightarrow Revoke\_chain \rightarrow Audit \rightarrow Verify$

where C denotes consent creation, MS multi-signature approval, SBT\_chain on-chain consent activation, StateCheck lifecycle validation,

AccessDecision authorisation enforcement over the full consent tuple, EMR authorised medical-record access, Revoke\_chain on-chain revocation, Audit immutable lifecycle recording, and Verify independent verification against Sepolia.

The demonstrated prototype makes several simplifications that are acceptable for a research demonstration but would require strengthening before deployment. The guardian signing keys are derived deterministically from the guardian DIDs so that the prototype can sign without wallets; in production each guardian would sign the same typed data with a wallet-held key registered against their DID. The doctor's identity and jurisdiction are declared in the interface rather than authenticated, and the Groth16 proof is generated and verified by the same server, so it currently demonstrates the integration of the zero-knowledge toolchain rather than an additional privacy guarantee. These aspects define the immediate future work of the project.

From a research-implementation perspective, the most significant feature of the presented subsystems is therefore the continuity between consent specification, multi-party authorisation, public on-chain activation and revocation, access enforcement and independently verifiable audit evidence. The user subsystems provide a visible representation of this continuity, allowing the proposed HALAH model to be demonstrated as an operational authorisation workflow on a public network rather than only as a conceptual framework.

### 6.8.12 Verification Links

♦ [RED — يجب حله قبل التسليم] **R1: Before submitting, re-open every link on this page and confirm the contract, both transactions and the token pages still resolve on Sepolia Etherscan exactly as described. The whole evidentiary chain of the report depends on these.**

Contract:

<https://sepolia.etherscan.io/address/0x0EC3617581DEC63A7f2bb162DC14d088916ADc73>

Consent activation (mint of token #1):  
<https://sepolia.etherscan.io/tx/0x8be1b99e9b7054d427bdee0a0b5cc56ae99030a399f4b11d3629ed5d98daf13d>

Consent activation (mint of token #2, photographed lifecycle):  
<https://sepolia.etherscan.io/tx/0x25ef5e2f0046735dcb01ff7b68875b760bdf88ad0fa3fedc9bfb910769d4c210>

Consent revocation (token #1):  
<https://sepolia.etherscan.io/tx/0x017efb9dc6acad9733fa05c19408c0166c9c0645e83b6ffdc41c4b3b85ddceaa>

Full audit-ledger export: [evidence/sepolia\\_audit\\_ledger\\_2026-09-24.csv](#);  
deployment and run record: [evidence/sepolia\\_deploy\\_v3\\_2026-09-24.txt](#)  
preserved in the project evidence records.

## 7 Current Progress Status

### 7.1 Progress of RO1: Trust-Centric Consent Model

Status: Completed

RO1 has been completed at the conceptual and prototype-design level. The main contribution of RO1 is the transformation of consent from a static permission record into a structured authorisation object. Instead of storing only whether a patient has granted access, the consent object explicitly records the conditions that determine whether access should be permitted. The proposed representation is

$$C = (I, A, P, T, L, E). \quad (71)$$

Identity information establishes the relevant participants. Authorisation requirements define who must approve the consent. Policy information specifies the purpose and permitted data scope. Authorisation evidence records the information required to demonstrate how the consent decision was established. The model provides the foundation for the remaining objectives because the identity, multiparty approval, and policy mechanisms can all be evaluated against the same consent object. The current result demonstrates that consent can be represented as an evaluable authorisation object rather than as a binary permission. This provides a conceptual basis for dynamic access decisions and allows subsequent authorisation conditions to be evaluated consistently.

### 7.2 Progress of RO2: Decentralised Identity and Authority

Status: Completed

RO2 has been completed at the conceptual and prototype level. The proposed framework explicitly separates identity authentication from authorisation authority, such that

$$\text{Identity} \neq \text{Authorisation}. \quad (72)$$

A decentralised identifier is used to establish the identity of a participant, while verifiable credentials provide evidence concerning the participant's role or authority. The identity verification condition is represented as

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u). \quad (73)$$

Successful identity verification therefore does not automatically grant access to healthcare information. Instead, identity and credential validity become trusted inputs to the subsequent authorisation process. The current implementation demonstrates the separation between participant identity and authorisation authority. A valid healthcare participant identity can be verified independently from the question of whether that participant is authorised to access a particular patient's data.

In the current prototype the approval threshold is fixed at N-of-N: every listed guardian must approve, each through an EIP-712 typed-data signature verified by cryptographic recovery, and the two-guardian case has been evaluated end-to-end, with configurable k-of-n thresholds remaining future work. With respect to identity verification,  $V_I$  in the prototype performs identifier- and credential-format validation only; cryptographic DID resolution against a registry and authentication of the requester are acknowledged limitations reserved for the next stage.

### 7.3 Progress of RO3: Trustworthy Multi-Party Authorisation

Status: Completed

RO3 has been completed at the conceptual and prototype level. The framework introduces threshold-based multi-party authorisation to prevent a single participant from unilaterally establishing sensitive healthcare data access. Let  $A_v$  represent the set of independently verified authorisation participants and  $N$  represent the required approval threshold. The authorisation condition is

$$V_A(C) = 1, |A_v| \geq N; 0, |A_v| < N. \quad (74)$$

If the threshold is not satisfied,

$$|A_v| < N \Rightarrow \text{Decision}(C, R) = \text{DENY}. \quad (75)$$

This mechanism allows the framework to distinguish between insufficient and sufficient collective authorisation. The prototype demonstrates that a consent object remains unable to establish valid authorisation until the required number of independently verified participants has approved it. For example, where two approvals are required,

$$|A_v| = 2 \Rightarrow V_A(C) = 1, \quad (76)$$

whereas

$$|A_v| = 1 \Rightarrow V_A(C) = 0. \quad (77)$$

This provides preliminary evidence that the proposed framework can enforce collective rather than unilateral authorisation.

### 7.4 Progress of RO4: Policy-Aware Access Control

♦ [RED — يجب حله قبل التسليم] R2a: Status upgraded to Completed. Your original CA2 plan placed RO4 in the next stage; be ready to defend the upgrade with the implemented evidence (scope, temporal and jurisdiction checks; the SA denial), and confirm your supervisor agrees with the new staging before submitting.

Status: Completed.

The policy predicate  $V_P$  is implemented at the prototype level: each access request declares a purpose and a requested data scope  $S_R$ , and the request is rejected whenever  $S_R$  is not a subset of the authorised scope  $S_C$ . The predicate is evaluated as one term of the complete decision matrix  $V_I \wedge V_A$

$\wedge V_P \wedge V_T \wedge V_L$ , and every denial names the failed checks explicitly in both the interface and the audit ledger. In addition, input validation on consent creation and access requests prevents malformed identifiers, scopes and jurisdictions from reaching the decision logic. Consequently, policy-aware access control is an enforced property of the running system rather than an expected outcome.

RO4 represents the next stage of the framework beyond identity and multi-party approval. The objective is to ensure that an otherwise valid requester cannot access healthcare information outside the purpose and data scope authorised by the consent. The proposed policy predicate is

$$V_P(C, R) = \text{Policy}(C, R). \quad (78)$$

For example, if  $S_C = \{\text{Observation, Medication}\}$ , and the requester asks for  $S_R = \{\text{Observation, Medication, Procedure}\}$ , the request exceeds the authorised scope and the jurisdiction and validity conditions are evaluated against the stored consent before any decision is returned.

## 7.5 Progress of RO5: Temporal and Lifecycle Trust

♦ [RED — يجب حله قبل التسليم] R2b: Status Largely Completed - same as R2a: the original plan said next stage. The on-chain revocation (block 11,771,307) and the state machine support the claim, but the formal lifecycle model is still future work; do not present RO5 as fully done.

Status: Largely Completed.

RO5 has moved from planned work to implemented capability. The consent validity interval  $[t_s, t_e]$  is now enforced by the temporal predicate  $V_T$  at every access request and is additionally stored on-chain in the SBT as the notBefore and expiry fields, so that temporal validity can be verified independently of the application. The consent lifecycle is implemented as an explicit state machine comprising PENDING\_SIGNATURE, PENDING\_TOKEN, NOT\_STARTED, ACTIVE, EXPIRED and REVOKED, and revocation is enforced end-to-end: the patient's withdrawal updates the application state and is confirmed as a revoke transaction on Sepolia in block 11,771,307, after which the contract itself reports the token as invalid and subsequent access requests are denied. What remains for the next stage is therefore the dynamic and delegated dimension of lifecycle trust, such as consent modification, delegation and guardian-set changes, rather than temporal enforcement itself.

$$V_T(C, t) = (t_s \leq t \leq t_e). \quad (79)$$

The next stage will extend the implemented lifecycle mechanism towards consent modification, delegation, and guardian-set changes, and will formalise the state-transition model so that unauthorised lifecycle transitions can be excluded by construction.

## 7.6 Progress of RO6: Security Assurance and Validation

Status: Partially Completed (empirical validation complete; formal assurance outstanding)

RO6 is partially completed through the implementation and initial scenario-based validation of the HALAH prototype. The current prototype provides a practical environment for evaluating the trust-oriented authorisation model using synthetic healthcare records. The system represents patients and healthcare participants using decentralised identities and provides mechanisms for consent creation, participant verification, multi-party approval, and access-control evaluation.

$$\text{Decision}(C, R) = \text{ALLOW}, V_I(u) \wedge V_A(C) \wedge V_P(C, R); \text{DENY}, \text{otherwise}. \quad (80)$$

Empirical validation now covers all six trust dimensions. A suite of 23 automated tests exercises per-dimension failures of the decision matrix, rejection of invalid EIP-712 guardian signatures, and tampered or expired zero-knowledge proofs. Live validation on the Sepolia testnet includes a negative demonstration in which a request declaring jurisdiction SA against a consent issued for AU is denied with  $V_L$  named as the failed check, and a revocation scenario in which the same consent, once revoked on-chain, is subsequently denied through  $V_A$ . Furthermore, an independent verification tool re-checks every ledger transaction hash against Sepolia receipts and reads each token back from the contract, reporting ALL CHECKS PASSED, and every granted access is accompanied by a real Groth16 proof generated and verified at request time. The implemented decision rule is  $\text{Decision}(C, R, t) = \text{ALLOW}$  iff  $V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L$ . Formal security analysis and a systematic performance study remain for the next stage.

At the current stage, the experimental evidence primarily demonstrates the consistency between the implemented consent, identity, and multi-party authorisation mechanisms and their corresponding research questions.

Policy-violation scenarios, temporal expiration, revocation and invalid lifecycle transitions have now been demonstrated empirically, both in the automated test suite and in the live Sepolia deployment. The remaining work for the next stage is therefore considerably narrower: formal definition and verification of the security properties, a systematic performance and overhead study, and the removal of prototype limitations such as the N-of-N approval rule, server-derived guardian keys and the unauthenticated requester role.

## 8 Publications Summary

The publication activities associated with this research are organised according to their current development status and their structural contribution to the thesis chapters and research questions.

**Table 7:** Summary of Research Outputs and Publication Plan

| Research Output / Topic                                                                                                                                                                    | Target Venue                   | Current Status | Thesis Alignment                                                                                                                                                                                                              |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Trust-Centric Consent Framework Model architecture and multi-party authorisation policies                                                                                                  | Elsevier/IEEE                  | Almost Ready   | Core architectural contribution; addresses RQ1-RQ4 (Chapters 3-4).                                                                                                                                                            |
| HALAH Prototype & Validation The decentralised implementation and the scenario-based validation are complete on the Sepolia public testnet; the performance evaluation remains outstanding | Systems / Security Conference  | In Progress    | Empirical validation platform; addresses implementation and validation; the paper's empirical section can now draw upon the deployed contract, the two minted tokens and the verified transaction trail as delivered evidence |
| Formal Security & Lifecycle Analysis Verification of temporal constraints and state transitions                                                                                            | Specialised Workshop / Journal | Planned        | Next stage research extension; addresses formal security assurance (Chapter 6).                                                                                                                                               |

The publication strategy is aligned with the progression of the research. The current stage work establishes the conceptual and technical foundation, while the next stage work will strengthen the framework through formal analysis and comprehensive empirical validation.

## 9 Research Plan

The research plan is divided into two major stages corresponding to current and next stage.

### 9.1 Current Stage: Completed and Current Work

RO1 to RO4 have been implemented and validated in the HALAH prototype, and RO5 is largely complete. The delivered evidence includes the ConsentSBTv3 contract deployed and source-verified on Sepolia at 0x0EC3617581DEC63A7f2bb162DC14d088916ADc73, with the evaluated consent minted as token #1 in block 11,771,243, revoked on-chain in block 11,771,307, and an independently reproduced lifecycle minted as token #2 in block 11,771,581. Each transaction hash is recorded in the audit ledger and is publicly inspectable on Etherscan.

The current stage focuses on establishing the foundational trust-oriented authorisation framework. The main activities are the development of the trust-centric consent model, decentralised identity and authority verification, multi-party authorisation, and policy-aware access control.

### 9.2 Next Stage: Planned Work

Temporal and lifecycle trust, originally planned for the next stage, has been brought forward and implemented: validity windows are enforced and anchored on-chain, revocation is effective at the contract level, and lifecycle transitions are governed by an explicit state machine. Consequently, the next stage concentrates on two remaining foci: formal security assurance and comprehensive empirical validation, including performance measurement.

The next stage will build upon the foundational trust-oriented authorisation framework established during current stage and extend the research towards dynamic consent governance, formal security assurance, and comprehensive empirical validation. While current stage focuses on establishing the core mechanisms required to construct a trustworthy authorisation decision, next stage will investigate whether this trust can be maintained over time, formally justified, and reliably demonstrated in practical healthcare data-sharing scenarios.

The first focus is formal security assurance. The current stage framework establishes the conceptual relationship between identity verification, collective authorisation, and policy enforcement. The next stage will investigate these relationships more rigorously by defining the security properties that the framework is expected to satisfy. The analysis will consider conditions such as invalid identities, insufficient authorisation, policy violations, expired consent, revoked consent, and unauthorised lifecycle transitions. The purpose of this work is not merely to demonstrate that the prototype works under normal conditions, but to establish explicit security properties and determine whether the proposed authorisation

model provides the expected protection when relevant security conditions are violated.

The second focus is comprehensive empirical validation. The HALAH prototype provides the experimental environment for evaluating the proposed framework using synthetic healthcare data and representative multi-party consent scenarios. Next stage will extend the current prototype-based evaluation to include both successful and adversarial access requests. The experiments will examine whether the implementation consistently produces an ALLOW decision only when the required trust conditions are satisfied and produces a DENY decision when one or more required conditions are violated. Particular attention will be given to the relationship between the formal security model and the observed behaviour of the implemented system. The major next stage activities and their expected outcomes are summarised in Table 8.

**Table 8:** Next Stage Research Activities, Methodological Focus, and Expected Outcomes

| Research Focus                                                 | Planned Activities                                                                                                                                                                                                                        | Expected Outcome                                                                                                                                              |
|----------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Consent Modification, Delegation and Lifecycle Extensions      | Extend the consent model to incorporate validity periods, dynamic expiration, immediate revocation, and controlled lifecycle transitions. Evaluate access decisions under varying temporal and consent-state constraints.                 | A robust, dynamic consent management mechanism capable of validating whether an authorisation remains active at the precise point of access.                  |
| Formal Security Assurance (Properties & Verification)          | Formally define critical security properties and analyse system behaviour under adverse conditions, including invalid identities, insufficient multi-party approvals, policy violations, expired/revoked states, and illegal transitions. | A rigorous formal security model and verification proof establishing explicit security guarantees for the trust-oriented authorisation framework.             |
| Comprehensive Empirical Validation (HALAH Prototype Scenarios) | Scale and extend HALAH prototype experiments using representative positive and negative healthcare data-sharing scenarios. Measure and compare observed system runtime performance, overhead, and enforcement accuracy.                   | Empirical evidence and benchmark datasets demonstrating that the implementation consistently and efficiently enforces the proposed authorisation model.       |
| Integrated Framework Evaluation (Synthesis & End-to-End)       | Integrate temporal, lifecycle, formal verification, and empirical modules into a unified, cohesive framework. Evaluate cross-component interactions, scalability bottlenecks, and end-to-end feasibility in real-world settings.          | A fully integrated, validated trust-oriented authorisation framework providing secure, multi-party patient consent and decentralised healthcare data sharing. |

Temporal and Lifecycle Trust — Completed (on-chain notBefore and expiry fields; revoke transaction confirmed in block 11,771,307; explicit lifecycle state machine). Comprehensive Empirical Validation — Partially delivered (23 automated tests; live jurisdiction denial and revocation-then-denial on Sepolia; independent chain verification reporting ALL CHECKS PASSED), with performance and overhead measurement remaining.

An important analytical objective of next stage is to examine the relationship between the different forms of trust established throughout the framework. Temporal validity, for example, should not be treated as an independent access-control feature. Instead, it should act as an additional condition on an already established authorisation relationship. Similarly, revocation should invalidate a previously established consent rather than merely create a new record indicating that the consent has changed. This perspective allows the research to investigate trust as a dynamic property rather than as a one-time outcome of authentication or approval.

The complete authorisation model developed across current stage and the next stage will therefore be evaluated as a conjunction of independently verifiable conditions. Conceptually, the final decision can be expressed as

$$Decision(C, R) = ALLOW \quad (81)$$

only when the identity and authority of the requester are valid, the required multi-party authorisation has been established, the requested operation satisfies the consent policy, and the consent remains valid according to its temporal and lifecycle state. If any required condition is violated, the framework should produce a denial decision and preserve sufficient evidence to explain the reason for that decision.

From a research perspective, this represents an important transition from static consent management to dynamic trustworthy authorisation. The objective is not to add a collection of independent security mechanisms, but to investigate how these mechanisms jointly contribute to the establishment, maintenance, and verification of trust throughout the consent lifecycle.

By the completion of next stage, the research is expected to provide three complementary forms of contribution. First, the research will provide a conceptual Trust Computing model that explains how trustworthy multi-party consent can be established and maintained. Second, it will provide a technical implementation through the HALAH prototype demonstrating how the proposed trust conditions can be enforced in a decentralised healthcare environment. Third, it will provide formal and empirical evidence concerning the security and practical effectiveness of the proposed framework.

Consequently, next stage will complete the transition from the foundational authorisation mechanisms established in current stage to a dynamically managed, formally reasoned, and empirically validated trust-oriented authorisation framework. The final contribution will be assessed

not simply by whether consent can be recorded or whether access can be granted, but by whether the system can provide a defensible basis for determining why an access decision should be trusted and when that trust should no longer apply.

## Appendix A — Traceability to the Implemented System

Table 10 summarises how each formal artefact of this report is realised in the implemented HALAH subsystem presented in Section 6.8, and which publicly verifiable evidence supports it.

| Research artefact                                          | Defined in   | Realised by (implementation)                                                                  | Publicly verifiable evidence                                           |
|------------------------------------------------------------|--------------|-----------------------------------------------------------------------------------------------|------------------------------------------------------------------------|
| RO1 / RQ1 — Consent object, Eq. (51), Algorithm 1          | \$6.1        | Patient subsystem: consent creation; state PENDING_SIGNATURE                                  | Consents f050c29a and 04da25f5 in the exported audit ledger            |
| RO2 / RQ2 — DID and VC verification, Algorithm 2           | \$6.2        | Guardian subsystem: EIP-712 typed-data signatures, off-chain signer recovery per guardian DID | Verified signer 0x3Af549b0... recorded per SIGN_CONSENT event          |
| RO3 / RQ3 — Threshold authorisation, Eq. (54), Algorithm 3 | \$6.3        | 2-of-2 ceremony with $N =  G $ ; SBT minted on threshold                                      | Mint tx 0x8be1b99e... daf13d, block 11,771,243, token #1               |
| Decision rule and trust predicates, Eq. (59), Figure 8     | \$5.2, \$6.6 | Doctor subsystem: five-verdict decision matrix, ALLOW / DENY with failed-check listing        | GRANTED and DENIED DATA_ACCESS events; SA-jurisdiction denial          |
| Lifecycle trust (RO5 direction)                            | \$6.5        | Six-state lifecycle with on-chain revocation (Section 6.8.6)                                  | Revoke tx 0x017efb9d... dceaa, block 11,771,307                        |
| Empirical assurance (RO6, empirical half)                  | \$6.6        | Auditor subsystem and the independent verifier re-checking every transaction receipt          | 60-event ledger; RESULT: ALL CHECKS PASSED; token #2, block 11,771,581 |

*Table 10: Traceability from the formal artefacts of this report to the implemented mechanisms and their on-chain evidence.*

## References

- [1] Abdullah Al Mamun, Sami Azam, and Clementine Gritti. Blockchain-based electronic health records management: a comprehensive review and future research direction. *IEEE Access*, 10:5768–5789, 2022.
- [2] J Andrew, Deva Priya Isravel, K Martin Sagayam, Bharat Bhushan, Yuichi Sei, and Jennifer Eunice. Blockchain for healthcare systems: Architecture, security challenges, trends and future directions. *Journal of Network and Computer Applications*, 215:103633, 2023.
- [3] Mohammad Salar Arbabi, Chhagan Lal, Narasimha Raghavan Veeraragavan, Dusica Marijan, Jan F Nygård, and Roman Vitenberg. A survey on blockchain for healthcare: Challenges, benefits, and future directions. *IEEE Communications Surveys & Tutorials*, 25(1):386–424, 2023.
- [4] Haotian Deng, Jinwen Liang, Chuan Zhang, Ximeng Liu, Liehuang Zhu, and Song Guo. FutureDID: A fully decentralized identity system with multi-party verification. *IEEE Transactions on Computers*, 73(8):2051–2065, 2024.
- [5] Andrea Flamini, Giada Sciarretta, Mario Scuro, Amir Sharif, Alessandro Tomasi, and Silvio Ranise. On cryptographic mechanisms for the selective disclosure of verifiable credentials. *Journal of Information Security and Applications*, 83:103789, 2024.
- [6] Abdul Ghafoor, Iraklis Symeonidis, Anna Rydberg, Cecilia Lindahl, and Abdul Qadus Abbasi. Towards empowering stakeholders through decentralized trust and secure livestock data sharing. *Cryptography*, 9(3):52, 2025.
- [7] Pranto Kumar Ghosh, Arindom Chakraborty, Mehedi Hasan, Khalid Rashid, and Abdul Hasib Siddique. Blockchain application in healthcare systems: a review. *Systems*, 11(1):38, 2023.
- [8] Remy Hellstern, Daniel C Park, Victoria Lemieux, and Guldana Salimjan. Leveraging blockchain-based archival solutions for sensitive documentation: A Xinjiang case study. *Digital Society*, 1(1):4, 2022.
- [9] Ateya Megahed Ibrahim, Hassanat Ramadan Abdel-Aziz, Heba Ali Hamed Mohamed, Donia Elsaid Fathi Zaghmir, Nadia Mohamed Ibrahim Wahba, Ghada A Hassan, Mostafa Shaban, Mohammad El-Nablaway, Ohoud Naif Aldughmi, and Taghreed Hussien Aboelola. Balancing confidentiality and care coordination: challenges in patient privacy. *BMC Nursing*, 23(1):564, 2024.
- [10] Vitor Jesus and Harshvardhan J Pandit. Consent receipts for a usable and auditable web of personal data. *IEEE Access*, 10:28545–28563, 2022.
- [11] Rong Jiang, Xue Chen, Yimin Yu, Ying Zhang, and Weiping Ding. Risk and UCON-based access control model for healthcare big data. *Journal of Big Data*, 10(1):104, 2023.

- [12] Katya Kaplow, Max Downey, Darren Stewart, Allan B Massie, Jennifer D Motter, Lauren Taylor, John Massarelli, Taylor Matalon, Carolyn Sidoti, Macey L Levan, et al. Data professionals' attitudes on data privacy, sharing, and consent in healthcare and research. *Digital Health*, 10:20552076241290964, 2024.
- [13] Muhammad Irfan Khalid, Mansoor Ahmed, Markus Helfert, and Jungsuk Kim. Privacy-first paradigm for dynamic consent management systems: empowering data subjects through decentralized data controllers and privacy-preserving techniques. *Electronics*, 12(24):4973, 2023.
- [14] Alexander Kharlamov, Roland Hohmann, and Glenn Parry. Data sharing decisions: perceptions and intentions in healthcare. *Strategic Change*, 32(6):223–237, 2023.
- [15] Behnam Khayer, Siamak Mirzaei, Hooman Alavizadeh, and Ahmad Salehi Shahraki. Blockchain for secure IoT: A review of identity management, access control, and trust mechanisms. *IoT*, 6(4):65, 2025.
- [16] Chalima Dimitra Nassar Kyriakidou, Athanasia Maria Papathanasiou, and George C Polyzos. Decentralized identity with applications to security and privacy for the internet of things. *Computer Networks and Communications*, 1(2):244–271, 2023.
- [17] Lanlan Li, Charles Z Liu, Kejia Huang, Ruiyi Deng, Majed Abdullah Alrowaily, Mansoor Alghamdi, Ibrahim S Alkhazi, and Malek Alrashidi. Trust-aware environmental state consensus for smart agriculture with TEE-enabled sensing and Byzantine-resilient blockchain coordination. *Sensors*, 26(14):4577, 2026.
- [18] Lanlan Li, Charles Z Liu, and Sanjeeb Shrestha. Analytical entropy approach for measuring blockchain immutability and tamper-resilient trust. *Entropy*, 28(6):690, 2026.
- [19] Richard K Lomotey, Sandra Kumi, and Ralph Deters. Data trusts as a service: Providing a platform for multi-party data sharing. *International Journal of Information Management Data Insights*, 2(1):100075, 2022.
- [20] Carlo Mazzocca, Abbas Acar, Selcuk Uluagac, Rebecca Montanari, Paolo Bellavista, and Mauro Conti. A survey on decentralized identifiers and verifiable credentials. *IEEE Communications Surveys & Tutorials*, 27:3641–3671, 2025.
- [21] Cindy Welzel, Max Ostermann, Hannah Louise Smith, Timo Minssen, Toralf Kirsten, and Stephen Gilbert. Enabling secure and self determined health data sharing and consent management. *npj Digital Medicine*, 8(1):560, 2025.

♦ [RED — يجب حله قبل التسليم] R7: This reference replaced an unverifiable preprint. Read the Welzel et al. article before the viva and confirm it genuinely supports the three places citing [21] (patient autonomy and privacy-preserving interoperability in 2.3.1; multi-stakeholder authority in 2.3.4; the corpus list in 2.2).

- [22] Roy McClelland and Colin M Harper. Information privacy in healthcare—the vital role of informed consent. *European Journal of Health Law*, 30(4):469–480, 2023.
- [23] Jämes Ménétrey, Christian Göttel, Anum Khurshid, Marcelo Pasin, Pascal Felber, Valerio Schiavoni, and Shahid Raza. Attestation mechanisms for trusted execution environments demystified. In *IFIP International Conference on Distributed Applications and Interoperable Systems*, pages 95–113. Springer, 2022.
- [24] Minal R Narkhede, Nilesh I Wankhede, and Akanksha M Kamble. Enhancing patient autonomy in data ownership: privacy models and consent frameworks for healthcare. *Journal of Digital Health*, 4(1):1–23, 2025.
- [25] Aleena Nazir, Mubashir Husain Rehmani, Bernard Butler, and Donna O’Shea. Access control in healthcare IoT: A comprehensive survey. *Engineering Reports*, 8(4):e70766, 2026.
- [26] Thanh Linh Nguyen, Lam Nguyen, Thong Hoang, Dilum Bandara, Qin Wang, Qinghua Lu, Xiwei Xu, Liming Zhu, and Shiping Chen. Blockchain-empowered trustworthy data sharing: Fundamentals, applications, and challenges. *ACM Computing Surveys*, 57(8):1–36, 2025.
- [27] Rohini Poolat Parameswarath, Prosanta Gope, and Biplab Sikdar. User-empowered privacy-preserving authentication protocol for electric vehicle charging based on decentralized identity and verifiable credential. *ACM Transactions on Management Information Systems (TMIS)*, 13(4):1–21, 2022.
- [28] Ahmed M Tawfik, Ayman Al-Ahwal, Adly S Tag Eldien, and Hala H Zayed. Blockchain-based access control and privacy preservation in healthcare: a comprehensive survey. *Cluster Computing*, 28(8):529, 2025.
- [29] Leonidas Theodorakopoulos, Alexandra Theodoropoulou, and Constantinos Halkiopoulos. Enhancing decentralized decision-making with big data and blockchain technology: A comprehensive review. *Applied Sciences*, 14(16):7007, 2024.
- [30] Mohammad Nawab Turan, Irshad Ahmed Hashimzai, and Mohammad Qaseem Qiam. A blockchain-based framework for secure and transparent environmental data sharing in smart cities: Enhancing trust, integrity, and interoperability in urban sustainability systems. *Nata Palemahan: Journal of Environmental Engineering Innovations*, 2(2):70–79, 2025.
- [31] Emily C Webber, David Brick, James P Scibilia, Peter Dehnel, Council on Clinical Information Technology, et al. Electronic communication of the health record and information with pediatric patients and their guardians. *Pediatrics*, 144(1):e20191359, 2019.
- [32] Hongjian Yin, Yiming Zhao, Lei Zhang, Baojun Qiao, Wenbo Chen, and Huaqing Wang. Attribute-based searchable encryption with decentralized

key management for healthcare data sharing. *Journal of Systems Architecture*, 148:103081, 2024.

[33] Jie Yin, Yang Xiao, Qian Chen, Xuefeng Liu, Qingqi Pei, Jianying Zhou, et al. DP-DID: A dynamic and proactive decentralized identity system. *IEEE Transactions on Information Forensics and Security*, 20:4999–5014, 2025.

[34] Matthew J Page, Joanne E McKenzie, Patrick M Bossuyt, Isabelle Boutron, Tammy C Hoffmann, Cynthia D Mulrow, et al. The PRISMA 2020 statement: an updated guideline for reporting systematic reviews. *BMJ*, 372:n71, 2021.

◆ [GREEN — غير مهم] G1: [21] and [34] break the alphabetical order of the list. Numeric citation styles do not require alphabetical order; fixing it would force renumbering every in-text citation. Recommended: leave as is.